

**DIN EN IEC 62443-3-3
(VDE 0802-3-3)**

DIN

Diese Norm ist zugleich eine **VDE-Bestimmung** im Sinne von VDE 0022. Sie ist nach Durchführung des vom VDE-Präsidium beschlossenen Genehmigungsverfahrens unter der oben angeführten Nummer in das VDE-Vorschriftenwerk aufgenommen und in der „etz Elektrotechnik + Automation“ bekannt gegeben worden.

VDE

Vervielfältigung – auch für innerbetriebliche Zwecke – nicht gestattet.

ICS 35.030; 35.240.50

**Industrielle Kommunikationsnetze –
IT-Sicherheit für Netze und Systeme –
Teil 3-3: Systemanforderungen zur IT-Sicherheit und Security-Level
(IEC 62443-3-3:2013 + COR1:2014);
Deutsche Fassung EN IEC 62443-3-3:2019 + AC:2019**

Industrial communication networks –
Network and system security –
Part 3-3: System security requirements and security levels
(IEC 62443-3-3:2013 + COR1:2014);
German version EN IEC 62443-3-3:2019 + AC:2019

Réseaux industriels de communication –
Sécurité dans les réseaux et les systèmes –
Partie-3: Exigences relatives à la sécurité dans les systèmes et niveaux de sécurité
(IEC 62443-3-3:2013 + COR1:2014);
Version allemande EN IEC 62443-3-3:2019 + AC:2019

Gesamtumfang 91 Seiten

DKE Deutsche Kommission Elektrotechnik Elektronik Informationstechnik in DIN und VDE

Anwendungsbeginn

Anwendungsbeginn für die von CENELEC am 2019-04-03 angenommene Europäische Norm als DIN-Norm ist 2020-01-01.

Diese Norm enthält die Berichtigung EN IEC 62443-3-3:2019/AC:2019, die das Corrigendum 1:2014 zu IEC 62443-3-3:2013 übernimmt.

Nationales Vorwort

Vorausgegangener Norm-Entwurf: E DIN IEC 62443-3-3 (VDE 0802-3-3):2015-06.

Für dieses Dokument ist das nationale Arbeitsgremium UK 931.1 „IT-Sicherheit in der Automatisierungstechnik“ der DKE Deutsche Kommission Elektrotechnik Elektronik Informationstechnik in DIN und VDE (www.dke.de) zuständig.

Die enthaltene IEC-Publikation wurde vom TC 65 „Industrial-process measurement, control and automation“ erarbeitet.

Das IEC-Komitee hat entschieden, dass der Inhalt dieses Dokuments bis zu dem Datum (stability date) unverändert bleiben soll, das auf der IEC-Website unter „<http://webstore.iec.ch>“ zu diesem Dokument angegeben ist. Zu diesem Zeitpunkt wird entsprechend der Entscheidung des Komitees das Dokument

- bestätigt,
- zurückgezogen,
- durch eine Folgeausgabe ersetzt oder
- geändert.

AC

Das IEC-Corrigendum 1, von CENELEC angenommen als AC, wurde eingearbeitet und mit einer senkrechten Linie und „AC“ am linken Textrand gekennzeichnet.

Das Original-Dokument enthält Bilder in Farbe, die in der Papierversion in einer Graustufen-Darstellung wiedergegeben werden. Elektronische Versionen dieses Dokuments enthalten die Bilder in der originalen Farbdarstellung.

Die Deutsche Fassung wurde im [Abschnitt 3](#) an den aktuellen Standardtext angepasst.

Zu den terminologischen Einträgen in [Abschnitt 3](#) hat das Nationale Gremium noch die folgenden Hinweise:

- Zu [3.1.8](#):
Zum Begriff „Verfügbarkeit“ siehe auch „Internationales Elektrotechnisches Wörterbuch – Deutsche Ausgabe“, Online-Zugang: <http://www.dke.de/dke-iev>.
- Zu [3.1.17](#):
Für den Begriff „Maßnahme“ verwendet ISO/IEC 27001:2008 die Benennung „control“ und IEC 62443-3-3:2013 „countermeasure“. Hierauf macht die Anmerkung in IEC 62443-3-3:2013 aufmerksam. Der Text dieser Anmerkung wurde nicht übersetzt. Da beide Benennungen in den jeweiligen deutschen Fassungen dieser Normen mit „Maßnahme“ übersetzt wurden, tritt in diesen die beschriebene Schwierigkeit nicht auf.
- Zu [3.1.20](#):
Die Definition des Begriffs „Gerät“ trifft auf „eingebettetes Gerät“ zu.

Nationaler Anhang NA (informativ)

Zusammenhang mit europäischen und internationalen Dokumenten

Für den Fall einer undatierten Verweisung im normativen Text (Verweisung auf ein Dokument ohne Angabe des Ausgabedatums und ohne Hinweis auf eine Abschnittsnummer, eine Tabelle, ein Bild usw.) bezieht sich die Verweisung auf die jeweils aktuellste Ausgabe des in Bezug genommenen Dokuments.

Für den Fall einer datierten Verweisung im normativen Text bezieht sich die Verweisung immer auf die in Bezug genommene Ausgabe des Dokuments.

Eine Information über den Zusammenhang der zitierten Dokumente mit den entsprechenden deutschen Dokumenten ist nachstehend wiedergegeben.

Tabelle NA.1

Europäisches Dokument	Internationales Dokument	Deutsches Dokument	Klassifikation im VDE-Vorschriftenwerk
–	IEC 62443-2-1	–	–
EN IEC 62443-4-1	IEC 62443-4-1	DIN EN IEC 62443-4-1 (VDE 0802-4-1)	VDE 0802-4-1
EN IEC 62443-4-2	IEC 62443-4-2 ^a	DIN EN 62443-4-2 (VDE 0802-4-2)	VDE 0802-4-2
–	IEC/TS 62443-1-1:2009	–	–
–	IEC/TS 62443-1-3	–	–
–	IEC 62443-2-4:2015 + Cor.:2015	DIN IEC 62443-2-4 (VDE 0802-2-4)	VDE 0802-2-4
EN 62443-3-2 ^a	IEC 62443-3-2 ^a	DIN EN 62443-3-2 (VDE 0802-3-2)	VDE 0802-3-2
–	IEC/TR 62443-1-2 ^a	–	–
–	IEC/TR 62443-1-4 ^a	–	–
–	IEC/TR 62443-2-2 ^a	–	–
–	IEC/TR 62443-2-3	–	–
–	IEC/TR 62443-3-1	–	–
–	ISO/IEC 19790	–	–
EN ISO/IEC 27002	ISO/IEC 27002	DIN EN ISO/IEC 27002	–
^a In Vorbereitung.			

Nationaler Anhang NB (informativ)

Literaturhinweise

DIN IEC 62443-2-4 (VDE 0802-2-4), *IT-Sicherheit für industrielle Automatisierungssysteme – Teil 2-4: Anforderungen an das IT-Sicherheitsprogramm von Dienstleistern für industrielle Automatisierungssysteme*

DIN EN 62443-3-2 (VDE 0802-3-2) (in Vorbereitung), *Sicherheit für industrielle Automatisierungssysteme – Teil 3-2: Sicherheitsrisikobeurteilung und Systemgestaltung*

DIN EN 62443-4-2 (VDE 0802-4-2) (in Vorbereitung), *Industrielle Kommunikationsnetze – IT-Sicherheit für industrielle Automatisierungssysteme – Teil 4-2: Anforderungen an Komponenten industrieller Automatisierungssysteme*

DIN EN IEC 62443-4-1 (VDE 0802-4-1), *IT-Sicherheit für industrielle Automatisierungssysteme – Teil 4-1: Anforderungen an den Lebenszyklus für eine sichere Produktentwicklung*

DIN EN ISO/IEC 27002, *Informationstechnik – Sicherheitsverfahren – Leitfaden für Informationssicherheitsmaßnahmen*

EUROPÄISCHE NORM
EUROPEAN STANDARD
NORME EUROPÉENNE

EN IEC 62443-3-3

April 2019

+ AC

Oktober 2019

ICS 25.040.40; 35.110

Deutsche Fassung

Industrielle Kommunikationsnetze –
IT-Sicherheit für Netze und Systeme –
Teil 3-3: Systemanforderungen zur IT-Sicherheit und Security-Level
(IEC 62443-3-3:2013 + COR1:2014)

Industrial communication networks –
Network and system security –
Part 3-3: System security requirements and
security levels
(IEC 62443-3-3:2013 + COR1:2014)

Réseaux industriels de communication –
Sécurité dans les réseaux et les systèmes –
Partie-3: Exigences relatives à la sécurité dans
les systèmes et niveaux de sécurité
(IEC 62443-3-3:2013 + COR1:2014)

Diese Europäische Norm wurde von CENELEC am 2019-04-03 angenommen.

Die Berichtigung tritt am 11. Oktober 2019 zur Einarbeitung in die deutsche Fassung der EN in Kraft.

CENELEC-Mitglieder sind gehalten, die CEN/CENELEC-Geschäftsordnung zu erfüllen, in der die Bedingungen festgelegt sind, unter denen dieser Europäischen Norm ohne jede Änderung der Status einer nationalen Norm zu geben ist.

Auf dem letzten Stand befindliche Listen dieser nationalen Normen mit ihren bibliographischen Angaben sind beim CEN-CENELEC Management Centre oder bei jedem CENELEC-Mitglied auf Anfrage erhältlich.

Diese Europäische Norm besteht in drei offiziellen Fassungen (Deutsch, Englisch, Französisch). Eine Fassung in einer anderen Sprache, die von einem CENELEC-Mitglied in eigener Verantwortung durch Übersetzung in seine Landessprache gemacht und dem CEN-CENELEC Management Centre mitgeteilt worden ist, hat den gleichen Status wie die offiziellen Fassungen.

CENELEC-Mitglieder sind die nationalen elektrotechnischen Komitees von Belgien, Bulgarien, Dänemark, Deutschland, der ehemaligen jugoslawischen Republik Mazedonien, Estland, Finnland, Frankreich, Griechenland, Irland, Island, Italien, Kroatien, Lettland, Litauen, Luxemburg, Malta, den Niederlanden, Norwegen, Österreich, Polen, Portugal, Rumänien, Schweden, der Schweiz, Serbien, der Slowakei, Slowenien, Spanien, der Tschechischen Republik, der Türkei, Ungarn, dem Vereinigten Königreich und Zypern.



Europäisches Komitee für Elektrotechnische Normung
European Committee for Electrotechnical Standardization
Comité Européen de Normalisation Electrotechnique

CEN-CENELEC Management Centre: Rue de la Science 23, B-1040 Brüssel

© 2019 CENELEC – Alle Rechte der Verwertung, gleich in welcher Form und in welchem Verfahren,
sind weltweit den Mitgliedern von CENELEC vorbehalten.

Ref. Nr. EN IEC 62443-3-3:2019 + AC:2019 D

Europäisches Vorwort

Dieses Dokument (EN IEC 62443-3-3:2019) enthält den Text der IEC 62443-3-3:2013, die vom IEC/TC 65 „Industrial-process measurement, control and automation“ erarbeitet wurde.

Nachstehende Daten wurden festgelegt:

- spätestes Datum, zu dem dieses Dokument auf nationaler Ebene durch Veröffentlichung einer identischen nationalen Norm oder durch Anerkennung übernommen werden muss (dop): 2020-04-03
- spätestes Datum, zu dem nationale Normen, die diesem Dokument entgegenstehen, zurückgezogen werden müssen (dow): 2022-04-03

Es wird auf die Möglichkeit hingewiesen, dass einige Elemente dieses Dokuments Patentrechte berühren können. CENELEC ist nicht dafür verantwortlich, einige oder alle diesbezüglichen Patentrechte zu identifizieren.

Anerkennungsnotiz

Der Text der Internationalen Norm IEC 62443-3-3:2013 wurde von CENELEC ohne irgendeine Abänderung als Europäische Norm angenommen.

In der offiziellen Fassung sind unter „Literaturhinweise“ zu den aufgelisteten Normen die nachstehenden Anmerkungen einzutragen:

IEC 62443-2-4	ANMERKUNG	Harmonisiert als EN IEC 62443-2-4.
IEC 62443-4-1	ANMERKUNG	Harmonisiert als EN IEC 62443-4-1.
IEC 62443-4-2	ANMERKUNG	Harmonisiert als EN IEC 62443-4-2.
ISO/IEC 27002	ANMERKUNG	Harmonisiert als EN ISO/IEC 27002.

Anerkennungsnotiz zu AC

Der Text der Berichtigung IEC 62443-3-3:2013/COR1:2014 wurde von CENELEC ohne irgendeine Abänderung als EN IEC 62443-3-3:2019/AC:2019-10 angenommen.

Anhang ZA (normativ)

Normative Verweisungen auf internationale Publikationen mit ihren entsprechenden europäischen Publikationen

Die folgenden Dokumente werden im Text in solcher Weise in Bezug genommen, dass einige Teile davon oder ihr gesamter Inhalt Anforderungen des vorliegenden Dokuments darstellen. Bei datierten Verweisungen gilt nur die in Bezug genommene Ausgabe. Bei undatierten Verweisungen gilt die letzte Ausgabe des in Bezug genommenen Dokuments (einschließlich aller Änderungen).

ANMERKUNG 1 Ist eine internationale Publikation durch gemeinsame Abänderungen modifiziert worden, gekennzeichnet durch (mod.), dann gilt die entsprechende EN oder das HD.

ANMERKUNG 2 Aktualisierte Informationen über die in diesem Anhang aufgeführten aktuellen Fassungen der Europäischen Normen sind hier verfügbar: www.cenelec.eu.

<u>Publikation</u>	<u>Jahr</u>	<u>Titel</u>	<u>EN/HD</u>	<u>Jahr</u>
IEC 62443-2-1	–	Industrial communication networks – Network and system security – Part 2-1: Establishing an industrial automation and control system security program	–	–
IEC/TS 62443-1-1	2009	Industrial communication networks – Network and system security – Part 1-1: Terminology, concepts and models	–	–

Inhalt	Seite
Europäisches Vorwort.....	2
Anhang ZA (normativ) Normative Verweisungen auf internationale Publikationen mit ihren entsprechenden europäischen Publikationen	3
0 Einleitung	13
0.1 Überblick.....	13
0.2 Zweck und Anwenderkreis	14
0.3 Verwendung innerhalb anderer Teile der Normenreihe IEC 62443.....	14
1 Anwendungsbereich	16
2 Normative Verweisungen	16
3 Begriffe, Abkürzungen und Erläuterungen	16
3.1 Begriffe	16
3.2 Abkürzungen	24
3.3 Vereinbarungen	26
4 Beschränkungen der IT-Sicherheit aufgrund der Natur des Automatisierungssystems	27
4.1 Überblick.....	27
4.2 Unterstützung wesentlicher Funktionen	27
4.3 Ausgleichsmaßnahmen	28
4.4 Minimal erforderliche Rechte (en: least privilege)	28
5 Grundlegende Anforderung FR 1 – Identifizierung und Authentifizierung	29
5.1 Zweck und Beschreibungen des SL-C(IAC).....	29
5.2 Begründung	29
5.3 SR 1.1 – Identifizierung und Authentifizierung von menschlichen Nutzern	29
5.3.1 Anforderung.....	29
5.3.2 Begründung und zusätzliche Hinweise	29
5.3.3 Weitergehende Anforderungen	30
5.3.4 Security-Level.....	30
5.4 SR 1.2 – Identifizierung und Authentifizierung von Softwareprozessen und Geräten	30
5.4.1 Anforderung.....	30
5.4.2 Begründung und zusätzliche Hinweise	30
5.4.3 Weitergehende Anforderungen	31
5.4.4 Security-Level.....	31
5.5 SR 1.3 – Nutzerkontenverwaltung.....	32
5.5.1 Anforderung.....	32
5.5.2 Begründung und zusätzliche Hinweise	32
5.5.3 Weitergehende Anforderungen	32
5.5.4 Security-Level.....	32
5.6 SR 1.4 – Verwaltung der Bezeichner	32
5.6.1 Anforderung.....	32

	Seite
5.6.2 Begründung und zusätzliche Hinweise	32
5.6.3 Weitergehende Anforderungen	33
5.6.4 Security-Level	33
5.7 SR 1.5 – Verwaltung der Authentifizierer	33
5.7.1 Anforderung	33
5.7.2 Begründung und zusätzliche Hinweise	33
5.7.3 Weitergehende Anforderungen	34
5.7.4 Security-Level	34
5.8 SR 1.6 – Management drahtloser Zugriffsverfahren	34
5.8.1 Anforderung	34
5.8.2 Begründung und zusätzliche Hinweise	35
5.8.3 Weitergehende Anforderungen	35
5.8.4 Security-Level	35
5.9 SR 1.7 – Stärke der Authentifizierung durch Passwörter	35
5.9.1 Anforderung	35
5.9.2 Begründung und zusätzliche Hinweise	35
5.9.3 Weitergehende Anforderungen	36
5.9.4 Security-Level	36
5.10 SR 1.8 – PKI-Zertifikate	36
5.10.1 Anforderung	36
5.10.2 Begründung und zusätzliche Hinweise	36
5.10.3 Weitergehende Anforderungen	37
5.10.4 Security-Level	37
5.11 SR 1.9 – Stärke der Authentifizierung durch öffentliche Schlüssel	37
5.11.1 Anforderung	37
5.11.2 Begründung und zusätzliche Hinweise	37
5.11.3 Weitergehende Anforderungen	38
5.11.4 Security-Level	38
5.12 SR 1.10 – Rückmeldung vom Authentifizierer	38
5.12.1 Anforderung	38
5.12.2 Begründung und zusätzliche Hinweise	38
5.12.3 Weitergehende Anforderungen	38
5.12.4 Security-Level	38
5.13 SR 1.11 – Erfolgreiche Anmeldeversuche	39
5.13.1 Anforderung	39
5.13.2 Begründung und zusätzliche Hinweise	39
5.13.3 Weitergehende Anforderungen	39
5.13.4 Security-Level	39
5.14 SR 1.12 – Nutzungshinweis	39

	Seite
5.14.1 Anforderung.....	39
5.14.2 Begründung und zusätzliche Hinweise	39
5.14.3 Weitergehende Anforderungen	40
5.14.4 Security-Level.....	40
5.15 SR 1.13 – Zugriff über nicht vertrauenswürdige Netze	40
5.15.1 Anforderung.....	40
5.15.2 Begründung und zusätzliche Hinweise	40
5.15.3 Weitergehende Anforderungen	40
5.15.4 Security-Level.....	40
6 Grundlegende Anforderung FR 2 – Nutzungskontrolle	41
6.1 Zweck und Beschreibungen des SL-C(UC)	41
6.2 Begründung	41
6.3 SR 2.1 – Durchsetzung der Autorisierung.....	41
6.3.1 Anforderung.....	41
6.3.2 Erläuterung und zusätzliche Hinweise	41
6.3.3 Weitergehende Anforderungen	42
6.3.4 Security-Level.....	42
6.4 SR 2.2 – Nutzungskontrolle von Funkverbindungen.....	43
6.4.1 Anforderung.....	43
6.4.2 Begründung und zusätzliche Hinweise	43
6.4.3 Weitergehende Anforderungen	43
6.4.4 Security-Level.....	43
6.5 SR 2.3 – Nutzungskontrolle von tragbaren und mobilen Geräten	43
6.5.1 Anforderung.....	43
6.5.2 Begründung und zusätzliche Hinweise	43
6.5.3 Weitergehende Anforderungen	44
6.5.4 Security-Level.....	44
6.6 SR 2.4 – Plattformübergreifender Code	44
6.6.1 Anforderung.....	44
6.6.2 Begründung und zusätzliche Hinweise	44
6.6.3 Weitergehende Anforderungen	44
6.6.4 Security-Level.....	45
6.7 SR 2.5 – Sitzungssperrung	45
6.7.1 Anforderung.....	45
6.7.2 Begründung und zusätzliche Hinweise	45
6.7.3 Weitergehende Anforderungen	45
6.7.4 Security-Level.....	45
6.8 SR 2.6 – Beendigung einer Fernzugriffssitzung.....	45
6.8.1 Anforderung.....	45

	Seite
6.8.2 Begründung und zusätzliche Hinweise	45
6.8.3 Weitergehende Anforderungen	46
6.8.4 Security-Level	46
6.9 SR 2.7 – Begrenzung der Anzahl gleichzeitiger Sitzungen	46
6.9.1 Anforderung	46
6.9.2 Begründung und zusätzliche Hinweise	46
6.9.3 Weitergehende Anforderungen	46
6.9.4 Security-Level	46
6.10 SR 2.8 – Prüfbare Ereignisse und deren Aufzeichnung	46
6.10.1 Anforderung	46
6.10.2 Begründung und zusätzliche Hinweise	47
6.10.3 Weitergehende Anforderungen	47
6.10.4 Security-Level	47
6.11 SR 2.9 – Speicherkapazität für Aufzeichnungen	47
6.11.1 Anforderung	47
6.11.2 Begründung und zusätzliche Hinweise	47
6.11.3 Weitergehende Anforderungen	48
6.11.4 Security-Level	48
6.12 SR 2.10 – Reaktion auf ausgefallene Verarbeitung von Ereignisdaten	48
6.12.1 Anforderung	48
6.12.2 Begründung und zusätzliche Hinweise	48
6.12.3 Weitergehende Anforderungen	48
6.12.4 Security-Level	48
6.13 SR 2.11 – Zeitstempel	49
6.13.1 Anforderung	49
6.13.2 Begründung und zusätzliche Hinweise	49
6.13.3 Weitergehende Anforderungen	49
6.13.4 Security-Level	49
6.14 SR 2.12 – Nichtabstreitbarkeit	49
6.14.1 Anforderung	49
6.14.2 Begründung und zusätzliche Hinweise	49
6.14.3 Weitergehende Anforderungen	50
6.14.4 Security-Level	50
7 Grundlegende Anforderung FR 3 – Systemintegrität	50
7.1 Zweck und Beschreibungen des SL-C(SI)	50
7.2 Begründung	50
7.3 SR 3.1 – Kommunikationsintegrität	50
7.3.1 Anforderung	50
7.3.2 Begründung und zusätzliche Hinweise	50

	Seite
7.3.3 Weitergehende Anforderungen	51
7.3.4 Security-Level.....	51
7.4 SR 3.2 – Schutz vor Schadcode	52
7.4.1 Anforderung.....	52
7.4.2 Begründung und zusätzliche Hinweise	52
7.4.3 Weitergehende Anforderungen	52
7.4.4 Security-Level.....	52
7.5 SR 3.3 – Verifikation der IT-Sicherheitsfunktionalität.....	53
7.5.1 Anforderung.....	53
7.5.2 Begründung und zusätzliche Hinweise	53
7.5.3 Weitergehende Anforderungen	53
7.5.4 Security-Level.....	53
7.6 SR 3.4 – Software- und Informationsintegrität	54
7.6.1 Anforderung.....	54
7.6.2 Begründung und zusätzliche Hinweise	54
7.6.3 Weitergehende Anforderungen	54
7.6.4 Security-Level.....	54
7.7 SR 3.5 – Eingabevalidierung	54
7.7.1 Anforderung.....	54
7.7.2 Begründung und zusätzliche Hinweise	54
7.7.3 Weitergehende Anforderungen	55
7.7.4 Security-Level.....	55
7.8 SR 3.6 – Vorbestimmte Zustände der Ausgänge.....	55
7.8.1 Anforderung.....	55
7.8.2 Begründung und zusätzliche Hinweise	55
7.8.3 Weitergehende Anforderungen	55
7.8.4 Security-Level.....	55
7.9 SR 3.7 – Fehlerbehandlung	55
7.9.1 Anforderung.....	55
7.9.2 Begründung und zusätzliche Hinweise	56
7.9.3 Weitergehende Anforderungen	56
7.9.4 Security-Level.....	56
7.10 SR 3.8 – Sitzungsintegrität.....	56
7.10.1 Anforderung.....	56
7.10.2 Begründung und zusätzliche Hinweise	56
7.10.3 Weitergehende Anforderungen	56
7.10.4 Security-Level.....	57
7.11 SR 3.9 – Schutz von Prüfinformationen	57
7.11.1 Anforderung.....	57

	Seite
7.11.2 Begründung und zusätzliche Hinweise	57
7.11.3 Weitergehende Anforderungen	57
7.11.4 Security-Level	57
8 Grundlegende Anforderung FR 4 – Vertraulichkeit der Daten	57
8.1 Zweck und Beschreibungen des SL-C(DC)	57
8.2 Begründung	58
8.3 SR 4.1 – Vertraulichkeit von Informationen	58
8.3.1 Anforderung	58
8.3.2 Begründung und zusätzliche Hinweise	58
8.3.3 Weitergehende Anforderungen	59
8.3.4 Security-Level	59
8.4 SR 4.2 – Dauerhaftigkeit von Informationen	59
8.4.1 Anforderung	59
8.4.2 Begründung und zusätzliche Hinweise	59
8.4.3 Weitergehende Anforderungen	59
8.4.4 Security-Level	60
8.5 SR 4.3 – Verwendung von Verschlüsselung	60
8.5.1 Anforderung	60
8.5.2 Begründung und zusätzliche Hinweise	60
8.5.3 Weitergehende Anforderungen	60
8.5.4 Security-Level	60
9 Grundlegende Anforderung FR 5 – Eingeschränkter Datenfluss	61
9.1 Zweck und Beschreibungen des SL-C(RDF)	61
9.2 Begründung	61
9.3 SR 5.1 – Netzaufteilung	61
9.3.1 Anforderung	61
9.3.2 Begründung und zusätzliche Hinweise	61
9.3.3 Weitergehende Anforderungen	62
9.3.4 Security-Level	62
9.4 SR 5.2 – Schutz der Zonengrenze	62
9.4.1 Anforderung	62
9.4.2 Begründung und zusätzliche Hinweise	62
9.4.3 Weitergehende Anforderungen	63
9.4.4 Security-Level	63
9.5 SR 5.3 – Beschränkung der Mensch-zu-Mensch-Kommunikation	63
9.5.1 Anforderung	63
9.5.2 Begründung und zusätzliche Hinweise	63
9.5.3 Weitergehende Anforderungen	64
9.5.4 Security-Level	64

	Seite
9.6 SR 5.4 – Aufteilung von Anwendungen.....	64
9.6.1 Anforderung.....	64
9.6.2 Begründung und zusätzliche Hinweise	64
9.6.3 Weitergehende Anforderungen	64
9.6.4 Security-Level.....	64
10 Grundlegende Anforderung FR 6 – Rechtzeitige Reaktion auf Ereignisse.....	65
10.1 Zweck und Beschreibungen des SL-C(TRE)	65
10.2 Begründung	65
10.3 SR 6.1 – Zugriffsmöglichkeit auf Ereignisprotokolle.....	65
10.3.1 Anforderung.....	65
10.3.2 Begründung und zusätzliche Hinweise	65
10.3.3 Weitergehende Anforderungen	65
10.3.4 Security-Level.....	66
10.4 SR 6.2 – Kontinuierliche Überwachung.....	66
10.4.1 Anforderung.....	66
10.4.2 Begründung und zusätzliche Hinweise	66
10.4.3 Weitergehende Anforderungen	66
10.4.4 Security-Level.....	66
11 Grundlegende Anforderung FR 7 – Ressourcenverfügbarkeit.....	67
11.1 Zweck und Beschreibungen des SL-C(RA).....	67
11.2 Begründung	67
11.3 SR 7.1 – Schutz gegen DoS-Ereignisse	67
11.3.1 Anforderung.....	67
11.3.2 Begründung und zusätzliche Hinweise	67
11.3.3 Weitergehende Anforderungen	67
11.3.4 Security-Level.....	68
11.4 SR 7.2 – Ressourcenmanagement	68
11.4.1 Anforderung.....	68
11.4.2 Begründung und zusätzliche Hinweise	68
11.4.3 Weitergehende Anforderungen	68
11.4.4 Security-Level.....	68
11.5 SR 7.3 – Datensicherung im Automatisierungssystem (Backup).....	68
11.5.1 Anforderung.....	68
11.5.2 Begründung und zusätzliche Hinweise	68
11.5.3 Weitergehende Anforderungen	69
11.5.4 Security-Level.....	69
11.6 SR 7.4 – Wiederherstellung des Automatisierungssystems	69
11.6.1 Anforderung.....	69
11.6.2 Begründung und zusätzliche Hinweise	69

	Seite
11.6.3 Weitergehende Anforderungen	69
11.6.4 Security-Level	69
11.7 SR 7.5 – Notstromversorgung	69
11.7.1 Anforderung	69
11.7.2 Begründung und zusätzliche Hinweise	70
11.7.3 Weitergehende Anforderungen	70
11.7.4 Security-Level	70
11.8 SR 7.6 – Netz- und IT-Sicherheitseinstellungen	70
11.8.1 Anforderung	70
11.8.2 Begründung und zusätzliche Hinweise	70
11.8.3 Weitergehende Anforderungen	70
11.8.4 Security-Level	70
11.9 SR 7.7 – Geringste Funktionalität	71
11.9.1 Anforderung	71
11.9.2 Begründung und zusätzliche Hinweise	71
11.9.3 Weitergehende Anforderungen	71
11.9.4 Security-Level	71
11.10 SR 7.8 – Verzeichnis der Komponenten eines Automatisierungssystems	71
11.10.1 Anforderung	71
11.10.2 Begründung und zusätzliche Hinweise	71
11.10.3 Weitergehende Anforderungen	71
11.10.4 Security-Level	71
Anhang A (informativ) Diskussion des SL-Vektors	72
A.1 Überblick	72
A.2 Security-Level	72
A.2.1 Definition	72
A.2.2 SL-Arten	73
A.2.3 Anwendung der Security-Level	73
A.3 SL-Vektor	77
A.3.1 Grundlegende Anforderungen	77
A.3.2 SL-Festlegung	78
A.3.2.1 Überblick	78
A.3.2.2 SL 0: Keine besonderen Anforderungen oder Schutzmaßnahmen notwendig	78
A.3.2.3 SL 1: Schutz gegen gelegentlichen oder zufälligen Missbrauch	78
A.3.2.4 SL 2: Schutz gegen einen absichtlichen Missbrauch mit einfachen Mitteln und geringem Aufwand, allgemeinen Fertigkeiten und geringer Motivation	79
A.3.2.5 SL 3: Schutz gegen einen absichtlichen Missbrauch mit raffinierten Mitteln und mittlerem Aufwand, IACS-spezifische Fertigkeiten und mittlerer Motivation	79
A.3.2.6 SL 4: Schutz gegen einen absichtlichen Missbrauch mit raffinierten Mitteln und erheblichem Aufwand, IACS-spezifische Fertigkeiten und hoher Motivation	79

	Seite
A.3.3 SL-Vektorformat	80
Anhang B (informativ) Abbildung der Systemanforderungen (SR) und weitergehenden Anforderungen (RE) auf die Security-Level (SL) 1 bis 4 der grundlegenden Anforderungen (FR).....	81
B.1 Überblick.....	81
B.2 SL-Abbildungstabelle.....	81
Literaturhinweise.....	86
Bilder	
Bild 1 – Aufbau der Normenreihe IEC 62443	15
Bild A.1 – Beispiel aus der verfahrenstechnischen Industrie mit Zonen und Conduits	75
Bild A.2 – Beispiel aus der Fertigungsindustrie mit Zonen und Conduits.....	76
Bild A.3 – Schematische Darstellung der Wechselbeziehung der Verwendung verschiedener SL-Arten	77
Tabellen	
Tabelle B.1 – Abbildung von SR und RE auf die FR für SL 1– 4 (1 von 5).....	81

0 Einleitung

0.1 Überblick

ANMERKUNG 1 Diese Norm ist Teil einer Reihe zur IT-Sicherheit industrieller Automatisierungssysteme (IACS). Sie wurde von der Arbeitsgruppe 4, Task Group 2 des ISA 99-Komitees in Zusammenarbeit mit IEC TC 65/WG 10 erarbeitet. Dieses Dokument schreibt die IT-Sicherheitsanforderungen an Automatisierungssysteme entsprechend den sieben grundlegenden Anforderungen nach IEC 62443-1-1 vor und weist dem betrachteten System Security-Level (SL) zu.

ANMERKUNG 2 Das Format dieser Norm folgt den Vorgaben von ISO/IEC, wie sie in den ISO/IEC-Direktiven, Teil 2, beschrieben sind [11].¹ Diese legen sowohl das Format einer Norm als auch die Verwendung von Wörtern wie „muss“, „sollte“, und „darf“ fest. Die Anforderungen in den normativen Abschnitten folgen den Vorgaben nach Anhang H der ISO/IEC-Direktiven.

Die auf dem Gebiet der industriellen Automatisierungstechnik (IACS, en: industrial automation and control system) tätigen Organisationen verwenden in zunehmendem Maße handelsübliche netzwerkfähige Geräte (COTS, en: commercial-off-the-shelf), die kostengünstig, effizient und in hohem Maße automatisiert sind. Ebenfalls werden Automatisierungssysteme in zunehmendem Maße aus wirtschaftlichen Gründen mit Netzen, die nicht zur IACS gehören, verbunden. Solche Geräte, offene Netzwerktechnologien und vermehrte Verbindungsfähigkeit bieten eine zunehmende Gelegenheit für Cyberattacken gegen die Hardware und Software von Automatisierungssystemen. Diese Schwächen können bei installierten Automatisierungssystemen Folgen für die Gesundheit, Sicherheit und Umwelt, die wirtschaftliche Situation und das Ansehen haben.

Organisationen, die zur IT-Sicherheit industrieller Automatisierungssysteme Lösungen aus der kommerziellen Informationstechnik (IT) einsetzen, verstehen möglicherweise die Auswirkungen dieser Entscheidung nicht in vollem Umfang. Obwohl viele kommerzielle IT-Anwendungen und IT-Sicherheitslösungen auch auf IACS angewendet werden können, so muss dies doch in geeigneter Weise erfolgen, um negative Folgen zu vermeiden. Aus diesem Grund muss bei der Festlegung der Systemanforderung auf eine Kombination aus funktionalen Anforderungen und Risikobewertung zurückgegriffen werden, häufig auch unter Beachtung betrieblicher Probleme.

Die IT-Sicherheitsmaßnahmen in einem IACS sollten nicht dazu führen, dass wesentliche Dienste und Funktionen oder gar Notfallprozeduren nicht ausgeführt werden können (einige oft installierte IT-Sicherheitsmaßnahmen haben das Vermögen hierzu). Bei den Sicherheitszielen des IACS stehen die Verfügbarkeit eines Automatisierungssystems, der Schutz und der Betrieb (selbst bei eingeschränkter Betriebsart) der Produktionsanlagen und das Antwortverhalten zeitkritischer Systeme im Vordergrund. Reine IT-Sicherheitsziele legen oft nicht dasselbe Gewicht auf diese Faktoren; sie haben eher den Schutz von Informationen als den von Betriebsmitteln im Auge. Diese andersartigen Zielsetzungen müssen klar als Schutzziele formuliert werden, unabhängig vom erreichten Integrationsgrad der Anlage. Ein wesentlicher Arbeitsschritt im Verlauf der Risikobewertung sollte, wie in IEC 62443-2-1² gefordert, die Benennung derjenigen Dienste und Funktionen sein, die für den Betrieb unverzichtbar sind (beispielsweise könnte in einigen Anlagen die technische Betriebsbetreuung als eine nachrangige Funktion eingestuft werden). In manchen Fällen könnte es dagegen hinnehmbar sein, dass eine IT-Sicherheitsmaßnahme zu einem vorübergehenden Ausfall von nachrangigen Diensten oder Funktionen führt, dagegen sollte ein unverzichtbarer Dienst oder eine unverzichtbare Funktion nicht in abträglicher Weise betroffen sein.

In der vorliegenden Norm wird angenommen, dass ein IT-Sicherheitsprogramm nach IEC 62443-2-1 aufgestellt wurde und betrieben wird. Des Weiteren wird davon ausgegangen, dass ein Sicherheitspatch-Management in Übereinstimmung mit den in IEC/TR 62443-2-3 [5] dargelegten Empfehlungen unter Verwendung der in der vorliegenden Norm dargelegten Systemanforderung und weitergehenden Anforderungen stattfindet. Zusätzlich wird in IEC 62443-3-2 [8] beschrieben, wie in einem Projekt risikobasierte IT-Sicherheitsstufen, die sogenannten Security-Level (SLs), festgelegt werden, die dann dazu herangezogen werden, um Produkte mit geeigneten Fähigkeiten entsprechend dieser Norm auszuwählen. Die vorliegende Norm orientiert sich

¹ Zahlen in rechteckigen Klammern verweisen auf die Literaturhinweise.

² Viele Dokumente der Normenreihe IEC 62443 befinden sich zurzeit in Überarbeitung oder in Erarbeitung.

wesentlich an ISO/IEC 27002 [15] und NIST SP800-53, rev 3 [24] (für eine vollständigere Liste der Quellen siehe [Abschnitt 2](#) und die Literaturhinweise).

Hauptziel der Normenreihe IEC 62443 ist die Bereitstellung eines flexiblen Rahmenwerkes zur erleichterten Behandlung gegenwärtiger und zukünftiger Sicherheitslücken eines IACS und die Anwendung von Abhilfemaßnahmen in einer systematischen und vertretbaren Weise. Es ist wichtig zu verstehen, dass es die Absicht der Reihe der Normen IEC 62443 ist, die Unternehmens-Sicherheit mit Erweiterungen zu versehen, die die Anforderungen an die kommerzielle IT aufnehmen und diese mit den besonderen Anforderungen nach strenger Verfügbarkeit, wie sie von IACS benötigt wird, zusammenzuführen.

0.2 Zweck und Anwenderkreis

Diese Norm richtet sich an die auf dem Gebiet der industriellen Automatisierungstechnik tätigen Betreiber, Systemintegratoren, Produktlieferanten, Dienstleister und gegebenenfalls Genehmigungsstellen. Zu letzteren gehören auch Behörden und Regulierer, deren Zuständigkeit es ist, die Einhaltung von Gesetzen und Vorschriften durch Prüfungen zu überwachen.

Systemintegratoren, Produktlieferanten und Dienstleister werden mit Hilfe dieser Norm bewerten, in wie weit ihre Produkte und Dienstleistungen die funktionalen IT-Sicherheitsfähigkeiten erbringen können, um die Anforderungen des Betreibers, ausgedrückt als SL-T (en: target security level, zu erreichendes SL), zu erreichen. Ebenso wie die Zuweisung von SL-Ts müssen auch die einzelnen Systemanforderungen (SR, en: system requirements) an das Automatisierungssystem und die weitergehenden Anforderungen (RE, en: requirements enhancements) auf den IT-Sicherheitsleitlinien, den Vorgehensweisen und der Risikobewertung des Betreibers im Zusammenhang mit der jeweiligen Anlage beruhen. Dabei ist zu beachten, dass manche Systemanforderungen Voraussetzungen für zulässige Ausnahmen enthalten, etwa wenn ihr Einhalten zur Verletzung fundamentaler betrieblicher Anforderungen eines Automatisierungssystems führen sollte (was Ausgleichsmaßnahmen notwendig machen könnte).

Beim Entwurf eines Automatisierungssystems, das eine Menge von Systemanforderungen zum jeweiligen SL-T einhalten soll, ist es nicht erforderlich, dass jede Komponente des vorgeschlagenen Automatisierungssystems auch jede Systemanforderung auf der in dieser Norm angegebenen Stufe einhalten muss. So können auch Ausgleichsmaßnahmen ergriffen werden, um die von anderen Subsystemen benötigte Funktionalität bereitzustellen und auf der Ebene des Automatisierungssystems dennoch die SL-T-Anforderungen einzuhalten. Die Einbeziehung von Ausgleichsmaßnahmen während der Entwurfsphase sollte durch eine umfassende Dokumentation begleitet werden, so dass das erreichte SL des Automatisierungssystems, SL-A(Automatisierungssystem), die beabsichtigten, sich aus dem Entwurf ergebenden IT-Sicherheitsfähigkeiten vollständig widerspiegelt. Auf ähnliche Weise können während der Zertifizierungsprüfung und während der nach erfolgter Installation durchgeführten Prüfungen Ausgleichsmaßnahmen eingesetzt und dokumentiert werden, um so den SL des Automatisierungssystems zu erreichen.

Der Detaillierungsgrad dieser Norm reicht nicht aus, um eine integrierte IT-Sicherheitsarchitektur zu entwerfen und aufzubauen. Hierzu sind zusätzliche und tiefergehende Analysen in der Systemebene und die Ausarbeitung abgeleiteter Anforderungen notwendig, die Gegenstand weiterer Normen der Reihe IEC 62443 sind, siehe die Einleitung. Man beachte, dass die Bereitstellung von ausreichend detaillierten Spezifikationen für den Aufbau einer IT-Sicherheitsarchitektur, nicht das Ziel dieser Norm ist. Dieses ist vielmehr die Festlegung einer gemeinsamen kleinsten Menge von Anforderungen, um fortschreitend strengere Security-Levels erreichen zu können. Der Entwurf einer diese Anforderungen einhaltenden Architektur obliegt den Systemintegratoren und Produktlieferanten. Sie sind bei diesen Arbeiten frei, individuelle Auswahlen zu treffen, und können sich somit dem Wettbewerb stellen und Innovationen vorantreiben. Diese Norm beschränkt sich ganz bewusst auf die Festlegung funktionaler Anforderungen und legt nicht fest, wie diese erfüllt werden sollten.

0.3 Verwendung innerhalb anderer Teile der Normenreihe IEC 62443

Bild 1 stellt graphisch die Zusammensetzung der Normenreihe IEC 62443 zum Zeitpunkt der Ausarbeitung der vorliegenden Norm dar.

IEC 62443-3-2 verwendet die Systemanforderungen (SR) und die weitergehenden Anforderungen (RE) als Prüfliste. Nachdem das betrachtete System anhand von Zonen und Conduits beschrieben wurde und diesen individuelle SL-Ts zugewiesen wurden, werden die in dieser Norm beschriebenen Systemanforderungen und

weitergehende Anforderungen und deren Abbildung auf SL-Cs zur Zusammenstellung einer Liste von Anforderungen verwendet, die der Entwurf des Automatisierungssystem einhalten muss. Dieser kann dann auf Vollständigkeit geprüft werden, dabei ergeben sich die SL-A.

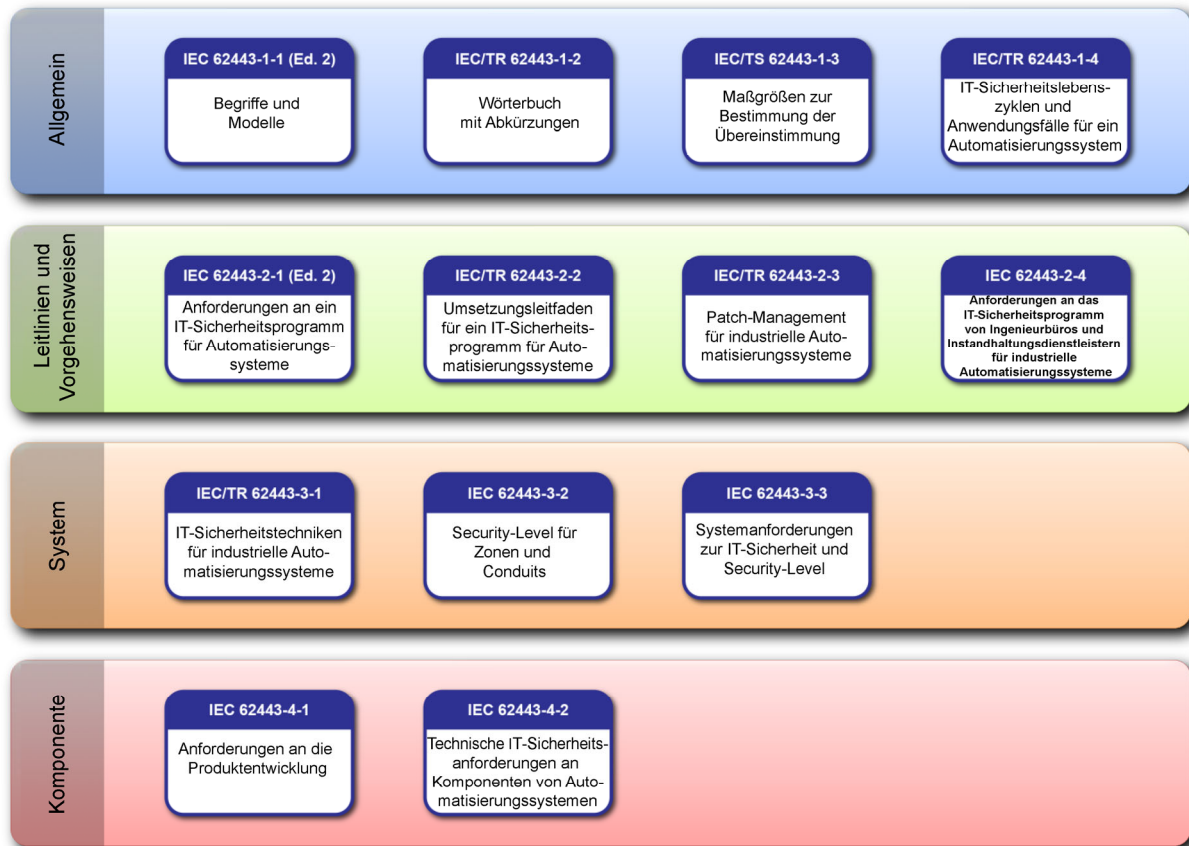


Bild 1 – Aufbau der Normenreihe IEC 62443

IEC/TS 62443-1-3 [2] verwendet die grundlegenden Anforderungen (FR), die Systemanforderungen (SR), die weitergehenden Anforderungen (RE) und deren Abbildung auf die SL-C (SL-C capable, erreichbares SL) als Prüfliste, anhand derer geprüft wird, ob die quantitativen Maßgrößen vollständig spezifiziert sind. Die quantitativen Maßgrößen zur Bestimmung der Übereinstimmung sind abhängig vom Zusammenhang. In Verbindung mit IEC 62443-3-2 werden die vom Betreiber angestrebten SL-T in quantitative Maßgrößen übersetzt; diese können dann bei Systemanalysen und der Abwägung unterschiedlicher Entwürfe zur Entwicklung einer IT-Sicherheitsarchitektur herangezogen werden.

IEC 62443-4-1 [9] beschreibt die Gesamtanforderungen während der Entwicklung von Produkten. Daher wendet sie sich an Produktlieferanten. Die Anforderungen an die IT-Sicherheit der Produkte werden aus der Liste der grundlegenden Anforderungen und der weitergehenden Anforderungen abgeleitet, wie sie in der vorliegenden Norm festgelegt sind. Bei der Entwicklung der Produktfähigkeiten werden die normativen Qualitätsfestlegungen nach IEC 62443-4-1 verwendet werden.

IEC 62443-4-2 [10] enthält Zusammenstellungen abgeleiteter Anforderungen, die eine detaillierte Abbildung der in dieser Norm festgelegten Systemanforderungen auf Subsysteme und Komponenten des betrachteten Systems darstellen. Zum Zeitpunkt der Ausarbeitung der vorliegenden Norm waren in IEC 62443-4-2 folgende Arten von Komponenten aufgeführt: eingebettete Geräte, Host-Geräte, Infrastrukturkomponenten und Anwendungen. So gesehen wendet sich die IEC 62443-4-2 an Verkäufer (Produktlieferant und Dienstleister). Die Anforderungen an die IT-Sicherheit der Produkte werden zunächst aus der Liste der grundlegenden Anforderungen und der weitergehenden Anforderungen (RE) spezifiziert in der vorliegenden Norm, abgeleitet. Zu ihrer Verfeinerung werden IT-Sicherheitsanforderung und -maßgrößen nach IEC 62443-3-2 und IEC/TS 62443-1-3 verwendet.

1 Anwendungsbereich

Diese Norm der Reihe IEC 62443 legt anhand der sieben grundlegenden Anforderungen (FR) nach IEC 62443-1-1 detaillierte technische Systemanforderungen (SR) an IACS fest, einschließlich der Festlegung der Anforderungen zu erreichbaren Security-Level, SL-C(Automatisierungssystem). Diese Anforderungen werden von verschiedene Personen im Bereich der industriellen Automatisierungstechnik angewendet, in dem sie, anhand der festgelegten Zonen und Conduits eines betrachteten Systems, einen angemessenen, zu erreichender Security-Level SL-T(Automatisierungssystem) für ein Schutzobjekt entwickeln.

Nach IEC 62443-1-1 gibt es insgesamt sieben grundlegende Anforderungen:

- a) Identifizierung und Authentifizierung (IAC),
- b) Nutzungskontrolle (UC),
- c) Systemintegrität (SI),
- d) Vertraulichkeit der Daten (DC),
- e) eingeschränkter Datenfluss (RDF),
- f) rechtzeitige Reaktion auf Ereignisse (TRE),
- g) Verfügbarkeit der Ressourcen (RA),

Diese sieben Anforderungen bilden die Grundlage für die erreichbaren SLs eines Automatisierungssystems, die SL-C(Automatisierungssystem). Auf der Ebene des Automatisierungssystems ist die Festlegung der erreichbaren IT-Sicherheit das Ziel dieser Norm und nicht die der erreichten SLs (SL-A) oder zu erreichenden SLs (SL-T), welche außerhalb des Anwendungsbereichs dieser Norm liegen.

Für einen äquivalenten Satz von nicht-technischen, programmbezogenen, erreichbaren Systemanforderungen, die für das vollständige Erreichen eines SL-T eines Automatisierungssystems erforderlich sind, wird auf IEC 62443-2-1 verwiesen.

2 Normative Verweisungen

Die folgenden Dokumente, die in diesem Dokument teilweise oder als Ganzes zitiert werden, sind für die Anwendung dieses Dokuments erforderlich. Bei datierten Verweisungen gilt nur die in Bezug genommene Ausgabe. Bei undatierten Verweisungen gilt die letzte Ausgabe des in Bezug genommenen Dokuments (einschließlich aller Änderungen).

IEC 62443-1-1:2009, *Industrial communication networks – Network and system security – Part 1-1: Terminology, concepts and models*

IEC 62443-2-1, *Industrial communication networks – Network and system security – Part 2-1: Establishing an industrial automation and control system security program*

3 Begriffe, Abkürzungen und Erläuterungen

3.1 Begriffe

Für die Anwendung dieses Dokuments gelten die Begriffe nach IEC 62443-1-1 und IEC 62443-2-1 und die folgenden Begriffe.

ISO und IEC stellen terminologische Datenbanken für die Verwendung in der Normung unter den folgenden Adressen bereit:

- IEC Electropedia: verfügbar unter <http://www.electropedia.org/>
- ISO Online Browsing Platform: verfügbar unter <http://www.iso.org/obp>

ANMERKUNG Viele der nachfolgenden Begriffe entstammen ursprünglich Quellen der International Organization for Standardization (ISO), der International Electrotechnical Commission (IEC) oder des U.S. National Institute of Standards

and Technology (NIST), manchmal mit geringfügigen Änderungen, um die Eignung bei der Festlegung der Sicherheitsanforderungen für Automatisierungssysteme zu verbessern.

3.1.1

Schutzobjekt

Betriebsmittel

(en: asset)

physikalisches oder logisches Objekt, das für das IACS entweder einen wahrgenommenen oder einen tatsächlichen Wert hat

Anmerkung 1 zum Begriff: In dieser Norm werden unter einem Schutzobjekt alle diejenigen Betrachtungseinheiten verstanden, die im Rahmen des IT-Sicherheitsmanagementsystems des IACS geschützt werden sollten.

3.1.2

Betreiber

(en: asset owner)

für ein oder mehrere IACS verantwortliche Person oder Gesellschaft

Anmerkung 1 zum Begriff: Die Benennung „Betreiber“ wird an Stelle der allgemeinen Benennung „Endanwender“ verwendet.

Anmerkung 2 zum Begriff: Diese Definition umfasst auch alle Komponenten, die Teil des IACS sind.

Anmerkung 3 zum Begriff: Im Zusammenhang mit dieser Norm wird ein Eigner von Anlagevermögen mit dem Betreiber eines IACS gleichgesetzt.

3.1.3

Angriff

(en: attack)

Übergriff auf ein System, der sich aus einer intelligenten Bedrohung herleitet

Anmerkung 1 zum Begriff: Beispielsweise ist eine intelligente Tat der vorsätzlicher Versuch (besonders im Sinne einer Methode oder einer Technik), Dienste zur IT-Sicherheit eines Systems zu umgehen und dessen Sicherheitsvorschriften zu verletzen.

Anmerkung 2 zum Begriff: Es gibt verschiedene allgemein erkannte Angriffsarten:

- Ein „aktiver Angriff“ versucht, die Systemressourcen zu verändern oder ihren Betrieb zu beeinträchtigen.
- Ein „passiver Angriff“ versucht zu lernen oder Informationen aus dem System zu nutzen, er beeinträchtigt aber keine Systemressourcen.
- Ein „Angriff von innen“ ist ein von einer innerhalb der IT-Sicherheitszone liegender Person oder Stelle veranlasster Angriff (von einem Innentäter), beispielsweise von einer Person oder Stelle, der es gestattet ist, auf Systemressourcen zuzugreifen, die diese jedoch in einer Art und Weise nutzt, wie es von den Autorisierten nicht vorgesehen war
- Ein „Angriff von außen“ ist ein von außerhalb der IT-Sicherheitszone veranlasster Angriff, durch einen nicht autorisierten oder illegalen Nutzer (einschließlich eines Innentäters, der von außerhalb der IT-Sicherheitszone aus angreift). Mögliche außenstehende Angreifer reichen von amateurhaften Witzbolden bis zu organisierten Kriminellen, internationalen Terroristen und feindlich gesinnten Regierungen.

3.1.4

Authentifizierung

(en: authentication)

Sicherstellung, dass die von einer Einheit behauptete Eigenschaft korrekt ist

Anmerkung 1 zum Begriff: Authentifizierung ist üblicherweise eine Voraussetzung für die Gewährung des Zugangs zu den Ressourcen eines Automatisierungssystems.

3.1.5

Authentifizierer

(en: authenticator)

Mittel zur Bestätigung der Identität eines Nutzers (menschlicher Nutzer, Softwareprozess oder Gerät)

Anmerkung 1 zum Begriff: Beispielsweise kann ein Passwort oder ein Token als Authentifizierer eingesetzt werden.

3.1.6

Authentizität

(en: authenticity)

Eigenschaft einer Einheit, das zu sein, was sie zu sein vorgibt

Anmerkung 1 zum Begriff: Authentizität wird typischerweise im Zusammenhang mit Vertrauen in die Identität einer Stelle oder die Gültigkeit einer Übertragung, in die Identität einer Nachricht oder des Absenders der Nachricht verwendet.

3.1.7

Automatik

(en: automatic)

Prozess oder Gerät, das bei vorgegebenen Bedingungen ohne menschliches Zutun funktioniert

3.1.8

Verfügbarkeit

(en: availability)

Fähigkeit, einen rechtzeitigen und zuverlässigen Zugang zu den Informationen und zur Funktionalität eines Automatisierungssystems sicherstellen zu können

3.1.9

Kommunikationskanal

(en: communication channel)

bestimmtes logisches oder physikalisches Kommunikationsglied zwischen Schutzobjekten

Anmerkung 1 zum Begriff: Ein Kanal ermöglicht die Herstellung einer Verbindung.

3.1.10

Ausgleichsmaßnahme

(en: compensating countermeasure)

Gegenmaßnahme, die anstelle von oder zusätzlich zu inhärenten IT-Sicherheitsfähigkeiten eingesetzt wird, um einer oder mehreren IT-Sicherheitsanforderungen zu genügen

Anmerkung 1 zum Begriff: Beispiele hierfür sind:

- (Komponenten-Ebene) abschließbarer Schaltschrank, in dem sich eine Steuerung befindet, die für sich alleine nicht ausreichend geschützt wäre;
- (Ebene des Automatisierungssystems/der Zonen) physikalische Zugangskontrolle (Wachpersonal, Tore und Schusswaffen) zum Schutz einer Schaltwarte, um den Zugang auf eine Gruppe bekannter Mitarbeiter zu beschränken; um der technischen Anforderung zu entsprechen, dass das Personal durch das IACS eindeutig identifiziert wird; und
- (Komponenten-Ebene) Eine speicherprogrammierbare Steuerung (SPS) erfüllt die vom Betreiber geforderten Fähigkeiten der Zugangskontrolle nicht, daher stellt der Zulieferer der SPS vor diese einen Firewall und verkauft dies zusammen als ein System.

3.1.11

Genehmigungsbehörde

(en: compliance authority)

rechtlich zuständige Stelle, die über die Angemessenheit einer Beurteilung der IT-Sicherheit, ihrer Umsetzung oder Wirksamkeit entsprechend eines Leitdokumentes zu entscheiden hat

3.1.12

Conduit

(en: conduit)

logische Gruppierung von Kommunikationskanälen, die zwei oder mehr Zonen verbindet, für die gemeinsame IT-Sicherheitsanforderungen gelten

Anmerkung 1 zum Begriff: Ein Conduit (ein Leitungsschutzrohr) darf eine Zone durchqueren, solange die IT-Sicherheit der im Conduit verlaufenden Kanäle durch die Zone nicht beeinträchtigt wird.

3.1.13

Vertraulichkeit

(en: confidentiality)

Bewahrung autorisierter Beschränkungen des Zugangs zu Informationen und deren Offenlegung, dies schließt auch Mittel zum Datenschutz und Schutz eigener Informationen ein

Anmerkung 1 zum Begriff: Wird dieser Begriff im Zusammenhang mit einem IACS verwendet, so bezieht er sich auf den Schutz der in diesem vorhandenen Daten und Informationen vor nicht autorisiertem Zugang.

3.1.14

Verbindung

(en: connection)

zwischen zwei oder mehr Endpunkten hergestellter Zusammenschluss, der den Aufbau einer Sitzung unterstützt

3.1.15

Folge

(en: consequence)

Bedingung oder Zustand, der logischerweise oder natürlicherweise auf ein Ereignis folgt

3.1.16

Automatisierungssystem

(en: control system)

Hardware- und Softwarekomponenten eines IACS

3.1.17

Maßnahme

(en: countermeasure)

Tätigkeit, Gerät, Prozedur oder Technik, durch die eine Bedrohung, eine Sicherheitslücke oder ein Angriff verringert wird, und zwar durch Beseitigen, Verhindern, Verringern des möglichen Schadens oder durch Entdeckung und Bericht, so dass Korrekturmaßnahmen eingeleitet werden können

Anmerkung 1 zum Begriff: Für die deutsche Sprachfassung ohne Belang.

3.1.18

eingeschränkter Betrieb

(en: degraded mode)

durch das Vorhandensein möglicher Fehlzustände, die beim Entwurf des Automatisierungssystems bereits berücksichtigt wurden, gekennzeichnete Betriebszustand

Anmerkung 1 zum Begriff: In einem eingeschränkten Betriebszustand kann das Automatisierungssystem trotz des Versagens eines oder mehrerer Systemelemente weiterhin wesentliche Funktionen erbringen, wie beispielsweise bei Fehlfunktion oder Ausfall von Betriebsmitteln, bei einer durch einen Ausfall verursachten Kommunikationsunterbrechung oder bei absichtlicher Abtrennung des Systems, weil erkannt oder vermutet wird, dass Subsysteme kompromittiert worden sind.

3.1.19

demilitarisierte Zone

(en: demilitarized zone)

gemeinsames, begrenztes Netz von Servern, das zwei oder mehr Zonen miteinander verbindet, um den Datenfluss zwischen diesen kontrollieren zu können

Anmerkung 1 zum Begriff: Demilitarisierte Zonen (DMZs) werden typischerweise eingesetzt, um direkte Verbindungen zwischen verschiedenen Zonen zu vermeiden.

3.1.20

Gerät

(en: device)

Betriebsmittel, das einen oder mehrere Prozessoren enthält und über die Fähigkeit verfügt, zu oder von einem anderen Betriebsmittel Daten und Steuerbefehle zu senden oder zu empfangen

Anmerkung 1 zum Begriff: Beispiele hierfür sind Steuerungen, Mensch-Maschine-Schnittstellen, SPSs, abgesetzte Bediengeräte, Messumformer, Aktoren, Ventile, Switches in Netzwerken.

3.1.21

Umgebung

(en: environment)

umgebende Objekte, Gebiete oder Umstände, die das Verhalten des IACS beeinflussen können und/oder durch dieses beeinflusst werden können

3.1.22

wesentliche Funktion

(en: essential function)

zur Erhaltung der Gesundheit, der Sicherheit, der Umwelt sowie der Verfügbarkeit der zu überwachenden Einrichtung erforderliche Funktion oder Fähigkeit

Anmerkung 1 zum Begriff: Zu den wesentlichen Funktionen gehören unter anderem die sicherheitstechnischen Funktionen (SIF), die Steuerungs- und Regelfunktionen sowie die Fähigkeit des Bedieners, die zu überwachende Einrichtung zu beobachten und zu bedienen. Der Verlust wesentlicher Funktionen kann auch als Verlust der Schutz-, bzw. Steuerungsfunktion, der Regelfunktion und der Überwachungsfunktion bezeichnet werden. In einigen Industriebereichen werden noch weitere Funktionen, wie z. B. die Dokumentation des Produktionsgeschehens als wesentlich eingestuft.

3.1.23

Ereignis

Vorfall

(en: event)

Auftreten von oder Änderung zu einer besonderen Menge von Umständen

Anmerkung 1 zum Begriff: In einem IACS kann dies eine von einer Person (berechtigt oder nicht berechtigt) vorgenommene Handlung, eine in dem Automatisierungssystem festgestellte Veränderung (normal oder anormal) oder eine automatische Reaktion des Automatisierungssystems selbst (normal oder anormal) sein.

3.1.24

Firecall

(en: firecall)

Verfahren der Bereitstellung eines Notzugangs zu einem gesicherten Automatisierungssystem

Anmerkung 1 zum Begriff: In einer Notsituation können nicht berechtigte Nutzer zur Problembeseitigung Zugang zu Schlüsselsystemen erlangen. Mit einem Firecall ist üblicherweise eine Nachschau verbunden, durch die sichergestellt wird, dass der Zugang zur Beseitigung eines Problems korrekt genutzt wurde. Bei diesem Verfahren wird im Allgemeinen eine einmalige Benutzererkennung oder ein Einmalpasswort erteilt.

3.1.25

Bezeichner

(en: identifier)

in einem IT-Sicherheitsbereich eindeutiges Symbol, das eine Einheit, die eine Identität vorgibt oder geltend macht, identifiziert, anzeigt oder benennt

3.1.26

identifizieren

(en: identify)

Zusicherung einer Identität

3.1.27

Auswirkung

(en: impact)

bewertete Auswirkung eines bestimmten Ereignisses

3.1.28

Vorfall

(en: incident)

Ereignis, welches nicht Teil des erwarteten Betriebsverhaltens eines Systems oder Dienstes ist und das zu einer Unterbrechung des vom Automatisierungssystem erbrachten Dienstes oder einer Verminderung von dessen Qualität führt oder führen kann

3.1.29

industrielles Automatisierungssystem

(en: industrial automation and control system)

Zusammenstellung von Personal, Hardware, Software und Vorgehensweisen, die eingebunden sind in den Betrieb eines industriellen Prozesses und dessen sicheren und zuverlässigen Betrieb beeinträchtigen oder beeinflussen kann

3.1.30

Integrität

(en: integrity)

Eigenschaft der Absicherung von Genauigkeit und Vollständigkeit von Schutzobjekten

3.1.31

minimal erforderliche Rechte

(en: least privilege)

Grundprinzip, demgemäß Nutzern (Menschen, Softwareprozesse oder Geräte) die entsprechend ihren Pflichten und Funktionen minimal erforderlichen Rechte zugewiesen werden sollten

Anmerkung 1 zum Begriff: Dieses Prinzip wird in einem IACS üblicherweise mittels einer Menge von Rollen realisiert.

3.1.32

plattformübergreifender Code

(en: mobile code)

von einem abgesetzten, möglicherweise nicht vertrauenswürdigem System, über ein Netz oder mittels mobiler Datenträger übertragenes Programm, welches unverändert in einem lokalen System durch den Empfänger ohne explizite Installation oder Nutzerbestätigung ausgeführt werden kann

Anmerkung 1 zum Begriff: Beispiele plattformübergreifenden Codes sind JavaScript, VBScript, Java Applets, ActiveX-Controls, Flash-Animationen, Shockwave-Movies und Microsoft Office-Makros.

3.1.33

Nichtabstreitbarkeit

(en: non-repudiation)

Fähigkeit, das Auftreten eines behaupteten Ereignisses oder einer Handlung und die verursachende Person oder Stelle nachzuweisen

Anmerkung 1 zum Begriff: Ziel der Nichtabstreitbarkeit ist es, Streitigkeiten über das Auftreten oder Nichtauftreten des Ereignisses oder der Handlung und die Beteiligung von betroffenen Stellen an diesem Ereignis beizulegen.

3.1.34

Produktlieferant

(en: product supplier)

Hersteller eines Hardware- und/oder Softwareprodukts

Anmerkung 1 zum Begriff: Zur besseren Unterscheidung wird diese Benennung anstelle des allgemeinen Wortes „Verkäufer“ verwendet.

3.1.35

Fernzugang

(en: remote access)

Zugriff auf ein Automatisierungssystem durch beliebige Nutzer (Mensch, Softwareprozess oder Gerät), die von außerhalb der angesprochenen IT-Sicherheitszone kommunizieren

3.1.36

Rolle

(en: role)

Menge von zusammenhängenden Verhaltensweisen, Berechtigungen und Verpflichtungen, die allen Nutzern (Menschen, Softwareprozesse oder Geräte) eines IACS zugeordnet sind

Anmerkung 1 zum Begriff: Die Berechtigungen, bestimmte Handlungen vorzunehmen, sind bestimmten Rollen zugeordnet.

3.1.37

sicherheitstechnisches System

(en: safety instrumented system)

System zur Ausführung einer oder mehrerer sicherheitstechnischer Funktionen

3.1.38

Security-Level

(en: security level)

Maß des Vertrauens, dass das IACS von Sicherheitslücken frei ist und in der beabsichtigten Weise funktioniert

Anmerkung 1 zum Begriff: Sicherheitslücken können entweder bei der Entwicklung des IACS entstehen, während seines Lebenszyklus zu irgendeinem Zeitpunkt in dieses hingbracht werden oder sich aus verändernden Bedrohungen ergeben. Bei der Entwicklung entstandene Sicherheitslücken können erst lange nach der Inbetriebnahme erkannt werden, beispielsweise wurde eine Verschlüsselungstechnik ungenügend umgesetzt oder die Leitlinien zur Verwaltung von Nutzerkonten waren ungenügend, wie z. B. das Nicht-Entfernen alter Benutzerkonten. Eingebraachte Sicherheitslücken können das Ergebnis eines Patches oder geänderter Leitlinien sein, durch die eine neue Sicherheitslücke geöffnet wird.

3.1.39

Dienstleister

(en: service provider)

Organisation (interne oder externe Organisation, Hersteller usw.), die zugesagt hat, entsprechend einer getroffenen Vereinbarung die Verantwortung zur Erbringung eines bestimmten Unterstützungsdienstes zu übernehmen und, falls angegeben, Lieferungen zu erhalten

Anmerkung 1 zum Begriff: Zur besseren Unterscheidung wird diese Benennung anstelle des allgemeinen Wortes „Verkäufer“ verwendet.

3.1.40

Sitzung

(en: session)

semipermanenter, zustandsbehafteter und interaktiver Informationsaustausch zwischen zwei oder mehr miteinander kommunizierenden Geräten

Anmerkung 1 zum Begriff: Üblicherweise hat eine Sitzung klar definierte Einschalt- und Abschaltverfahren.

3.1.41

Sitzungs-ID

(en: session ID)

Bezeichner, der zum Kenntlichmachen eines bestimmten Sitzungseintrags verwendet wird

3.1.42

Sollwert

(en: set point)

in einer Regelung benannter Zielwert, wobei dieser eine oder mehrere Handlungen im Automatisierungssystem führt

3.1.43

Systemintegrator

(en: system integrator)

Person oder Gesellschaft, die sich darauf spezialisiert hat, Teilsysteme zu einem ganzen System zusammenfügen, und die dafür sorgt, dass diese Teilsysteme sich entsprechend den Projektspezifikationen verhalten

3.1.44

Bedrohung

(en: threat)

Umstand oder Ereignis mit dem Vermögen, sich durch einen nicht autorisierten Zugriff auf Daten, deren Zerstörung, Offenlegung, Veränderung oder durch Denial-of-Service nachteilig auf den Betrieb (einschließlich Aufgabe, Funktion und Ansehen), auf Vermögenswerte, auf Automatisierungssysteme oder auf Personen auszuwirken

3.1.45

Vertrauen

(en: trust)

Vertrauen, dass man gewiss sein kann, dass eine Operation, die Quelle eines Datenverarbeitungsvorgangs, ein Netz oder ein Softwareprozess sich wie erwartet verhält

Anmerkung 1 zum Begriff: Üblicherweise kann man sagen, dass eine Person oder Stelle einer zweiten vertraut, wenn sie die Annahme trifft, dass sich die zweite wie erwartet verhalten wird.

Anmerkung 2 zum Begriff: Das Vertrauen kann auf einige besondere Funktionen beschränkt sein.

3.1.46

nicht vertrauenswürdig

(en: untrusted)

erfüllt vorher festgelegte Anforderungen zum Vertrauen nicht

Anmerkung 1 zum Begriff: Eine Person oder Stelle kann einfach als nicht vertrauenswürdig erklärt werden.

3.1.47

Zone

(en: zone)

Zusammenfassung logischer oder physikalischer Anlagenteile, für die IT-Sicherheitsanforderungen gemeinsam gelten

Anmerkung 1 zum Begriff: Eine Zone ist klar begrenzt. Die IT-Sicherheitsleitlinien einer Zone werden üblicherweise durch eine Kombination von Verfahren sowohl am Zonenrand als auch innerhalb der Zone durchgesetzt.

3.2 Abkürzungen

Abkürzung	Englische Benennung	Deutsche Benennung
AES	Advanced encryption standard	erweiterter Verschlüsselungsstandard
API	Application programming interface	Schnittstelle für ein Anwendungsprogramm
ASLR	Address space layout randomization	Verwürfelung des Adressraums
BPCS	Basic process control system	Betriebs- und Überwachungseinrichtung
CA	Certification authority	Zertifizierungsstelle
CIP	Critical infrastructure protection	Schutz kritischer Infrastruktur(en)
COTS	Commercial off the shelf	handelsüblich
CRL	Certificate revocation list	Zertifikatsperrliste
DC	Data confidentiality	Datenvertraulichkeit
DEP	Data execution prevention	Datenausführungsverhinderung
DHCP	Dynamic host configuration protocol	Kommunikationsprotokoll zur Zuweisung von Konfigurationen
DMZ	Demilitarized zone	demilitarisierte Zone
DNS	Domain name service	Domänennamendienst
DoS	Denial-of-Service	Ablehnung, einer Stelle, einen Dienst zu erbringen
EICAR	European Institute for Computer Antivirus Research	gemeinnütziger Verein mit dem Ziel Computerviren zu erforschen
EMI	Electromagnetic interference	elektromagnetische Störung
FAT	Factory acceptance testing	Prüfung bei der Werksabnahme
FIPS	[US NIST] <i>Federal Information Processing Standard</i>	Bundesstandard für Informationsverarbeitung der Vereinigten Staaten von Amerika
FR	Foundational requirement	grundlegende Anforderung
FS-PLC	Functional safety PLC	Sicherheitsgerichtete SPS
FTP	File transfer protocol	Dateiübertragungsprotokoll
GLONASS	Global Navigation Satellite System	globales Navigationssatellitensystem <der russischen Föderation>
GPS	Global Positioning System	globales Positionierungssystem
HMI	Human-machine interface	Mensch-Maschine-Schnittstelle
HSE	Health, safety and environmental	Gesundheit, Sicherheit und Umwelt
HTTP	Hypertext transfer protocol	Protokoll zur Übertragung von HTML-Seiten im Internet
HTTPS	HTTP secure	Protokoll zur sicheren Übertragung von HTML-Seiten im Internet
IAC	Identification and authentication control	Identifizierung und Authentifizierung
IACS	Industrial automation and control system(s)	industrielles Automatisierungssystem
IAMS	Instrument asset management system	Instandhaltungssystem für Mess- und Stellgeräte

Abkürzung	Englische Benennung	Deutsche Benennung
ID	Identifier	Bezeichner
IDS	Intrusion detection system	System zur Erkennung von Angriffen auf ein Computersystem oder Rechnernetz
IEEE	Institute of Electrical and Electronics Engineers	Weltweiter Ingenieurverband
IETF	Internet Engineering Task Force	Organisation, die sich mit der technischen Weiterentwicklung des Internets befasst
IM	Instant messaging	Nachrichtensofortversand
IP	Internet Protocol	Internetprotokoll
IPS	Intrusion prevention system	ein IDS, das Gegenmaßnahmen einleiten kann
ISA	International Society of Automation	gemeinnützige Fachgesellschaft für Automatisierung
ISO	International Organization for Standardization	internationale Standardisierungsorganisation
IT	Information technology	Informationstechnik
MES	Manufacturing Execution System	Produktionsleitsystem
NERC	North American Electric Reliability Corporation	Non-Profit-Organisation für die Koordinierung der Stromnetze im nordamerikanischen Raum
NIST	U.S. National Institute of Standards and Technology	Bundesbehörde der Vereinigten Staaten von Amerika für Standards und Technologie
NX	No Execute	keine Ausführung
OCSP	Online certificate status protocol	Netzwerkprotokoll zur Statusabfrage von Zertifikaten
OWASP	Open Web Application Security Project	Non-Profit-Organisation mit dem Ziel, die Sicherheit von Anwendungen und Diensten im Internet zu verbessern
PDF	Portable document format	transportables Datenformat
PKI	Public key infrastructure	Sicherheitsinfrastruktur
SPS	Programmable logic controller (PLC)	speicherprogrammierbare Steuerung
RA	Resource availability	Ressourcenverfügbarkeit
RAM	Random access memory	Speicher mit wahlfreiem/direktem Zugriff
RDF	Restricted data flow	eingeschränkter Datenfluss
RE	Requirement enhancement	weitergehende Anforderung
RFC	[IETF] Request for Comment	Reihe technischer und organisatorischer Dokumente zum Internet
RJ	Registered jack	genormter Stecker
RTU	Remote terminal unit	entferntes Endgerät
SAT	Site acceptance testing	Abnahme der installierten Anlage
SHA	Secure hash algorithm	sicherer Hash-Algorithmus
SI	System integrity	Systemintegrität

Abkürzung	Englische Benennung	Deutsche Benennung
SIEM	Security Information and Event Management	Sicherheitsinformations- und Ereignismanagement
SIF	safety instrumented function	sicherheitstechnische Funktion
SIL	Safety Integrity Level	Sicherheitsintegritäts-Level
SIS	Safety instrumented system	sicherheitstechnisches System
SL	Security level	Security-Level
SL-A	Achieved security level	erreichter Security-Level
SL-C	Capability security level	erreichbarer Security-Level
SL-T	Target Security-Level	zu erreichender Security-Level
SP	[US NIST] Special Publication	Sonderveröffentlichung der Bundesbehörde der Vereinigten Staaten von Amerika für Standards und Technologie
SR	System Requirement	Systemanforderung
SSH	Secure socket shell	Unix-basiertes Protokoll für einen sicheren Zugriff auf entfernte Computer
SuC	System under consideration	betrachtetes System
TCP	Transmission Control Protocol	Übertragungssteuerungsprotokoll
TPM	Trusted platform module	Computerchip mit Sicherheitsfunktionen
TRE	Timely response to events	Rechtzeitige Reaktion auf Ereignisse
UC	Use control	Nutzungskontrolle
USB	Universal serial bus	universeller serieller Bus
VoIP	Voice over internet protocol	IP-Telefonie
WEP	Wired equivalent privacy	verdrahteten Systemen entsprechende Privatsphäre, ehemaliges Standard-Verschlüsselungsprotokoll für WLAN
WLAN	Wireless local area network	drahtloses lokales Netzwerk

3.3 Vereinbarungen

Die vorliegende Norm erweitert die sieben grundlegenden Anforderungen (FR) nach IEC 62443-1-1 zu einer Reihe von Systemanforderungen (SR). Jede Systemanforderung besteht aus einer Hauptanforderung und gegebenenfalls weitergehenden Anforderungen (RE), die die IT-Sicherheit verstärken. Für ein besseres Verständnis seitens des Lesers wird jede Hauptanforderung mit einer Begründung und zusätzlichen Hinweisen versehen und jede zugehörige weitergehende Anforderungen, sofern nötig, mit einer Anmerkung. Die Hauptforderung und etwaige vorhandene weitergehende Anforderungen werden dann auf die erreichbaren Security-Level des Automatisierungssystems, SL-C(FR, Automatisierungssystem), 1 bis 4 abgebildet.

Alle sieben grundlegenden Anforderungen haben eine festgelegte Menge von vier SL. SL 0 als erreichbares SL eines Automatisierungssystems für eine gegebene grundlegende Anforderung (FR) bedeutet keine Anforderung. Die Erklärung des Zwecks der grundlegenden Anforderung 4 in [Abschnitt 8](#) – Vertraulichkeit der Daten – lautet beispielsweise folgendermaßen:

Die Vertraulichkeit von Daten in Kommunikationskanälen und Datenbeständen sicherstellen, um deren nicht autorisierte Offenlegung zu verhindern.

Die zugehörigen vier SL sind wie folgt definiert:

- SL 1: die nicht autorisierte Offenlegung von Informationen durch Abhören oder zufälliges Aufdecken verhindern.
- SL 2: die nicht autorisierte Offenlegung von Informationen an eine danach aktiv mit einfachen Mitteln bei geringem Aufwand, allgemeinen Fertigkeiten und geringer Motivation suchende Person oder Stelle verhindern.
- SL 3: die nicht autorisierte Offenlegung von Informationen an eine danach aktiv mit raffinierten Mitteln und moderatem Aufwand, IACS-spezifische Fertigkeiten und mittlerer Motivation suchende Person oder Stelle verhindern.
- SL 4: die nicht autorisierte Offenlegung von Informationen an eine danach aktiv mit raffinierten Mitteln und erheblichem Aufwand, IACS-spezifische Fertigkeiten und hoher Motivation suchende Person oder Stelle verhindern.

Die einzelnen Zuweisungen von Systemanforderungen (SR) und weitergehende Anforderungen (RE) erfolgen somit entsprechend einer schrittweisen Erhöhung der gesamten IT-Sicherheit des IACS für diese bestimmte grundlegende Anforderung (FR).

Die Bezeichnung „SL-C(Automatisierungssystem)“, die durchgehend in dieser Norm verwendet wird, steht für die Fähigkeit, die erforderlich ist, um einen SL für eine gegebene grundlegende Anforderung zu erbringen. Für eine vollständige Beschreibung des SL-Vektorkonzepts wird auf [Anhang A](#) verwiesen.

4 Beschränkungen der IT-Sicherheit aufgrund der Natur des Automatisierungssystems

4.1 Überblick

Beim Lesen, Vorgeben und Ausführen der in den [Abschnitten 5 bis 11](#) dieser Norm im Einzelnen festgelegten Systemanforderungen sind einige gemeinsame Einschränkungen zu beachten. Die Einleitung dieser Norm bot eine kontextbezogene Diskussion darüber, was diese Norm erreichen soll. Dieser Abschnitt und die folgenden Abschnitte zu den einzelnen grundlegenden Anforderungen liefern die normativen Angaben, um die IT-Sicherheit im Unternehmen im Hinblick auf die in einem IACS benötigten rigorosen Anforderungen an Integrität und Verfügbarkeit erweitern zu können.

ANMERKUNG Der Inhalt dieses Abschnittes wird gegebenenfalls in IEC 62443-1-1 übernommen werden.

4.2 Unterstützung wesentlicher Funktionen

Wie in [3.1.22](#) dokumentiert, ist eine wesentliche Funktion eine „zur Erhaltung der Gesundheit, der Sicherheit, der Umwelt sowie der Verfügbarkeit der zu überwachenden Einrichtung erforderliche Funktion oder Fähigkeit“.

- IT-Sicherheitsmaßnahmen dürfen sich nicht nachteilig auf wesentliche Funktionen eines hoch verfügbaren IACS auswirken, außer dies wird durch eine Risikoeinschätzung unterstützt.

ANMERKUNG Bezüglich der Dokumentationsanforderungen an eine Risikobeurteilung, die zur Absicherung von Situationen zu erbringen ist, in denen sich IT-Sicherheitsmaßnahmen auf wesentliche Funktionen auswirken, wird auf IEC 62443-2-1 verwiesen.

Beim Lesen, Spezifizieren und Umsetzen der in dieser Norm beschriebenen Systemanforderungen sollte die Umsetzung von IT-Sicherheitsmaßnahmen nicht zu einem Verlust des Schutzes, der Regelung, der Beobachtungsmöglichkeit oder anderer wesentlicher Funktionen führen. Im Nachgang zu einer Risikoanalyse könnten einige Einrichtungen feststellen, dass bestimmte Arten von IT-Sicherheitsmaßnahmen den kontinuierlichen Betrieb anhalten, jedoch dürfen IT-Sicherheitsmaßnahmen nicht zum Verlust des Schutzes führen, der Auswirkungen auf Gesundheit, Sicherheit und Umwelt hätte. Beispiele solcher Einschränkungen sind:

- Durch Zugangskontrollen (IAC und UC) darf der Betrieb wesentlicher Funktion nicht behindert werden; insbesondere gilt:

- Benutzerkonten mit Zugang zu wesentlichen Funktionen dürfen nicht gesperrt werden, auch nicht vorübergehend (siehe 5.5, SR 1.3 – Einheitliche Nutzerkontenverwaltung; 5.6, SR 1.4 – Verwaltung der Bezeichner; 5.13, SR 1.11 – Erfolgreiche Anmeldeversuche und 6.7, SR 2.5 – Sitzungssperrung).
- Überprüfung und Aufzeichnung von Bedienhandlungen zur Durchsetzung der Nichtabstreitbarkeit dürfen die Reaktion des Systems nicht signifikant verzögern (siehe 6.14, SR 2.12 – Nichtabstreitbarkeit).
- Bei hochverfügbaren Automatisierungssystemen darf der Ausfall der Zertifizierungsstelle nicht zur Unterbrechung wesentlicher Funktionen führen (siehe 5.10, SR 1.8 – PKI-Zertifikate).
- Identifizierung und Authentifizierung dürfen die Einleitung der sicherheitstechnischen Funktion (SIF) nicht verhindern (siehe 5.3 SR 1.1 – Identifizierung und Authentifizierung von menschlichen Nutzern und 5.4, SR 1.2 – Identifizierung und Authentifizierung von Softwareprozessen und Geräten). Gleiches gilt für die Durchsetzung von Autorisierungen (siehe 6.3, SR 2.1 – Durchsetzung der Autorisierung).
- Mit falschen Zeitstempeln versehene Ereignisdatensätze (siehe 6.10, SR 2.8 – Prüfbare Ereignisse und deren Aufzeichnung und 6.13, SR 2.11 – Zeitstempel) dürfen wesentlichen Funktionen nicht beeinträchtigen.
- Wesentliche Funktionen eines IACS müssen auch dann aufrechterhalten werden, wenn der Schutz der Zonengrenze in den Zustand „Im Fehlerfall geschlossen“ und/oder „Inselmodus“ übergeht (siehe 9.4, SR 5.2 – Schutz der Zonengrenze).
- Ein Denial-of-Service (DoS)-Vorfall mit Wirkung auf das Netz des Automatisierungssystems oder des sicherheitstechnischen Systems (SIS) darf die sicherheitstechnische Funktion (SIF) nicht an der Ausführung hindern (siehe 11.3, SR 7.1 – Schutz gegen DoS-Ereignisse).

4.3 Ausgleichsmaßnahmen

In dieser Norm beschriebenen Ausgleichsmaßnahmen müssen die in IEC 62443-3-2 beschriebenen Leitlinien befolgen.

In dieser Norm wird durchgängig folgende normative Formulierung zur Beschreibung einer Systemanforderung verwendet: „Das Automatisierungssystem muss die Fähigkeit bieten, ...“ eine bestimmte IT-Sicherheitsanforderung zu unterstützen. Das Automatisierungssystem muss die Fähigkeit bieten, aber sie kann auch durch eine externe Komponente erbracht werden. In solch einem Fall muss das Automatisierungssystem eine „Schnittstelle“ zu dieser externen Komponente bereitstellen. Einige Beispiele für solche Ausgleichsmaßnahmen sind Nutzeridentifizierung (entweder zentral oder verteilt), Durchsetzung eines starken Passwortes, Gültigkeitsprüfung einer Signatur, Korrelation von IT-Sicherheitsvorfällen und Außerbetriebnahme von Geräten (Dauerhaftigkeit von Informationen).

ANMERKUNG 1 Die in dieser Norm dargelegten IT-Sicherheitsanforderungen an das Automatisierungssystem betreffen alle für ein Automatisierungssystem relevanten technischen Funktionen, einschließlich Werkzeuge und Anwendungen. Jedoch können, wie hier vermerkt, einige dieser Funktionen auch mit externen Mitteln erbracht werden.

ANMERKUNG 2 Bei einigen Anwendungen mit hoher Ressourcenverfügbarkeit (hoher SL-T(RA, Automatisierungssystem)) werden außerhalb des Automatisierungssystems gelegene und erbrachte Ausgleichsmaßnahmen (wie etwa zusätzliche physikalische Sicherheitsmaßnahmen und erweiterte Überprüfungen der Vergangenheit von Mitarbeitern) notwendig sein. In diesen Fällen kann es sein, dass ein üblicherweise auf hochverfügbare Ressourcen angewiesenes Automatisierungssystem mit einem niedrigeren SL (1 oder 2) ausgeführt wird, je nach den getroffenen Ausgleichsmaßnahmen. Aussperrung oder Verlust der Regelfähigkeit aufgrund von IT-Sicherheitsmaßnahmen nimmt für sehr hochverfügbare Automatisierungssysteme zu und nicht ab. Daher sind höhere SL nicht immer besser, selbst wenn die Kosten keinen signifikanten Faktor darstellen.

4.4 Minimal erforderliche Rechte (en: least privilege)

Es muss die Fähigkeit vorhanden sein, das Prinzip der minimal erforderlichen Rechte durchzusetzen. Dabei müssen die Rechte so abgestuft und deren Abbildungen auf die einzelnen Rollen so flexibel sein, dass dieses Konzept unterstützt wird. Falls gefordert, sollten individuelle Zuordnungsmöglichkeiten zur Verfügung stehen.

5 Grundlegende Anforderung FR 1 – Identifizierung und Authentifizierung

5.1 Zweck und Beschreibungen des SL-C(IAC)

Alle Nutzer (Menschen, Softwareprozesse und Geräte) identifizieren und authentifizieren, bevor ihnen der Zugang zum Automatisierungssystem gewährt wird.

- SL 1 – Identifizieren und Authentifizieren aller Nutzer (Menschen, Softwareprozesse und Geräte) durch Verfahren, die gegen gelegentlichen oder zufälligen Zugang von nicht authentifizierten Personen oder Stellen schützen.
- SL 2 – Identifiziere und authentisiere alle Nutzer (Menschen, Softwareprozesse und Geräte) durch Verfahren, die gegen einen absichtlichen, nicht authentifizierten Zugang von Personen oder Stellen, die mit einfachen Mitteln, geringen Ressourcen, allgemeinen Fertigkeiten und geringer Motivation vorgehen, schützen.
- SL 3 – Identifiziere und authentisiere alle Nutzer (Menschen, Softwareprozesse und Geräte) durch Verfahren, die gegen einen absichtlichen, nicht authentifizierten Zugang von Personen oder Stellen, die mit raffinierten Mitteln, mittleren Ressourcen, IACS-spezifische Fertigkeiten und mittlerer Motivation vorgehen, schützen.
- SL 4 – Identifiziere und authentisiere alle Nutzer (Menschen, Softwareprozesse und Geräte) durch Verfahren, die gegen einen absichtlichen, nicht authentifizierten Zugang von Personen oder Stellen, die mit raffinierten Mitteln, erheblicher Ressourcen, IACS-spezifische Fertigkeiten und hoher Motivation vorgehen, schützen.

5.2 Begründung

Die Betreiber müssen eine Liste aller Nutzer (Mensch, Softwareprozes und Gerät) erstellen und für jede Komponente des Automatisierungssystems die erforderliche Schutzstufe durch Identifizierung und Authentifizierung bestimmen können. Das Ziel der Identifizierung und Authentifizierung ist es, das Automatisierungssystem dadurch zu schützen, dass die Identität eines jeden Nutzers geprüft wird, der Zugriff zum Automatisierungssystem anfordert, bevor die Kommunikation aktiviert wird. Zu den Empfehlungen und Leitlinien sollten solche Verfahren gehören, die im gemischten Modus arbeiten. Zum Beispiel erfordern manche Komponenten eines Automatisierungssystems eine starke Identifizierung und Authentifizierung, wie z. B. starke Authentifizierungsverfahren, und andere nicht.

5.3 SR 1.1 – Identifizierung und Authentifizierung von menschlichen Nutzern

5.3.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, alle menschlichen Nutzer zu identifizieren und zu authentifizieren. Diese Fähigkeit muss an allen Schnittstellen, die menschlichen Nutzern Zugang zum Automatisierungssystem gewähren, die Identifizierung und Authentifizierung durchsetzen, so dass die Trennung von Aufgaben und das Prinzip der minimal erforderlichen Rechte entsprechend den anzuwendenden IT-Sicherheitsleitlinien und -vorgehensweisen unterstützt wird.

5.3.2 Begründung und zusätzliche Hinweise

Alle menschlichen Nutzer müssen für alle Arten eines Zugriffs auf das Automatisierungssystem identifiziert und authentifiziert werden. Die Authentifizierung der Identität dieser Nutzer sollte durch die Verwendung solcher Methoden wie z. B. Passwörter, Token, biometrische Merkmale oder, bei Multifaktor-Authentifizierung, einer Kombination dieser Methoden erfolgen. Der Aufenthaltsort des betreffenden menschlichen Nutzers kann ebenfalls als Teil des Authentifizierungsprozesses verwendet werden. Diese Anforderung sollte sowohl bei lokalem als auch Fernzugriff gelten. Zusätzlich zum Identifizieren und Authentifizieren aller menschlichen Nutzer auf der Ebene des Automatisierungssystems (beispielsweise bei der Anmeldung am System) werden Identifizierungs- und Authentifizierungsverfahren oft auch in der Ebene der Anwendungen eingesetzt.

Dort, wo die menschlichen Nutzer wie eine einzige Gruppe auftreten (beispielsweise die Bediener einer Leitwarte), dürfen die Identifizierung und Authentifizierung der Nutzer rollenbasiert oder gruppenbasiert erfolgen. Bei einigen Automatisierungssystemen ist die Fähigkeit eines unmittelbaren Eingriffs der Bediener kritisch. Daher ist es wesentlich, dass lokale Notfallmaßnahmen sowie die wesentlichen Funktionen des Automati-

sierungssysteme nicht durch Identifizierungs- und Authentifizierungsanforderungen behindert werden (siehe [Abschnitt 4](#) für eine ausführliche Darstellung). Der Zugang zu diesen Systemen kann durch geeignete physikalische Sicherheitsmechanismen eingeschränkt werden (siehe IEC 62443-2-1). Ein Beispiel solch einer Situation ist eine Leitwarte für kritische Prozesse, für die eine strikte physikalische Zugangskontrolle und Überwachung durchgeführt wird und Schichtpläne einer Gruppe von Bedienern Verantwortlichkeiten zuweisen. Diese dürfen dann dieselbe Nutzeridentität verwenden. Zusätzlich sollten die Clients auf den Arbeitsplatzrechnern der Bediener authentifiziert werden (siehe 5.4, SR 1.2 – Identifizierung und Authentifizierung von Softwareprozessen und Geräten), oder die Verwendung des gemeinsamen Benutzerkontos sollte auf den Raum der Leitwarte beschränkt werden.

Entsprechend den IAC-Leitlinien nach IEC 62443-2-1 prüft das Automatisierungssystem in einem ersten Schritt die Identität aller menschlichen Nutzer. In einem zweiten Schritt werden die den menschlichen Nutzern zugewiesenen Berechtigungen (siehe [6.3](#), SR 2.1 – Durchsetzung der Autorisierung) durchgesetzt.

5.3.3 Weitergehende Anforderungen

5.3.3.1 SR 1.1 RE 1 – Eindeutige Identifizierung und Authentifizierung

Das Automatisierungssystem muss die Fähigkeit bieten, alle menschlichen Nutzer eindeutig zu identifizieren und zu authentifizieren.

5.3.3.2 SR 1.1 RE 2 – Multifaktor-Authentifizierung für nicht vertrauenswürdige Netze

Das Automatisierungssystem muss die Fähigkeit bieten, eine Multifaktor-Authentifizierung für den Zugriff menschlicher Nutzer auf das Automatisierungssystem über ein nicht vertrauenswürdiges Netz (siehe [5.15](#), SR 1.13 – Zugriff über nicht vertrauenswürdige Netze) einzusetzen.

ANMERKUNG Siehe [5.7](#), SR 1.5 – Verwaltung von Authentifizierern und RE [5.7.3.1](#) zu dessen Weiterführung bei Softwareprozessen.

5.3.3.3 SR 1.1 RE 3 – Multifaktor-Authentifizierung für alle Netze

Das Automatisierungssystem muss die Fähigkeit bieten, eine Multifaktor-Authentifizierung für den Zugriff aller menschlichen Nutzer auf das Automatisierungssystem zu verwenden.

5.3.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 1.1 – Identifizierung und Authentifizierung von menschlichen Nutzern sind:

- SL-C(IAC, Automatisierungssystem) 1: SR 1.1;
- SL-C(IAC, Automatisierungssystem) 2: SR 1.1 (1);
- SL-C(IAC, Automatisierungssystem) 3: SR 1.1 (1) (2);
- SL-C(IAC, Automatisierungssystem) 4: SR 1.1 (1) (2) (3).

5.4 SR 1.2 – Identifizierung und Authentifizierung von Softwareprozessen und Geräten

5.4.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, alle Softwareprozesse und Geräte zu identifizieren und zu authentifizieren. Diese Fähigkeit muss solche Identifikation und Authentisierung an allen Schnittstellen umsetzen, die Zugang zum Automatisierungssystem gewähren, so dass das Prinzip der kleinsten Rechte in Übereinstimmung mit den zutreffenden Leitlinien und Vorgehensweisen unterstützt wird.

5.4.2 Begründung und zusätzliche Hinweise

Die Funktion der Identifizierung und Authentifizierung besteht darin, einen Bezeichner auf einen unbekannten Softwareprozess oder ein unbekanntes Gerät (in diesem Unterabschnitt ab hier als Einheit bezeichnet) so abzubilden, so dass diese vor Aufnahme eines Datenaustausches bekannt gemacht wird. Würde man es

betrügerischen Einheiten erlauben, automatisierungsspezifische Daten zu senden oder zu empfangen, so könnte dies zu einem schädlichen Verhalten des legitimen Automatisierungssystems führen.

Alle Einheiten müssen für alle Zugriffe auf das Automatisierungssystem identifiziert und authentifiziert werden. Die Authentifizierung der Identität dieser Einheiten sollte durch die Verwendung von Methoden wie z. B. Passwörtern, Token oder Aufenthaltsort (physikalisch oder logisch) erfolgen. Diese Anforderung sollte sowohl bei einem lokalen Zugriff als auch bei einem Zugriff aus der Ferne gelten. Bei einigen Szenarien, in denen einzelne Einheiten dazu verwendet werden, sich mit verschiedenen Zielsystemen (beispielsweise Fernunterstützung durch einen Kundendienst) zu verbinden, können jedoch mehrere Identitäten für eine Einheit technisch nicht ausführbar sein, so dass Ausgleichsmaßnahmen angewendet werden müssten.

Zum Schutz vor Man-in-the-Middle-Angriffen oder Spoofing sind Identifizierungs- und Authentifizierungsverfahren für alle Einheiten nötig. In manchen Fällen können diese Verfahren mehrere Softwareprozesse einbeziehen, die auf demselben physikalischen Server laufen, wobei jeder Prozess seine eigene Identität hat. In anderen Fällen kann die Identität an das physikalische Gerät gebunden sein, wenn beispielsweise alle Prozesse auf einer bestimmten SPS laufen.

Besondere Aufmerksamkeit ist erforderlich, wenn tragbare oder mobile Geräte identifiziert und authentifiziert werden müssen. Diese Art von Geräten ist eine bekannte Methode, um in Automatisierungssystemen, auch solchen, die ansonsten isoliert sind, unerwünschten Netzverkehr zu erzeugen, Schadsoftware (Schadprogramme) einzuschleusen oder Informationsoffenlegung herbeizuführen.

Sofern Einheiten wie eine geschlossene Gruppe funktionieren, darf die Identifizierung und Authentifizierung auch rollenbasiert, gruppenbasiert oder einheitenbasiert erfolgen; dabei ist es äußerst wichtig, dass lokale Notfallhandlungen, aber auch für das Automatisierungssystem wesentliche Funktionen, nicht durch Identifizierungs- und Authentifizierungsanforderungen behindert werden (siehe [Abschnitt 4](#) für eine ausführliche Darstellung). Bei üblichen Schutzverfahren führt zum Beispiel eine Gruppe von Geräten gemeinsam die Schutzfunktionen aus und kommuniziert mittels Multicast-Nachrichten untereinander. In solchen Fällen findet häufig eine Gruppenauthentifizierung auf Basis gemeinsamer Benutzerkonten oder gemeinsamer symmetrischer Schlüssel statt.

Entsprechend den in IEC 62443-2-1 festgelegten Identifizierungs- und Authentifizierungsleitlinien überprüft das Automatisierungssystem in einem ersten Schritt die Identität aller Einheiten. In einem zweiten Schritt werden die den identifizierten Einheiten zugewiesenen Rechte durchgesetzt (siehe [6.3](#), SR 2.1 – Durchsetzung der Autorisierung).

5.4.3 Weitergehende Anforderungen

5.4.3.1 SR 1.2 RE 1 – Eindeutige Identifizierung und Authentifizierung

Das Automatisierungssystem muss die Fähigkeit bieten, alle Softwareprozesse und Geräte eindeutig zu identifizieren und zu authentifizieren.

5.4.3.2 Leer

5.4.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 1.2 – Identifizierung und Authentifizierung von Softwareprozessen und Geräten sind:

- SL-C(IAC, Automatisierungssystem) 1: keine;
- SL-C(IAC, Automatisierungssystem) 2: SR 1.2;
- SL-C(IAC, Automatisierungssystem) 3: SR 1.2 (1);
- SL-C(IAC, Automatisierungssystem) 4: SR 1.2 (1).

5.5 SR 1.3 – Nutzerkontenverwaltung

5.5.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, alle Konten autorisierter Nutzer zu verwalten, hierzu gehören das Hinzufügen, die Aktivierung, die Änderung, das Sperren und das Löschen von Konten.

5.5.2 Begründung und zusätzliche Hinweise

Die Nutzerkontenverwaltung darf die Zusammenfassung von Konten (beispielsweise individuell, rollenbasiert, gerätebasiert und Automatisierungssystem-basiert), die Aufstellung von Bedingungen für Gruppenmitgliedschaften und die Zuweisung verbundener Autorisierungen beinhalten. In bestimmten Anwendungen von IACS, für die individuelle Konten aus Sicht einer Risikoanalyse oder aus regulatorischer Sicht als nicht notwendig eingestuft werden, sind gemeinsam genutzte Konten akzeptabel, solange angemessene Ausgleichsmaßnahmen (wie etwa beschränkter physikalischer Zugang oder organisatorische Maßnahmen, die Zustimmung einfordern) in Kraft und dokumentiert sind.

Nicht-menschliche Nutzerkonten (manchmal als Servicekonten bezeichnet), die der Kommunikation verschiedener Softwareprozesse untereinander dienen (zum Beispiel Leitsystem zum Server für historische Daten und Leitsystem zu SPS) erfordern typischerweise andere IT-Sicherheitsleitlinien und Verfahren als für Menschen angelegte Nutzerkonten. Für eine verbesserte IT-Sicherheit sollte die Verwaltung der Konten nach vereinheitlichten Leitlinien erfolgen und lokal in den entsprechenden Komponenten des Automatisierungssystems stattfinden. Für die Erstinstallation des Systems voreingestellte, jetzt aber nicht mehr gebrauchte Systemkonten sollten entfernbar sein. Die Vereinfachung und durchgängige Anwendung der Nutzerkontenverwaltung verbessert die IT-Sicherheit.

5.5.3 Weitergehende Anforderungen

5.5.3.1 SR 1.3 RE 1 – Einheitliche Nutzerkontenverwaltung

Das Automatisierungssystem muss die Fähigkeit bieten, eine einheitliche Nutzerkontenverwaltung zu unterstützen.

5.5.3.2 Leer

5.5.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 1.3 – Nutzerkontenverwaltung sind:

- SL-C(IAC, Automatisierungssystem) 1: SR 1.3;
- SL-C(IAC, Automatisierungssystem) 2: SR 1.3;
- SL-C(IAC, Automatisierungssystem) 3: SR 1.3 (1);
- SL-C(IAC, Automatisierungssystem) 4: SR 1.3 (1).

5.6 SR 1.4 – Verwaltung der Bezeichner

5.6.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, Bezeichner nach Nutzern, Gruppen, Rollen oder verschiedenen Schnittstellenarten des Automatisierungssystems zu verwalten.

5.6.2 Begründung und zusätzliche Hinweise

Bezeichner unterscheiden sich von den Berechtigungen, über die eine Person oder Stelle innerhalb eines bestimmten Bereichs oder einer bestimmten Zone eines Automatisierungssystems verfügt (siehe 6.3, SR 2.1 – Durchsetzung der Autorisierung). Dort, wo die menschlichen Nutzer wie eine einzige Gruppe auftreten (beispielsweise die Bediener in der Leitwarte), kann die Identifizierung der Nutzer rollenbasiert, gruppenbasiert oder gerätebasiert erfolgen. Bei einigen Automatisierungssystemen ist die Fähigkeit eines unmittelbaren Eingriffs der Bediener kritisch. Lokale Notfallaktionen für das Automatisierungssystem sollten nicht durch Identifizierungsanforderungen behindert werden. Der Zugriff auf diese Systeme darf durch geeignete Ausgleichs-

maßnahmen beschränkt werden. Bezeichner dürfen für Teile, aber nicht notwendigerweise für das gesamte Automatisierungssystem, gefordert werden. Beispielsweise fordern drahtlose Geräte einen Bezeichner, drahtgebundene Geräte dagegen nicht.

Die Verwaltung der Bezeichner wird durch lokale Leitlinien und Vorgehensweisen geregelt, die nach IEC 62443-2-1 aufgestellt wurden.

5.6.3 Weitergehende Anforderungen

Keine.

5.6.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 1.4 – Verwaltung der Bezeichner sind:

- SL-C(IAC, Automatisierungssystem) 1: SR 1.4;
- SL-C(IAC, Automatisierungssystem) 2: SR 1.4;
- SL-C(IAC, Automatisierungssystem) 3: SR 1.4;
- SL-C(IAC, Automatisierungssystem) 4: SR 1.4;

5.7 SR 1.5 – Verwaltung der Authentifizierer^{N1}

5.7.1 Anforderung

Das Automatisierungssystem muss die Fähigkeiten bieten:

- h) den Inhalt eines Authentifizierers zu initialisieren;
- i) alle voreingestellten Authentifizierer nach erfolgter Installation des Automatisierungssystems zu ändern;
- j) alle Authentifizierer zu ändern/zu erneuern; und
- k) alle Authentifizierer vor einer nicht autorisierten Offenlegung und Änderung während der Speicherung und Übermittlung zu schützen.^{N2}

5.7.2 Begründung und zusätzliche Hinweise

Neben einem Bezeichner (siehe 5.6, SR 1.4 – Verwaltung der Bezeichner) wird ein Authentifizierer zur Bestätigung der Identität benötigt. Authentifizierer eines Automatisierungssystems sind unter anderem: Token, symmetrische Schlüssel, private Schlüssel (als Teil eines öffentlichen/privaten Schlüsselpaares), biometrische Merkmale, Passwörter, physikalische Schlüssel und Schlüsselkarten. Menschliche Nutzer sollten angemessene Maßnahmen treffen, damit ihre Authentifizierer sicher verwahrt bleiben, sie sollten ihre persönlichen Authentifizierer in ihrem Besitz halten, sie nicht verleihen oder mit anderen Personen teilen und verlorene oder kompromittierte sofort melden.

Authentifizierer unterliegen einem Lebenszyklus. Wenn ein Nutzerkonto automatisch eingerichtet wird, muss auch ein neuer Authentifizierer erzeugt werden, damit der Kontoinhaber sich authentifizieren kann. Beispielsweise ist in einem passwortbasierten System ein Nutzerkonto mit einem Passwort verbunden. Die Festlegung des anfänglichen Authentifizierersinhaltes könnte so interpretiert werden, dass der Verwalter das anfängliche Passwort festlegt, welches das Kontoverwaltungssystem für alle neuen Konten vergibt. Wenn man in der Lage ist, diese anfänglichen Werte konfigurieren zu können, so würde man es einem Angreifer erschweren, das Passwort zwischen Einrichtung und erster Benutzung eines Kontos (dabei sollte der Kontoinhaber ein neues Passwort eintragen) erraten zu können. Einige Automatisierungssysteme werden mit Hilfe von unbeaufsichtigten Installationsprogrammen installiert, die alle benötigten Konten mit voreingestellten Passwörtern einrichten; manche Geräte werden sogar mit voreingestellten Passwörtern ausgeliefert. Im Laufe der Zeit werden solche Passwörter häufig allgemein bekannt und sogar im Internet dokumentiert. Die Fähigkeit, voreingestellte Passwörter ändern zu können, schützt das System gegen nicht-autorisierte Nutzer,

^{N1} Nationale Fußnote: Ein im Deutschen hierfür gebräuchlicher Ausdruck ist „Schlüsselmanagement“.

^{N2} Nationale Fußnote: Die in IEC 62443-3-3:2013 verwendete Nummerierung der Aufzählungspunkte ist nicht korrekt und sollte bei a) beginnen.

die mittels voreingestellter Passwörter Zugriff auf dieses erlangen würden. Passwörter können bei der Speicherung oder bei der Übertragung im Rahmen der netzbasierten Authentifizierung erlangt werden. Diese kann komplexer gestaltet werden mittels kryptographische Schutzmaßnahmen wie z. B. Verschlüsselung oder Hashfunktion oder mittels Handshake-Protokolle, bei denen man überhaupt keine Übertragung des Passwortes benötigt. Aber dennoch können Passwörter Gegenstand von Angriffen sein, beispielsweise durch systematisches Ausprobieren (en: brute force) oder Brechen des kryptographischen Schutzes bei deren Übertragung oder Speicherung. Das für solche Gelegenheiten offene Fenster kann verkleinert werden, indem man die Passwörter periodisch ändert oder erneuert. Ähnliche Überlegungen gelten für Authentifizierungssysteme mittels kryptographischer Schlüssel. Einen erweiterten Schutz kann man erreichen, wenn man Hardware-Mechanismen wie hardwaregebundene IT-Sicherheitsmodule, z. B. Trusted-Platform-Modules (TPM), einsetzt.

Die Verwaltung der Authentifizierer sollte in Leitlinien und Vorgehensweisen geregelt werden, beispielsweise Vorgaben zur Änderung voreingestellter Authentifizierer, Auffrischintervalle und die Festlegung des Schutzes der Authentifizierer oder von Firecall-Prozeduren (siehe [3.1.24](#)).

Eine Sperrung oder der Verlust der Steuerungsfunktionen auf Grund von IT-Sicherheitsmaßnahmen ist nicht hinnehmbar. Falls das Automatisierungssystem eine hohe Verfügbarkeit haben muss, sollten Maßnahmen zur Erhaltung dieses hohen Verfügbarkeitsniveaus ergriffen werden (etwa durch physikalische Ausgleichsmaßnahmen, duplizierte Schlüssel und Eingriffe des Aufsichtspersonals).

Neben den hier geforderten Fähigkeiten der Verwaltung der Authentifizierer (Schlüsselmanagement) hängt die Stärke der Authentifizierungsverfahren von der Stärke des gewählten Authentifizierers (beispielsweise von der Komplexität des Passwortes oder der Schlüssellänge bei der Authentifizierung öffentlicher Schlüssel) und den Leitlinien für die Validierung des Authentifizierers im Authentifizierungsprozess (beispielsweise von der Dauer der Gültigkeit eines Passwortes oder von der bei der Validierung öffentlicher Schlüsselzertifikate vorzunehmenden Prüfungen) ab. Für die gebräuchlichsten Authentifizierungsverfahren, also Authentifizierung mittels Passwörtern oder öffentlicher Schlüssel, gelten weitergehende Anforderungen nach [5.9](#), SR 1.7 – Stärke der Authentifizierung durch Passwörter, [5.10](#), SR 1.8 – PKI-Zertifikate und [5.11](#), SR 1.9 – Stärke der Authentifizierung mit öffentlichen Schlüsseln).

5.7.3 Weitergehende Anforderungen

5.7.3.1 SR 1.5 RE 1 – Beglaubigung der Identität von Softwareprozessen durch Hardwaremaßnahmen

Das Automatisierungssystem muss für Nutzer von Softwareprozessen und Geräten die Fähigkeit bieten, die betreffenden Authentifizierer durch Hardwaremechanismen zu schützen.

5.7.3.2 Leer

5.7.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 1.5 – Verwaltung der Authentifizierer sind:

- SL-C(IAC, Automatisierungssystem) 1: SR 1.5;
- SL-C(IAC, Automatisierungssystem) 2: SR 1.5;
- SL-C(IAC, Automatisierungssystem) 3: SR 1.5 (1);
- SL-C(IAC, Automatisierungssystem) 4: SR 1.5 (1).

5.8 SR 1.6 – Management drahtloser Zugriffsverfahren

5.8.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, alle drahtlos kommunizierenden Nutzer (menschliche Nutzer, Softwareprozesse und Geräte) zu identifizieren und zu authentifizieren.

5.8.2 Begründung und zusätzliche Hinweise

Alle drahtlosen Technologien können, und in den meisten Fällen sollten sie auch nur, als eine weitere Kommunikationsmöglichkeit angesehen werden und daher auch denselben IT-Sicherheitsanforderungen wie jedes andere von einem IACS benutzte Kommunikationsmedium unterliegen. Von einem IT-Sicherheitsstandpunkt aus gesehen gibt es daher mindestens einen signifikanten Unterschied zwischen einer drahtgebunden und einer drahtlosen Kommunikation: Die physikalischen Sicherheitsmaßnahmen sind bei drahtloser Kommunikation normalerweise weniger wirksam. Aus diesem und möglicherweise anderen Gründen (beispielsweise aus regulatorischen Unterschieden) könnte eine Risikoanalyse berechtigterweise zu einem höheren SL-T(IAC, Automatisierungssystem) führen, wenn eine drahtlose Kommunikation anstelle einer drahtgebunden in einem sonst identischen Anwendungsfall eingesetzt wird.

Drahtlose Technologien umfassen unter anderem Mikrowellen, Satelliten, Paketfunk, Institute of Electrical and Electronics Engineers (IEEE) 802.11x, IEEE 802.15.4 (ZigBee, IEC 62591 – *WirelessHART*®, ISA-100.11a), IEEE 802.15.1 (Bluetooth), drahtlose, mobile LAN-Router, schnurlose Telefone und verschiedene Infrarot-Technologien.

5.8.3 Weitergehende Anforderungen

5.8.3.1 SR 1.6 RE 1 – Eindeutige Identifizierung und Authentifizierung

Das Automatisierungssystem muss die Fähigkeit bieten, alle drahtlos kommunizierenden Nutzer (menschliche Nutzer, Softwareprozesse und Geräte) eindeutig zu identifizieren und zu authentifizieren.

5.8.3.2 Leer

5.8.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 1.6 – Management drahtloser Zugriffsverfahren sind:

- SL-C(IAC, Automatisierungssystem) 1: SR 1.6;
- SL-C(IAC, Automatisierungssystem) 2: SR 1.6 (1);
- SL-C(IAC, Automatisierungssystem) 3: SR 1.6 (1);
- SL-C(IAC, Automatisierungssystem) 4: SR 1.6 (1).

5.9 SR 1.7 – Stärke der Authentifizierung durch Passwörter

5.9.1 Anforderung

Ein Automatisierungssystem, das Passwörter zur Authentifizierung verwendet, muss die Fähigkeit bieten, eine konfigurierbare Stärke von Passwörtern, beruhend auf deren kleinster Länge, und eine Vielfalt ihrer Zeichen durchzusetzen.

5.9.2 Begründung und zusätzliche Hinweise

Die Authentifizierung eines Nutzers anhand seines Nutzernamens und eines geheimen Passworts ist ein sehr geläufiges Verfahren. Viele Angriffe auf solche Verfahren konzentrieren sich darauf, das Passwort zu erraten (beispielsweise Wörterbuchangriffe oder gezieltes Social Engineering^{N3}) oder den kryptographischen Schutz der gespeicherten Passwortdarstellung zu brechen (beispielsweise durch Verwendung von Regenbogen-tabellen oder durch Erzeugen von Hashkollisionen mit der Brute-Force-Vorgehensweise).

Eine durch eine erhöhte Anzahl erlaubter Zeichen umfangreichere Menge gültiger Passwörter macht solche Angriffe komplexer, aber nur dann, wenn die umfangreichere Menge auch tatsächlich ausgeschöpft wird (allgemein neigen Nutzer dazu, in einem Passwort möglichst keine Sonderzeichen zu verwenden, da diese vermeintlich schwerer einzuprägen sind). Durch die Begrenzung der Lebensdauer eines Passwortes verkleinert man für einen Angreifer die Möglichkeit, dessen Geheimnis zu brechen. Um die Nutzer daran zu hindern, diese Maßnahme zu umgehen und ihr gerade geändertes Passwort sogleich wieder auf den alten

^{N3} Nationale Fußnote: Erlangen vertraulicher Informationen durch Annäherung an Geheimnisträger mittels gesellschaftlicher oder gespielter Kontakte.

Wert zurücksetzen, wird üblicherweise für ein Passwort auch eine Mindestlebensdauer durchgesetzt. Ein Hinweis auf den bevorstehenden Ablauf eines Passwortes ermöglicht es dem Nutzer, sein Passwort zu einem für ihn im Rahmen der betrieblichen Randbedingungen angemessenen Zeitpunkt zu ändern.

Dieser Schutz kann noch weiter vergrößert werden, indem die Wiederverwendung von Passwörtern beschränkt (und so einer kleinen Menge von wechselnden Passwörtern vorbeugt) wird, wodurch der Nutzen eines einmal gebrochenen Passwortes weiter verringert wird. Einen weitergehenden Schutz über Passwort-basierte Verfahren hinaus kann durch eine Multifaktor-Authentifizierung erreicht werden (siehe 5.3, SR 1.1 – Identifizierung und Authentifizierung von menschlichen Nutzern und 5.4, SR 1.2 – Identifizierung und Authentifizierung von Softwareprozessen und Geräten).

5.9.3 Weitergehende Anforderungen

5.9.3.1 SR 1.7 RE 1 – Erzeugung und Lebensdauerbeschränkungen von Passwörtern für menschliche Nutzer

Das Automatisierungssystem muss die Fähigkeit bieten, für eine einstellbare Anzahl von Erzeugungen zu verhindern, dass ein gegebenes Konto eines menschlichen Nutzers ein Passwort wiederverwendet. Zusätzlich muss das Automatisierungssystem die Fähigkeit bieten, eine minimale und maximale Lebensdauer von Passwörtern für einen menschlichen Nutzer durchzusetzen. Diese Fähigkeiten müssen mit den üblicherweise in der Industrie herrschenden IT-Sicherheitspraktiken im Einklang stehen.

ANMERKUNG Es ist eine allgemein übliche und gute Praxis, dass das Automatisierungssystem einen Nutzer zum Wechsel des Passwortes auffordert, sobald eine einstellbare Zeit vor dessen Ablauf erreicht ist.

5.9.3.2 SR 1.7 RE 2 – Lebensdauerbeschränkungen von Passwörtern für alle Nutzer

Das Automatisierungssystem muss die Fähigkeit bieten, eine minimale und maximale Lebensdauer von Passwörtern für alle Nutzer durchzusetzen.

5.9.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 1.7 – Stärke der Authentifizierung durch Passwörter sind:

- SL-C(IAC, Automatisierungssystem) 1: SR 1.7;
- SL-C(IAC, Automatisierungssystem) 2: SR 1.7;
- SL-C(IAC, Automatisierungssystem) 3: SR 1.7 (1);
- SL-C(IAC, Automatisierungssystem) 4: SR 1.7 (1) (2);

5.10 SR 1.8 – PKI-Zertifikate

5.10.1 Anforderung

Falls eine Public-Key-Infrastruktur (PKI) zum Einsatz kommt, muss das Automatisierungssystem die Fähigkeit bieten, eine solche PKI entsprechend bewährter Verfahren zu betreiben oder öffentliche Schlüsselzertifikate von einer bestehenden PKI beziehen zu können.

5.10.2 Begründung und zusätzliche Hinweise

Eine Registrierung, um ein Zertifikat einer PKI zu erhalten, erfordert die Beibringung einer Erlaubnis durch eine Überwachungsstelle oder eine verantwortliche Amtsperson und die Ausführung mit Hilfe eines abgesicherten Verfahrens, das die Identität des Inhabers des Zertifikats bestätigt und sicherstellt, dass das Zertifikat an die Zielgruppe ausgegeben worden ist. Jegliche aus der Verwendung öffentlicher Schlüsselzertifikate resultierende Verzögerung sollte die Leistungsfähigkeit des Automatisierungssystems nicht beeinträchtigen.

Bei der Wahl einer geeigneten Public-Key-Infrastruktur sollten die Zertifizierungsleitlinien der Organisation beachtet werden; diese sollten auf dem Risiko beruhen, das sich aus einem Bruch der Vertraulichkeit der geschützten Information ergibt. Anleitungen zur Festlegung solcher Leitlinien finden sich in allgemein anerkannten Standards und Leitlinien, beispielsweise in dem Request for Comment (RFC) der Internet Engineering Task Force (IETF) RFC 3647 [29] für eine X.509-basierte PKI. Beispielsweise sollten der geeignete Ort

einer Zertifizierungsstelle, entweder innerhalb des Automatisierungssystems oder im Internet, sowie die Liste der vertrauenswürdigen Zertifizierungsstellen in den Leitlinien berücksichtigt werden, wobei dies von der Netzarchitektur (siehe auch IEC 62443-2-1) abhängt.

5.10.3 Weitergehende Anforderungen

Keine.

5.10.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 1.8 – PKI-Zertifikate sind:

- SL-C(IAC, Automatisierungssystem) 1: keine;
- SL-C(IAC, Automatisierungssystem) 2: SR 1.8;
- SL-C(IAC, Automatisierungssystem) 3: SR 1.8;
- SL-C(IAC, Automatisierungssystem) 4: SR 1.8.

5.11 SR 1.9 – Stärke der Authentifizierung durch öffentliche Schlüssel

5.11.1 Anforderung

Bei Automatisierungssystemen, die Authentifizierung mit öffentlichen Schlüsseln verwenden, muss das Automatisierungssystem die Fähigkeit bieten:

- a) Zertifikate durch Prüfung der Gültigkeit der vorliegenden Signatur validieren;
- b) Zertifikate durch Aufbau eines Zertifizierungspfades zu einer anerkannten Zertifizierungsstelle validieren oder, im Falle eines selbst signierten Zertifikats, durch Ausgabe von untergeordneten Zertifikaten an alle Hosts, die mit demjenigen kommunizieren, auf den das Zertifikat ausgestellt wurde;
- c) Zertifikate auf mögliche Widerrufe überprüfen und dadurch validieren;
- d) die Kontrolle des zugehörigen privaten Schlüssels durch den Nutzer (menschlicher Nutzer, Softwareprozess oder Gerät) einrichten; und
- e) die authentifizierte Identität auf einen Nutzer (menschlichen Nutzer, Softwareprozess oder Gerät) abbilden.

5.11.2 Begründung und zusätzliche Hinweise

Asymmetrische Kryptosysteme (mit privaten und öffentlichen Schlüsseln) hängen in starkem Maße von der Geheimhaltung des privaten Schlüssels und der korrekten Handhabung der Vertrauensbeziehung ab. Bei der Verifikation des Vertrauens zwischen zwei jeweils mittels öffentlichen Schlüssels authentifizierten Einheiten ist es entscheidend, dass das Zertifikat des öffentlichen Schlüssels auf eine vertrauenswürdige Einheit zurückgeführt werden kann. Ein häufiger Fehler bei der Implementierung der Validierung von Zertifikaten ist, dass lediglich die Gültigkeit der Signatur eines Zertifikats geprüft wird, aber nicht das Vertrauen in den Signierer. In einer PKI wird einem Signierer vertraut, wenn er eine vertrauenswürdige Zertifizierungsstelle ist oder ein Zertifikat besitzt, das von einer solchen herausgegeben wurde, so dass alle Verifizierer die ihnen vorgelegten Zertifikate zu einer vertrauenswürdigen Zertifizierungsstelle zurückverfolgen müssen. Kann solch eine Kette von vertrauenswürdigen Zertifizierungsstellen nicht aufgebaut werden, sollte dem vorgelegten Zertifikat nicht vertraut werden.

Werden an Stelle einer PKI selbst signierte Zertifikate eingesetzt, das zu zertifizierende Subjekt signiert sein Zertifikat also selbst, dann gibt es überhaupt keine vertrauenswürdige Dritt- oder Zertifizierungsstelle. Dieses sollte durch Ausgabe selbst signierter Zertifikate für die öffentlichen Schlüssel an alle Partner ausgeglichen werden, die diese durch anderweitig abgesicherte Mechanismen validieren müssen (beispielsweise durch Konfiguration aller Partner in einer vertrauenswürdigen Umgebung). Vertrauenswürdige Zertifikate müssen über gesicherte Kanäle an die Partner verteilt werden. Während des Validierungsvorganges sollte einem selbst signierten Zertifikat nur dann vertraut werden, wenn sich dieses bereits in der Liste der vertrauenswürdigen Zertifikate des validierenden Partners befindet. Die Menge vertrauenswürdiger Zertifikate sollte so klein wie möglich gehalten werden.

In beiden Fällen muss bei der Validierung damit gerechnet werden, dass ein Zertifikat widerrufen wird. In einer PKI geschieht dies meist durch die Führung von Zertifikatssperrlisten oder durch den Betrieb eines „Online Certificate Status Protocol“ (OCSP)-Servers. Sollte auf Grund von Einschränkungen im Automatisierungssystem eine Abfrage von Sperrlisten nicht möglich sein, so können Vorkehrungen wie eine kurze Zertifikatslebensdauer diesen Mangel kompensieren. Man beachte, dass gelegentlich Zertifikate mit kurzer Lebensdauer zu erheblichen betrieblichen Belastungen in einem Automatisierungssystem führen können.

5.11.3 Weitergehende Anforderungen

5.11.3.1 SR 1.9 RE 1 – Beglaubigung öffentlicher Schlüssel durch Hardwaremaßnahmen

Das Automatisierungssystem muss die Fähigkeit bieten, die betreffenden privaten Schlüssel mittels Hardwaremaßnahmen entsprechend üblichen technischen Gepflogenheiten und Empfehlungen zu schützen.

5.11.3.2 Leer

5.11.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 1.9 – Beglaubigung öffentlicher Schlüssel durch Hardwaremaßnahmen sind:

- SL-C(IAC, Automatisierungssystem) 1: keine;
- SL-C(IAC, Automatisierungssystem) 2: SR 1.9;
- SL-C(IAC, Automatisierungssystem) 3: SR 1.9 (1);
- SL-C(IAC, Automatisierungssystem) 4: SR 1.9 (1);

5.12 SR 1.10 – Rückmeldung vom Authentifizierer

5.12.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, während des Authentifizierungsvorganges die Rückmeldungen von Authentifizierungsinformationen zu verdecken.

5.12.2 Begründung und zusätzliche Hinweise

Das Verdecken von Rückmeldungen schützt Informationen vor einer möglichen Auswertung durch nicht autorisierte Individuen, beispielsweise verdeckt das Anzeigen von Sternchen oder anderen Zufallszeichen die Rückmeldung von Authentifizierungsinformationen, wenn ein menschlicher Nutzer sein Passwort eingibt. Weitere Beispiele sind die Eingabe eines WEP-Schlüssels, eines Tokens beim SSH-Verfahren und RSA-Einmalpasswörter. Die authentifizierende Stelle sollte keine Hinweise wie „unbenannter Nutzername“ als Erklärung für die fehlgeschlagene Authentifizierung liefern.

5.12.3 Weitergehende Anforderungen

Keine.

5.12.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 1.10 – Rückmeldung vom Authentifizierer sind:

- SL-C(IAC, Automatisierungssystem) 1: SR 1.10;
- SL-C(IAC, Automatisierungssystem) 2: SR 1.10;
- SL-C(IAC, Automatisierungssystem) 3: SR 1.10;
- SL-C(IAC, Automatisierungssystem) 4: SR 1.10.

5.13 SR 1.11 – Erfolgreiche Anmeldeversuche

5.13.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, eine Grenze für eine einstellbare Anzahl erfolgloser aufeinanderfolgender Anmeldeversuche irgendeines Nutzers (menschlichen Nutzers, Softwareprozesses oder Geräts) innerhalb einer einstellbaren Zeit durchzusetzen. Es muss weiterhin die Fähigkeit bieten, nach dem Überschreiten dieser Grenze den Zugang für eine vorgegebene Zeit oder bis zum Entsperren durch einen Administrator verweigern zu können.

Für Systemkonten, in deren Auftrag kritische Dienste oder Server betrieben werden, muss das Automatisierungssystem die Fähigkeit bieten, interaktive Anmeldungen zu verbieten.

5.13.2 Begründung und zusätzliche Hinweise

Aufgrund der Möglichkeit einer Denial-of-Service-Situation darf die Anzahl aufeinanderfolgender ungültiger Anmeldeversuche begrenzt werden. Falls diese Grenze aktiviert wurde, darf das Automatisierungssystem automatisch die Anzahl der Anmeldeversuche nach einer vorbestimmten Zeit, in Übereinstimmung mit den geltenden IT-Sicherheitsleitlinien und Verfahren, wieder auf null zurücksetzen. Durch diese Rücksetzung auf null können die Nutzer (menschliche Nutzer, Softwareprozesse und Geräte) Zugriff bekommen, sofern sie den richtigen Anmeldebezeichner haben. Sind in Notsituationen unmittelbare Reaktionen des Bedienpersonals erforderlich, dann sollte eine automatische Zugriffsverweigerung zu Bedienplätzen, Arbeitsplatz-Computern oder Netzknoten des Automatisierungssystems nicht stattfinden. Alle Aussperrungsmechanismen sollten die funktionalen Anforderungen an einen Dauerbetrieb berücksichtigen, um schädliche Denial-of-Service-Situationen, die zu einem Totalausfall des Systems oder zu Personenschäden führen könnten, abzumildern. Die Zulassung interaktiver Anmeldungen an einem für kritische Dienste verwendeten Konto könnte eine Möglichkeit für eine Denial-of-Service-Situation oder anderen Missbrauch darstellen.

5.13.3 Weitergehende Anforderungen

Keine.

5.13.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 1.11 – Erfolgreiche Anmeldeversuche sind:

- SL-C(IAC, Automatisierungssystem) 1: SR 1.11;
- SL-C(IAC, Automatisierungssystem) 2: SR 1.11;
- SL-C(IAC, Automatisierungssystem) 3: SR 1.11;
- SL-C(IAC, Automatisierungssystem) 4: SR 1.11.

5.14 SR 1.12 – Nutzungshinweis

5.14.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, noch vor der Authentifizierung auf die mit der Nutzung des Systems verbundenen Rechte und Pflichten hinzuweisen. Diese Anzeige muss von autorisiertem Personal konfiguriert werden können.

5.14.2 Begründung und zusätzliche Hinweise

Leitlinien und Verfahren zum Datenschutz und zur IT-Sicherheit müssen im Einklang mit gesetzlichen Vorgaben, Leitlinien, Richtlinien, Normen und Anleitungen stehen. Häufig liegt die Begründung hierfür in der Strafverfolgung und dem Nachweis vorsätzlichen Rechtsbruches. Dieser Hinweis des Automatisierungssystems ist somit zur Unterstützung solcher Regeln notwendig und verbessert die IT-Sicherheit eines IACS nicht. Derartige Systemnutzungshinweise können in Form eines Warnbanners implementiert werden, der bei der Anmeldung von Personen an das Automatisierungssystem angezeigt wird. Ein in den Räumen des Automatisierungssystems angebrachtes Warnbanner schützt nicht gegen Probleme bei der Fernanmeldung.

Beispiele für Elemente zur Aufnahme in die Systemnutzungshinweise sind:

- a) dass die sich anmeldende Person auf ein besonderes Automatisierungssystem zugreift;
- b) dass die Systembenutzung überwacht und aufgezeichnet werden und Gegenstand einer Prüfung sein kann;
- c) dass eine nicht autorisierte Verwendung des Systems verboten ist und strafrechtlich oder zivilrechtlich verfolgt werden kann; und
- d) dass mit der Verwendung des Systems der Überwachung und der Aufzeichnung zugestimmt wird.

5.14.3 Weitergehende Anforderungen

Keine.

5.14.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 1.12 – Nutzungshinweise sind:

- SL-C(IAC, Automatisierungssystem) 1: SR 1.12;
- SL-C(IAC, Automatisierungssystem) 2: SR 1.12;
- SL-C(IAC, Automatisierungssystem) 3: SR 1.12;
- SL-C(IAC, Automatisierungssystem) 4: SR 1.12.

5.15 SR 1.13 – Zugriff über nicht vertrauenswürdige Netze

5.15.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, alle Arten von über nicht vertrauenswürdige Netze geführten Zugriffen auf das Automatisierungssystem zu überwachen und zu kontrollieren.

5.15.2 Begründung und zusätzliche Hinweise

Beispiele für den Zugriff auf das Automatisierungssystem über nicht vertrauenswürdige Netze sind Fernzugriffe (wie Einwählen, Breitband- und Funk) wie auch Verbindungen vom Büronetz des Unternehmens (nicht über das Automatisierungssystem). Das Automatisierungssystem sollte über Wählverbindungen hergestellte Zugriffe beschränken (beispielsweise den Zugriff über Wählverbindungen im Hinblick auf die Quelle der Anfrage beschränken) oder gegen nicht autorisierte Verbindungen oder gegen Unterwanderung autorisierter Verbindungen (beispielsweise durch VPN-Technik) schützen. Zugriff über nicht vertrauenswürdige Netze auf geographisch abgelegene Komponenten des Automatisierungssystems (beispielsweise Schaltwarten und Feldgeräte) sollten nur wenn nötig und authentifiziert erlaubt werden. IT-Sicherheitsleitlinien und -vorgehensweisen dürfen eine Multifaktor-Authentifizierung für einen Fernzugriff auf das Automatisierungssystem fordern.

5.15.3 Weitergehende Anforderungen

5.15.3.1 SR 1.13 RE 1 – Genehmigung ausdrücklicher Anmeldebegehren

Das Automatisierungssystem muss die Fähigkeit bieten, über unzuverlässige Netze übermittelte Zugriffsanforderungen zu verweigern, sofern dies nicht durch eine zugewiesene Rolle zugelassen wird.

5.15.3.2 Leer

5.15.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 1.13 – Zugriff über nicht vertrauenswürdige Netze sind:

- SL-C(IAC, Automatisierungssystem) 1: SR 1.13;
- SL-C(IAC, Automatisierungssystem) 2: SR 1.13 (1);
- SL-C(IAC, Automatisierungssystem) 3: SR 1.13 (1);
- SL-C(IAC, Automatisierungssystem) 4: SR 1.13 (1).

6 Grundlegende Anforderung FR 2 – Nutzungskontrolle

6.1 Zweck und Beschreibungen des SL-C(UC)

Die einem authentifizierten Nutzer (menschlichen Nutzer, Softwareprozess oder Gerät) zugewiesenen Berechtigungen, die es diesem erlauben, die geforderten Aktionen im IACS durchzuführen, durchsetzen sowie die Verwendung dieser Berechtigungen überwachen.

- SL 1 – Beschränke die Nutzung des IACS entsprechend den festgelegten Berechtigungen, um vor gelegentlichem oder zufälligem Missbrauch zu schützen.
- SL 2 – Beschränke die Nutzung des IACS entsprechend den festgelegten Berechtigungen, um vor Überlastung durch Personen oder Stellen, die mit einfachen Mitteln bei geringen Ressourcen, allgemeinen Fertigkeiten und geringer Motivation vorgehen, zu schützen.
- SL 3 – Beschränke die Nutzung des IACS entsprechend den festgelegten Berechtigungen, um vor Überlastung durch Personen oder Stellen, die mit raffinierten Mitteln und mittleren Ressourcen, IACS-spezifischen Fertigkeiten und mittlerer Motivation vorgehen, zu schützen.
- SL 4 – Beschränke die Nutzung des IACS entsprechend den festgelegten Berechtigungen, um vor Überlastung durch Personen oder Stellen, die mit raffinierten Mitteln und erheblichen Ressourcen, IACS-spezifischen Fertigkeiten und hoher Motivation vorgehen, zu schützen.

6.2 Begründung

Nach erfolgter Identifizierung und Authentifizierung eines Nutzers muss das Automatisierungssystem die erlaubten Aktionen auf die autorisierte Nutzung des Automatisierungssystems einschränken. Betreiber und Systemintegratoren müssen jedem Nutzer (menschlichem Nutzer, Softwareprozess oder Gerät), jeder Gruppe, Rolle usw. (siehe 5.6, SR 1.4 – Verwaltung der Bezeichner) die Berechtigungen zuweisen, die die autorisierte Nutzung des IACS definieren. Das Ziel der Nutzungskontrolle ist der Schutz vor nicht autorisierten Handlungen an den Ressourcen des Automatisierungssystems durch Verifikation, dass die erforderlichen Berechtigungen erteilt worden sind, bevor dem Nutzer erlaubt wird, die Aktionen durchzuführen. Beispiele solcher Handlungen sind Daten auslesen oder schreiben, Programme herunterladen und Konfigurationen verändern. Empfehlungen und Leitlinien sollten Verfahren enthalten, die im gemischten Modus arbeiten. Beispielsweise erfordern einige Ressourcen des Automatisierungssystems eine strenge Nutzungskontrolle, wie z. B. restriktive Berechtigungen, andere dagegen nicht. Die Nutzungskontrolle muss auch auf Daten bei der Speicherung ausgedehnt werden. Nutzerberechtigungen können nach Tageszeit/Datum, Ort und Zugangsmedium variieren.

6.3 SR 2.1 – Durchsetzung der Autorisierung

6.3.1 Anforderung

Um die Nutzung des Automatisierungssystems zu kontrollieren, indem Aufgaben getrennt werden und das Prinzip der minimal erforderlichen Rechte beachtet wird, muss das Automatisierungssystem an allen Schnittstellen die Fähigkeit bieten, die allen menschlichen Nutzern zugewiesenen Autorisierungen durchzusetzen.

6.3.2 Erläuterung und zusätzliche Hinweise

Leitlinien zur Nutzungskontrolle (beispielsweise identitätsbasierte, rollenbasierte und sonstige Leitlinien) und damit zusammenhängender Mechanismen zur Durchsetzung von Lese-/Schreibberechtigungen (beispielsweise Zugriffskontrolllisten, Zugriffskontrollmatrizen und Kryptographie) werden zur Nutzungskontrolle zwischen Nutzern (menschlichen Nutzern, Softwareprozessen oder Geräten) und Schutzobjekten (beispielsweise Geräte, Dateien, Aufzeichnungen, Softwareprozesse, Programme und Domänen) verwendet.

Nach erfolgter Verifikation der Identität eines Nutzers (menschlicher Nutzer, Softwareprozess oder Gerät) (siehe 5.3, SR 1.1 – Identifizierung und Authentifizierung von menschlichen Nutzern und 5.4, SR 1.2 – Identifizierung und Authentifizierung von Softwareprozessen und Geräten) durch das Automatisierungssystem muss dieses zusätzlich verifizieren, dass eine angeforderte Handlung auch tatsächlich entsprechend den festgelegten IT-Sicherheitsleitlinien und Vorgehensweisen und Verfahren erlaubt ist. So würde beispielsweise bei einer rollenbasierten Zugriffsregelung das Automatisierungssystem prüfen, welche Rollen einem verifizierten Nutzer oder Betriebsmittel zugewiesen sind und welche Berechtigungen diesen Rollen

zugewiesen sind; falls die angeforderte Handlung durch die Erlaubnis abgedeckt ist, wird sie ausgeführt, andernfalls wird sie verweigert. Dies ermöglicht die Durchsetzung der Trennung der Aufgaben und des Prinzips der minimal erforderlichen Rechte. Die Mechanismen zur Durchsetzung dieser Regeln sollten das Betriebsverhalten des Automatisierungssystems nicht nachteilig beeinflussen.

Geplante oder ungeplante Änderungen an Komponenten des Automatisierungssystems können erhebliche Auswirkungen auf die gesamte IT-Sicherheit des Automatisierungssystems haben. Entsprechend sollte es lediglich qualifizierten und autorisierten Personen gestattet werden, mit Komponenten des Automatisierungssystems umzugehen, um Änderungen einzuleiten, einschließlich Upgrades und Modifikationen.

6.3.3 Weitergehende Anforderungen

6.3.3.1 SR 2.1 RE 1 – Durchsetzung der Autorisierung für alle Nutzer

Um die Nutzung des Automatisierungssystems zu kontrollieren, indem Aufgaben getrennt werden und das Prinzip der minimal erforderlichen Rechte beachtet wird, muss das Automatisierungssystem an allen Schnittstellen die Fähigkeit bieten, die allen Nutzern (menschlichen Nutzern, Softwareprozessen oder Geräten) zugewiesenen Autorisierungen durchzusetzen.

6.3.3.2 SR 2.1 RE 2 – Abbildung der Berechtigung auf Rollen

Das Automatisierungssystem muss einem autorisierten Nutzer oder einer autorisierten Rolle die Möglichkeit einräumen, die Abbildung der Berechtigungen aller menschlichen Nutzer auf Rollen festzulegen und zu modifizieren.

ANMERKUNG 1 Es ist allgemein üblich, Rollen nicht auf fest verschachtelte Hierarchien zu beschränken, in denen eine höherrangige Rolle eine Obermenge einer weniger berechtigten Rolle ist. Beispielsweise verfügt ein Systemadministrator im Allgemeinen nicht zwangsläufig auch über die Berechtigungen eines Anlagenbedieners.

ANMERKUNG 2 Diese weitergehende Anforderung kann sowohl auf Softwareprozesse als auch Geräte angewendet werden.

6.3.3.3 SR 2.1 RE 3 – Eingriff des Aufsichtspersonals

Das Automatisierungssystem muss den manuellen Eingriff des Aufsichtspersonals unterstützen, um aktuelle Autorisierungen menschlicher Nutzer für eine konfigurierbare Zeit oder Ereignisabfolge zu überschreiben.

ANMERKUNG Die Implementierung einer kontrollierten, geprüften Möglichkeit und eines manuellen Eingriffs in automatische Mechanismen im Notfall oder in anderen schwerwiegenden Situationen wird oft benötigt. Dies ermöglicht es dem Aufsichtspersonal, in einem Notfall ggf. schnell einen Bediener in die Lage zu versetzen, auf unübliche Vorkommnisse und Zustände zu reagieren, ohne zunächst die aktuelle Sitzung beenden und daran anschließend zeitaufwändig eine neue Sitzung als ein höher berechtigter menschlicher Nutzer aufzubauen zu müssen.

6.3.3.4 SR 2.1 RE 4 – Doppelte Zustimmung

Das Automatisierungssystem muss eine doppelte Zustimmung unterstützen, falls eine Handlung zu schwerwiegenden Auswirkungen auf den industriellen Prozess führen kann.

ANMERKUNG Es ist allgemein üblich, eine doppelte Zustimmung auf solche Handlungen zu beschränken, bei denen man sehr sicher sein muss, dass diese zuverlässig und korrekt ausgeführt werden. Die Forderung nach einer doppelten Zustimmung betont die Schwere der Folgen einer eventuell nicht korrekt ausgeführten Handlung. Ein Beispiel dafür ist die Änderung eines Sollwertes eines kritischen industriellen Prozesses. Es ist allgemein üblich, keine doppelte Zustimmung anzuwenden, falls eine unmittelbare Reaktion erforderlich ist, um negative Folgen auf Gesundheit, Sicherheit und Umwelt zu vermeiden; dies könnte beispielsweise eine Notabschaltung eines industriellen Prozesses sein.

6.3.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 2.1 – Durchsetzung der Autorisierung sind:

- SL-C(UC, Automatisierungssystem) 1: SR 2.1;
- SL-C(UC, Automatisierungssystem) 2: SR 2.1 (1) (2);

- SL-C(UC, Automatisierungssystem) 3: SR 2.1 (1) (2) (3);
- SL-C(UC, Automatisierungssystem) 4: SR 2.1 (1) (2) (3) (4).

6.4 SR 2.2 – Nutzungskontrolle von Funkverbindungen

6.4.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, bei Funkverbindungen zum Automatisierungssystem in der industriellen Praxis allgemein übliche Nutzungsbeschränkungen zu autorisieren, zu überwachen und durchzusetzen.

6.4.2 Begründung und zusätzliche Hinweise

Alle drahtlosen Technologien können und sollten in den meisten Fällen lediglich als eine weitere Kommunikationsmöglichkeit angesehen werden und daher denselben IT-Sicherheitsanforderungen unterliegen wie jedes andere von einem IACS benutzte Kommunikationsmedium auch. Jedoch könnte eine Risikoanalyse zu einer Anforderung an drahtlose IACS-Komponenten führen, die eine Unterstützung höherer Fähigkeiten zur Nutzungskontrolle fordern, als dies typischerweise bei drahtgebundener Kommunikation bei sonst gleichem Anwendungsfall und SL-T der Fall wäre. Regulatorische Unterschiede können ebenfalls zu unterschiedlichen Anforderungen zwischen drahtloser und drahtgebundener Kommunikation führen.

Wie in 5.8, SR 1.6 – Management drahtloser Zugriffsverfahren vermerkt, umfassen drahtlose Technologien unter anderem: Mikrowellen, Satelliten, Pakettfunk, IEEE 802.11x, IEEE 802.15.4 (ZigBee, IEC 62591 – *WirelessHART*®, ISA-100.11a), IEEE 802.15.1 (Bluetooth), drahtlose, mobile LAN-Router, schnurlose Telefone und verschiedene Infrarot-Technologien.

6.4.3 Weitergehende Anforderungen

6.4.3.1 SR 2.2 RE 1 – Nicht genehmigte drahtlose Geräte erkennen und anzeigen

Das Automatisierungssystem muss die Fähigkeit bieten, in der Umgebung des Automatisierungssystems sendende, nicht genehmigte drahtlose Geräte zu erkennen und diese anzuzeigen.

6.4.3.2 Leer

6.4.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 2.2 – Nutzungskontrolle von Funkverbindungen sind:

- SL-C(UC, Automatisierungssystem) 1: SR 2.2;
- SL-C(UC, Automatisierungssystem) 2: SR 2.2;
- SL-C(UC, Automatisierungssystem) 3: SR 2.2 (1);
- SL-C(UC, Automatisierungssystem) 4: SR 2.2 (1).

6.5 SR 2.3 – Nutzungskontrolle von tragbaren und mobilen Geräten

6.5.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, konfigurierbare Nutzungsbeschränkungen, die Folgendes umfassen, automatisch durchzusetzen:

- a) die Nutzung tragbarer und mobiler Geräten verhindern;
- b) eine kontextspezifische Autorisierung einfordern; und
- c) die Übertragung von Daten und Code von und zu tragbaren und mobilen Geräten einschränken.

6.5.2 Begründung und zusätzliche Hinweise

Tragbare und mobile Geräte können unerwünschten Netzverkehr erzeugen, Schadprogramme einschleusen und Informationen offenlegen, daher sollten für deren Einsatz in der typischen Umgebung eines Automatisierungssystems besondere Maßnahmen getroffen werden. IT-Sicherheitsleitlinien und Vorgehensweisen dürfen

DIN EN IEC 62443-3-3 (VDE 0802-3-3):2020-01 EN IEC 62443-3-3:2019 + AC:2019

bestimmte, durch tragbare und mobile Geräte ausführbaren Funktionen oder Tätigkeiten nicht zulassen. Anleitungen bezüglich der Erlaubnis zum Einsatz von tragbaren und mobilen Geräten sind in IEC 62443-2-1 zu finden.

Der Schutz von in tragbaren und mobilen Geräten befindlichen Informationen (beispielsweise der Einsatz kryptographischer Verfahren zur Aufrechterhaltung von deren Vertraulichkeit und Integrität während der Speicherung oder der Übertragung außerhalb geschützter Bereiche) wird an anderer Stelle behandelt (siehe [Abschnitt 8](#), FR 4 – Vertraulichkeit der Daten).

6.5.3 Weitergehende Anforderungen

6.5.3.1 SR 2.3 RE 1 – IT-Sicherheitsstatus tragbarer und mobiler Geräte durchsetzen

Das Automatisierungssystem muss die Fähigkeit bieten, zu verifizieren, dass tragbare und mobile Geräte, die versuchen, sich mit einer Zone zu verbinden, deren IT-Sicherheitsanforderungen einhalten.

6.5.3.2 Leer

6.5.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 2.3 – Nutzungskontrolle von tragbaren und mobilen Geräten sind:

- SL-C(UC, Automatisierungssystem) 1: SR 2.3;
- SL-C(UC, Automatisierungssystem) 2: SR 2.3;
- SL-C(UC, Automatisierungssystem) 3: SR 2.3 (1);
- SL-C(UC, Automatisierungssystem) 4: SR 2.3 (1).

6.6 SR 2.4 – Plattformübergreifender Code

6.6.1 Anforderung

Das Automatisierungssystem muss, ausgehend von der Möglichkeit, dass dem Automatisierungssystem Schaden zugefügt wird, die Fähigkeit bieten, Einschränkungen der Nutzung von Techniken mit plattformübergreifendem Code einschließlich der folgenden durchzusetzen:

- a) die Ausführung plattformübergreifenden Codes verhindern;
- b) eine geeignete Authentifizierung und Autorisierung des Codeursprungs einfordern;
- c) die Übertragung plattformübergreifenden Codes zu und vom Automatisierungssystem einschränken; und
- d) den Einsatz plattformübergreifenden Codes überwachen.

6.6.2 Begründung und zusätzliche Hinweise

Technologien mit mobilem Code umfassen unter anderem Java, JavaScript, ActiveX, Portable Document Format (PDF), Postscript, Shockwave-Filme, Flashanimationen und VBScript. Nutzungsbeschränkungen gelten sowohl für die Auswahl und Verwendung von auf Servern installierten Codes als auch für auf einzelne Arbeitsplatzrechner heruntergeladene und dort ausgeführte plattformübergreifenden Codes. Die Entwicklung, der Erwerb und die Einführung unzulässigen plattformübergreifende Codes sollte durch geeignete Vorgehensweisen unterbunden werden. So könnte beispielsweise der direkte Austausch plattformübergreifender Codes mit dem Automatisierungssystem verboten sein, aber in einer überwachten, angrenzenden Umgebung, die vom Personal des IACS betrieben wird, erlaubt sein.

6.6.3 Weitergehende Anforderungen

6.6.3.1 SR 2.4 RE 1 – Prüfung der Integrität plattformübergreifenden Codes

Das Automatisierungssystem muss die Fähigkeit bieten, die Integrität plattformübergreifende Codes zu verifizieren, ehe es deren Ausführung erlaubt.

6.6.3.2 Leer

6.6.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 2.4 – Plattformübergreifender Code sind:

- SL-C(UC, Automatisierungssystem) 1: SR 2.4;
- SL-C(UC, Automatisierungssystem) 2: SR 2.4;
- SL-C(UC, Automatisierungssystem) 3: SR 2.4 (1);
- SL-C(UC, Automatisierungssystem) 4: SR 2.4 (1).

6.7 SR 2.5 – Sitzungssperrung

6.7.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, nach einer einstellbaren Zeit der Inaktivität oder durch manuellen Eingriff einen weiteren Zugriff durch Herbeiführen einer Sitzungssperrung zu verhindern. Diese muss wirksam bleiben, bis ein menschlicher Nutzer, dem entweder die Sitzung gehört oder der sonst dazu autorisiert ist, unter Verwendung angemessener Vorgehensweisen zur Identifizierung und Authentifizierung den Zugriff wieder herstellt.

6.7.2 Begründung und zusätzliche Hinweise

Die für ein Automatisierungssystem verantwortliche Person oder Stelle sollte Sitzungssperrungen einsetzen, um den Zugriff auf bestimmte Arbeitsplatzrechner oder Knoten zu verhindern. Das Automatisierungssystem sollte Mechanismen zur Sitzungssperrung automatisch nach einer einstellbaren Zeit für bestimmte Arbeitsplatzrechner oder Knoten aktivieren. In manchen Fällen ist eine Sperrung der Sitzung von Arbeitsplatzrechnern oder Knoten im Automatisierungssystem nicht angeraten (beispielsweise Sitzungen, die der unmittelbaren Reaktion des Bedieners in Notfällen dienen). Sitzungssperrungen sind kein Ersatz für das Abmelden vom Automatisierungssystem. In Situationen, in denen das Automatisierungssystem keine Sitzungssperrung unterstützen kann, sollte die verantwortliche Person oder Stelle geeignete Ausgleichsmaßnahmen ergreifen (beispielsweise erweiterte physikalische Sicherheit, Maßnahmen im Hinblick auf das Personal und Prüfungen).

6.7.3 Weitergehende Anforderungen

Keine.

6.7.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 2.5 – Sitzungssperrung sind:

- SL-C(UC, Automatisierungssystem) 1: SR 2.5;
- SL-C(UC, Automatisierungssystem) 2: SR 2.5;
- SL-C(UC, Automatisierungssystem) 3: SR 2.5;
- SL-C(UC, Automatisierungssystem) 4: SR 2.5.

6.8 SR 2.6 – Beendigung einer Fernzugriffssitzung

6.8.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, eine Fernzugriffssitzung entweder automatisch nach einer einstellbaren Zeit der Inaktivität oder von Hand durch den Nutzer, der sie initiiert hat, zu beenden.

6.8.2 Begründung und zusätzliche Hinweise

Eine Fernzugriffssitzung wird eingeleitet, wenn auf ein Automatisierungssystem über die Grenze einer Zone, die vom Betreiber aufgrund einer Risikobeurteilung festgelegt wurde, hinweg zugegriffen wird. Diese Forderung darf auf Sitzungen beschränkt werden, die entsprechend der Risikobeurteilung des Automatisierungssystems und der IT-Sicherheitsleitlinien und Vorgehensweisen der Überwachung und der

Instandhaltung dienen (keine kritischen Handlungen). Einige Automatisierungssysteme oder Komponenten erlauben das Beenden von Sitzungen möglicherweise nicht.

6.8.3 Weitergehende Anforderungen

Keine.

6.8.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 2.6 – Beendigung einer Fernzugriffssitzung sind:

- SL-C(UC, Automatisierungssystem) 1: keine;
- SL-C(UC, Automatisierungssystem) 2: SR 2.6;
- SL-C(UC, Automatisierungssystem) 3: SR 2.6;
- SL-C(UC, Automatisierungssystem) 4: SR 2.6.

6.9 SR 2.7 – Begrenzung der Anzahl gleichzeitiger Sitzungen

6.9.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, die Anzahl der gleichzeitigen Sitzungen je Schnittstelle für jeden gegebenen Nutzer (menschlichen Nutzer, Softwareprozess oder Gerät) auf eine einstellbare Anzahl von Sitzungen zu begrenzen.

6.9.2 Begründung und zusätzliche Hinweise

Sollte kein Grenzwert festgelegt sein, könnte eine DoS-Situation infolge eines Ressourcenengpasses eintreten. Es muss daher abgewogen werden zwischen der möglichen Aussperrung eines bestimmten Nutzers und der Aussperrung aller Nutzer aufgrund nicht ausreichender Ressourcen im Automatisierungssystem. Es bedarf wahrscheinlich der Anleitung durch die Produktlieferanten und den Systemintegrator, um angemessene Informationen zur Verfügung zu stellen, wie die Anzahl möglicher Sitzungen festgelegt werden sollte.

6.9.3 Weitergehende Anforderungen

Keine.

6.9.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 2.7 – Begrenzung der Anzahl gleichzeitiger Sitzungen sind:

- SL-C(UC, Automatisierungssystem) 1: keine;
- SL-C(UC, Automatisierungssystem) 2: keine;
- SL-C(UC, Automatisierungssystem) 3: SR 2.7;
- SL-C(UC, Automatisierungssystem) 4: SR 2.7.

6.10 SR 2.8 – Prüfbare Ereignisse und deren Aufzeichnung

6.10.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, Ereignisdatensätze zur IT-Sicherheit in den folgenden Kategorien zu erzeugen: Zugangskontrolle, fehlerhafte Anfragen, Vorfälle mit dem Betriebssystem, Vorfälle im Automatisierungssystem, Vorfälle bei der Sicherung und Wiederherstellung von Daten, Konfigurationsänderungen, mögliche Auskundschaftungen und Vorfälle, die aus dem Ereignisprotokoll hervorgehen. Die einzelnen Ereignisdatensätze müssen folgende Angaben enthalten: Zeitstempel, Quelle (Gerät, Softwareprozess oder Konto des menschlichen Nutzers, von dem das Ereignis herrührt), Kategorie, Art, Bezeichner und Ergebnis des Ereignisses.

6.10.2 Begründung und zusätzliche Hinweise

Diese Anforderung dient der Aufzeichnung des Auftretens wichtiger Ereignisse, die als bedeutend und wichtig für die IT-Sicherheit des Automatisierungssystems geprüft werden müssen. Die hierzu erforderlichen Tätigkeiten können sich auf die Leistung des Automatisierungssystems auswirken. Diese Aufzeichnungsfunktion wird üblicherweise mit der Funktion zur Anzeige von Auslastung und Zustand des Netzwerks, die sich in einer anderen Zone befinden kann, abgestimmt. Bei der Zusammenstellung von Listen prüfbarer Ereignisse sollten allgemein anerkannte Prüflisten herangezogen werden. In den IT-Sicherheitsleitlinien und -vorgehensweisen sollten nachprüfbar Ereignisse vorgegeben sein, die dazu geeignet sind, IT-Sicherheitsvorfälle im Nachhinein untersuchen zu können. Zusätzlich sollten die Aufzeichnungen für die Überwachung, die Wirksamkeit und die korrekte Ausführung von IT-Sicherheitsverfahren ausreichen, um die in dieser Norm geforderten Eigenschaften zu erfüllen.

Es sollte beachtet werden, dass die Forderung nach einer Ereignisaufzeichnung innerhalb einer bestimmten Systemfunktionalität gilt, insbesondere innerhalb der dort aufgestellten Anforderungen an die IT-Sicherheit auf einer bestimmten Stufe (Level). Beispielsweise ist die Forderung nach einer Aufzeichnung der Ereignisse im Rahmen der Authentifizierung (in der Kategorie Zugriffskontrolle) in einem SL 1-System nur anwendbar auf die für SL 1 geforderte Stufe der Authentifizierungsfunktionalität entsprechend der Anforderung in [Abschnitt 5](#). Vorfälle können in jeder Komponente des Automatisierungssystems auftreten (beispielsweise Anmeldeversuche) oder von speziellen Überwachungseinrichtungen erkannt werden. Beispielsweise könnte Port-Scanning durch ein Intrusion-Detection-System (IDS) oder ein Intrusion-Prevention-System (IPS) erkannt werden.

6.10.3 Weitergehende Anforderungen

6.10.3.1 SR 2.8 RE 1 – Zentral verwaltete systemweite Ereignisaufzeichnung

Das Automatisierungssystem muss die Fähigkeit bieten, prüfbare Ereignisse zentral zu verwalten und die Ereignisaufzeichnungen unterschiedlicher Komponenten aus dem gesamten Automatisierungssystem zu einer systemweiten (logischen oder physischen), zeitlich korrelierten Aufzeichnung zusammenzuführen. Das Automatisierungssystem muss die Fähigkeit bieten, diese Aufzeichnungen in standardisierten Industrieformaten zu exportieren, damit standardisierte kommerzielle Analysewerkzeuge, beispielsweise Sicherheitsinformations- und Ereignismanagement Lösungen (SIEM), diese analysieren können.

6.10.3.2 Leer

6.10.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 2.8 – Prüfbar Ereignisse und deren Aufzeichnung sind:

- SL-C(UC, Automatisierungssystem) 1: SR 2.8;
- SL-C(UC, Automatisierungssystem) 2: SR 2.8;
- SL-C(UC, Automatisierungssystem) 3: SR 2.8 (1);
- SL-C(UC, Automatisierungssystem) 4: SR 2.8 (1).

6.11 SR 2.9 – Speicherkapazität für Aufzeichnungen

6.11.1 Anforderung

Das Automatisierungssystem muss zur Aufzeichnung der Prüfungen ausreichend Speicherkapazität entsprechend allgemein anerkannten Empfehlungen zu Ereignisprotokollen und Systemkonfiguration bereitstellen. Das Automatisierungssystem muss Prüfmechanismen bereithalten, um die Wahrscheinlichkeit der Überschreitung dieser Speicherkapazität zu verringern.

6.11.2 Begründung und zusätzliche Hinweise

Das Automatisierungssystem sollte unter Berücksichtigung der Aufbewahrungsregeln, der durchzuführenden Prüfungen und der Forderung nach On-line-Prüfung ausreichend Speicherkapazität bereitstellen. Hierzu kann unter anderen der Leitfaden NIST Special Publication (SP) 800-92 [\[27\]](#) herangezogen werden. Die Speicher-

kapazität sollte ausreichen, um Ereignisprotokolle entsprechend geltender Leitlinien, Regelungen oder geschäftlicher Anforderungen genügend lang aufbewahren zu können.

6.11.3 Weitergehende Anforderungen

6.11.3.1 SR 2.9 RE 1 – Warnung, wenn die Kapazitätsgrenze zur Speicherung von Ereignisdatensätzen erreicht ist

Falls die zugeteilte Speicherkapazität für Ereignisdatensätze einen einstellbaren Anteil an der maximalen Speicherkapazität für Ereignisdatensätze erreicht hat, muss das Automatisierungssystem in der Lage sein, eine entsprechende Warnung herauszugeben.

6.11.3.2 Leer

6.11.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 2.9 – Speicherkapazität für Ereignisdatensätze sind:

- SL-C(UC, Automatisierungssystem) 1: SR 2.9;
- SL-C(UC, Automatisierungssystem) 2: SR 2.9;
- SL-C(UC, Automatisierungssystem) 3: SR 2.9 (1);
- SL-C(UC, Automatisierungssystem) 4: SR 2.9 (1).

6.12 SR 2.10 – Reaktion auf ausgefallene Verarbeitung von Ereignisdaten

6.12.1 Anforderung

Im Falle des Ausfalls der Verarbeitung der Ereignisdaten muss das Automatisierungssystem die Fähigkeit bieten, das Bedienpersonal hierüber zu benachrichtigen und den Verlust wesentlicher Dienste und Funktionen zu verhindern. Das Automatisierungssystem muss als Reaktion auf eine ausgefallene Verarbeitung von Ereignisdaten die Fähigkeit bieten, entsprechend allgemein anerkannter industrieller Gepflogenheiten geeignete Maßnahmen zu unterstützen.

6.12.2 Begründung und zusätzliche Hinweise

Ereignisdaten werden üblicherweise an der Quelle der Ereignisse erzeugt. Die Ereignisdatenverarbeitung umfasst die Übertragung, eine mögliche Ergänzung (wie etwa das Hinzufügen eines Zeitstempels) und eine dauerhafte Speicherung der Ereignisdatensätze. Ausfälle der Ereignisdatenverarbeitung umfassen beispielsweise Software- oder Hardwarefehler, Ausfälle im Erfassungsmechanismus und das Erreichen oder Überschreiten der Speicherkapazität für Ereignisdatensätze. Bei der Entwicklung geeigneter Gegenmaßnahmen kann man sich beispielsweise am Leitfaden NIST SP800-92 orientieren. Hierbei gilt es zu beachten, dass sowohl ein Überschreiben der ältesten Prüfaufzeichnungen als auch ein Unterbrechen der Erzeugung neuer Aufzeichnungen mögliche Reaktionen auf ein Überschreiten der Speicherkapazität sein können, die jedoch den Verlust möglicherweise wichtiger forensischer Informationen bewirken.

6.12.3 Weitergehende Anforderungen

Keine.

6.12.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 2.10 – Reaktion auf ausgefallene Ereignisdatenverarbeitung sind:

- SL-C(UC, Automatisierungssystem) 1: SR 2.10;
- SL-C(UC, Automatisierungssystem) 2: SR 2.10;
- SL-C(UC, Automatisierungssystem) 3: SR 2.10;
- SL-C(UC, Automatisierungssystem) 4: SR 2.10.

6.13 SR 2.11 – Zeitstempel

6.13.1 Anforderung

Das Automatisierungssystem muss für die Erzeugung von Ereignisdatensätzen Zeitstempel liefern.

6.13.2 Begründung und zusätzliche Hinweise

Bei der Erzeugung der Zeitstempel (mit Uhrzeit und Datum) von Ereignisdatensätzen sollten systeminterne Uhren verwendet werden. Sollte eine systemweite Zeitsynchronisation nicht vorhanden sein (was in vielen Installationen der Fall ist), werden für eine Analyse von Ereignisabläufen Angaben über die Zeitabweichungen benötigt. Außerdem könnte eine Synchronisation der intern erzeugten Ereignisdatensätze mit externen Ereignissen eine Synchronisierung mit allgemein anerkannten externen Zeitquellen erfordern (wie z. B. dem Global Positioning System (GPS), Global Navigation Satellite System (GLONASS) und Galileo). Die Zeitquelle sollte vor nicht autorisierter Änderung geschützt sein.

6.13.3 Weitergehende Anforderungen

6.13.3.1 SR 2.11 RE 1 – Interne Systemtakte

Das Automatisierungssystem muss die Fähigkeit bieten, systeminterne Uhren in einstellbaren Zeitabschnitten zu synchronisieren.

6.13.3.2 SR 2.11 RE 2 – Schutz und Integrität der Zeitquelle

Die Zeitquelle (Taktgenerator) muss vor nicht autorisierter Änderung geschützt werden, eine Änderung muss ein prüfbares Ereignis hervorrufen.

6.13.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 2.11 – Zeitstempel sind:

- SL-C(UC, Automatisierungssystem) 1: keine;
- SL-C(UC, Automatisierungssystem) 2: SR 2.11;
- SL-C(UC, Automatisierungssystem) 3: SR 2.11 (1);
- SL-C(UC, Automatisierungssystem) 4: SR 2.11 (1) (2).

6.14 SR 2.12 – Nichtabstreitbarkeit

6.14.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, festzustellen, ob ein bestimmter menschlicher Nutzer eine bestimmte Handlung vorgenommen hat.

6.14.2 Begründung und zusätzliche Hinweise

Beispiele solcher von einem Nutzer vorgenommenen Handlungen sind: Bedienhandlungen ausführen, Konfigurationen im Automatisierungssystem ändern, Informationen erzeugen, eine Nachricht senden, eine Information bestätigen (beispielsweise Zustimmung signalisieren) und eine Nachricht empfangen. Die Nichtabstreitbarkeit schützt gegen spätere falsche Behauptungen eines Nutzers, eine bestimmte Handlung nicht vorgenommen zu haben, eines Autors, ein bestimmtes Dokument nicht geschrieben zu haben, eines Senders, eine Nachricht nicht übermittelt zu haben, eines Empfängers, eine Nachricht nicht erhalten zu haben oder eines Signierers, ein Dokument nicht signiert zu haben. Nichtabstreitbarkeits-Dienste können verwendet werden, um festzustellen, ob eine Information von einem bestimmten Nutzer stammt, ob ein Nutzer bestimmte Handlungen vorgenommen hat (beispielsweise eine E-Mail gesendet und einen Arbeitsauftrag bestätigt) oder bestimmte Informationen erhalten hat. Nichtabstreitbarkeits-Dienste werden durch verschiedene Techniken erreicht (beispielsweise durch digitale Signaturen, digitale Empfangsquittung einer Nachricht und durch Zeitstempel).

6.14.3 Weitergehende Anforderungen

6.14.3.1 SR 2.12 RE 1 – Nichtabstreitbarkeit für alle Nutzer

Das Automatisierungssystem muss die Fähigkeit bieten, festzustellen, ob ein bestimmter Nutzer (menschlicher Nutzer, Softwareprozess oder Gerät) eine bestimmte Handlung vorgenommen hat.

6.14.3.2 Leer

6.14.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 2.12 – Nichtabstreitbarkeit sind:

- SL-C(UC, Automatisierungssystem) 1: keine;
- SL-C(UC, Automatisierungssystem) 2: keine;
- SL-C(UC, Automatisierungssystem) 3: SR 2.12;
- SL-C(UC, Automatisierungssystem) 4: SR 2.12 (1).

7 Grundlegende Anforderung FR 3 – Systemintegrität

7.1 Zweck und Beschreibungen des SL-C(SI)

Die Integrität des IACS sicherstellen und nicht autorisierte Manipulation verhindern.

- SL 1 – Schütze die Integrität des IACS gegen gelegentliche oder zufällige Manipulation.
- SL 2 – Schütze die Integrität des IACS gegen Manipulation durch Personen oder Stellen, die mit einfachen Mitteln, geringen Ressourcen, allgemeinen Fertigkeiten und geringer Motivation vorgehen.
- SL 3 – Schütze die Integrität des IACS gegen Manipulation durch Personen oder Stellen, die mit raffinierten Mitteln, mittleren Ressourcen, IACS-spezifische Fertigkeiten und mittlerer Motivation vorgehen.
- SL 4 – Schütze die Integrität des IACS gegen Manipulation durch Personen oder Stellen, die mit raffinierten Mitteln, erheblichen Ressourcen, IACS-spezifische Fertigkeiten und hoher Motivation vorgehen.

7.2 Begründung

IACS werden meist mehreren Prüfphasen unterzogen (Stückprüfung, Werksabnahme, Abnahme der installierten Anlage, Zertifizierung, Inbetriebnahme usw.), um noch vor Produktionsaufnahme festzustellen, dass sich die Systeme bestimmungsgemäß verhalten. Nach Betriebsbeginn sind die Betreiber für die Aufrechterhaltung der Integrität des IACS verantwortlich. Mittels ihrer Risikobewertung können sie unterschiedlichen Systemen, Kommunikationskanälen und Informationen in ihrem IACS unterschiedliche Stufen des Integritätsschutzes zuweisen. Die Integrität der Schutzobjekte sollte sowohl im Betriebszustand als auch in Nicht-Betriebszuständen aufrechterhalten werden, beispielsweise während der Produktion, im Lager oder wenn die Anlage zum Zwecke der Instandhaltung heruntergefahren wurde. Die Integrität der logischen Vermögenswerte sollte bei deren Übertragung und Speicherung aufrechterhalten werden, beispielsweise bei der Übertragung über ein Kommunikationsnetz oder bei der Ablage in einem Datenbestand.

7.3 SR 3.1 – Kommunikationsintegrität

7.3.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, die Integrität der übertragenen Information zu schützen.

7.3.2 Begründung und zusätzliche Hinweise

Bei vielen gängigen Angriffen auf Kommunikationsnetze werden übertragene Daten manipuliert, z. B. Manipulation von Datenpaketen. Netzwerke mit Switches oder Routern bieten Angreifern Gelegenheit, Pakete zu manipulieren, da der unerkannte Zugriff auf solche Netze im Allgemeinen leicht ist, auch kann das

Routing selbst manipuliert werden, um so noch mehr Zugriffsmöglichkeiten auf die übertragenen Information zu erhalten. Eine Manipulation in einem Automatisierungssystem könnte eine Änderung von Messwerten sein, die von einem Messwertaufnehmer zu einem Empfänger übertragen werden, oder die Veränderung von Stellgrößenwerten, die von einer Regelung an ein Stellglied gesendet werden.

Je nach Gegebenheit (beispielsweise Übertragung über einen lokalen Netzabschnitt gegenüber einer Übertragung über ein nicht vertrauenswürdiges Netz) und der für die Übertragung verwendeten Netzwerktechnik (beispielsweise TCP/IP gegenüber einer lokalen seriellen Verbindung) werden unterschiedlich machbare und geeignete Techniken verwendet werden. In einem kleinen Netz mit direkten Punkt-zu-Punkt-Verbindungen kann ein physikalischer Zugangsschutz an allen Knoten für einen niedrigen Security-Level (SL) ausreichend sein, falls die Integrität der Endpunkte ebenfalls geschützt wird (siehe 7.6, SR 3.4 – Software- und Informationsintegrität). Dagegen kann in Netzen, die in Bereichen aufgebaut sind, in denen regelmäßig Personal anwesend ist, oder in einem WAN ein physikalischer Zugangsschutz kaum durchgesetzt werden. Falls für die Erbringung eines Kommunikationsdienstes anstelle eines dafür vollständig ausgerichteten Dienstes ein kommerzieller Dienstleister in Anspruch genommen wird, der seine Dienste wie ein Massenprodukt anbietet (beispielsweise eine Mietleitung gegenüber einer T1-Verbindung), kann es noch schwieriger werden, die erforderlichen Zusicherungen hinsichtlich der Umsetzung der benötigten Maßnahmen zur Kommunikationsintegrität zu erlangen (beispielsweise wegen rechtlicher Beschränkungen). Sollte es nicht machbar oder unmöglich sein, die bestehenden IT-Sicherheitsanforderungen einzuhalten, dann könnte es angebracht sein, geeignete Ausgleichsmaßnahmen zu ergreifen oder das zusätzliche Risiko ausdrücklich zu akzeptieren.

Industrieeinrichtungen sind häufig Umweltbedingungen ausgesetzt, die eine Beeinträchtigung der Integrität oder Fehlalarme bewirken können. Häufig befinden sich in der Umwelt Partikel, Flüssigkeiten, Gase, Strahlung und Funkstörungen), die die Integrität der Kommunikationskabel und -signale stören können. Die Netzinfrastruktur sollte so ausgelegt werden, dass diese Umwelteinflüsse einen möglichst geringen Einfluss auf die Kommunikationsintegrität haben. Falls beispielsweise die Anwesenheit von Partikeln, Flüssigkeiten oder Gasen anzunehmen ist, könnte es erforderlich sein, abgedichtete RJ-45-Buchsen oder M12-Stecker anstelle handelsüblicher RJ-45 Buchsen zu verwenden sowie Kabel mit besonderem Mantel. Im Falle von Schwingungsbeanspruchungen könnten M12-Stecker nötig sein, damit die Federlasche eines RJ-45 Steckers nicht während des Betriebs ausrastet. Sofern Funkstörungen oder elektromagnetische Verträglichkeit besonders zu beachten sind, könnte es erforderlich sein, geschirmte Kabel mit verdrehten Aderpaaren oder Glasfaserkabel einzusetzen, um Auswirkungen auf die Kommunikationssignale zu verhindern. Falls der Aufbau eines Funknetzes geplant wird, könnte es notwendig werden, das Funkspektrum in der betreffenden Gegend zu analysieren, um zu bestätigen, dass dies eine machbare Lösung ist.

7.3.3 Weitergehende Anforderungen

7.3.3.1 SR 3.1 RE 1 – Kryptographische Schutzmaßnahmen zur Bewahrung der Integrität

Das Automatisierungssystem muss die Fähigkeit bieten, kryptographische Verfahren einzusetzen, um Veränderungen der Informationen während der Kommunikation zu erkennen.

ANMERKUNG Es ist gute allgemeine Praxis, kryptographische Verfahren zur Authentifizierung und Sicherstellung der Integrität von Nachrichten erst dann festzulegen, nachdem die IT-Sicherheitsbedürfnisse und die möglichen Nebenwirkungen auf das Systemverhalten und die Fähigkeit, nach einem Systemausfall wieder hergestellt werden zu können, sorgfältig bedacht wurden.

7.3.3.2 Leer

7.3.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 3.1 – Kommunikationsintegrität sind:

- SL-C(SI, Automatisierungssystem) 1: SR 3.1;
- SL-C(SI, Automatisierungssystem) 2: SR 3.1;
- SL-C(SI, Automatisierungssystem) 3: SR 3.1 (1);
- SL-C(SI, Automatisierungssystem) 4: SR 3.1 (1).

7.4 SR 3.2 – Schutz vor Schadcode

7.4.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, Schutzmechanismen zu verwenden, die die Wirkung von Schadcode oder nicht autorisierter Software verhindern, erkennen, melden und Abhilfe hiergegen schaffen. Das Automatisierungssystem muss die Fähigkeit bieten, diese Schutzvorkehrungen zu aktualisieren.

7.4.2 Begründung und zusätzliche Hinweise

Das Automatisierungssystem sollte Schutzvorkehrungen einsetzen, um Fälle von Schadcode (beispielsweise Viren, Würmer, Trojaner und Spyware), die durch E-Mails, Anhänge von E-Mails, über den Internetzugang, durch mobile Datenträger (beispielsweise durch über USB angeschlossene Geräte, Disketten oder Compact Disks (CD)), PDF-Dokumente, Web-Dienste, Netzverbindungen und infizierte Laptops oder andere gemeinsame Mittel übertragen wurden, zu verhindern, zu erkennen, zu melden und Abhilfe hiergegen zu schaffen.

Erkennungsverfahren sollten Integritätsverletzungen von Programm- und Datendateien erkennen können. Hierfür verwendete Techniken können unter anderem die Überwachung der binären Integrität und von Attributen, Hashfunktionen sowie Signaturtechniken umfassen. Abhilfetechniken können unter anderem Dateisäuberung, in Quarantäne stellen, Dateilöschung, eingeschränkte Kommunikation mit dem Host und Intrusion-Protection-Systeme umfassen.

Techniken zur Verhinderung können unter anderem Blacklisting und Whitelisting, Kontrolle mobiler Datenträger, Sandbox-Techniken sowie Verfahren spezieller Systemplattformen wie eingeschränkte Updates von Firmware, No Execute (NX)-Bit, Datenausführungsverhinderung (DEP, en: data execution prevention), Adressverwürfelung (ASLR, en: address space layout randomization,), Erkennung korumpierter Stacks und Mandatory Access Control umfassen. Siehe [10.4](#), SR 6.2 – Kontinuierliche Überwachung für eine zugehörige Anforderung unter Einbeziehung von Überwachungswerkzeugen im Automatisierungssystem.

Zu den Verfahren zur Verhinderung und Abhilfe gehören solche, die für Hosts (PCs und Server) und netzba-sierte Verfahren wie IDS und IPS entwickelt wurden, sowie solche zum Schutz der Komponenten eines Au-tomatisierungssystems (wie z. B. SPS und Mensch-Maschine-Schnittstelle).

7.4.3 Weitergehende Anforderungen

7.4.3.1 SR 3.2 RE 1 – Schutz vor Schadcode an Eingangs- und Ausgangspunkten

Das Automatisierungssystem muss die Fähigkeit bieten, Verfahren zum Schutz vor Schadcode an allen Ein-gangs- und Ausgangspunkten einzusetzen.

ANMERKUNG Solche Verfahren werden üblicherweise auf mobilen Datenträgern, über Firewalls, unidirektionale Gate-ways, auf Webservern, Proxyservern oder Fernzugriff-Servern bereitgestellt.

7.4.3.2 SR 3.2 RE 2 – Zentrale Verwaltung und zentrales Meldewesen zum Schutz vor Schadcode

Das Automatisierungssystem muss die Fähigkeit bieten, die Verfahren zum Schutz vor Schadcode zu ver-walten.

ANMERKUNG Solche Verfahren werden üblicherweise an zentralen Punkten der Infrastruktur verwaltet oder mit Hilfe von SIEM-Lösungen bereitgestellt.

7.4.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 3.2 – Schutz vor Schadcode sind:

- SL-C(SI, Automatisierungssystem) 1: SR 3.2;
- SL-C(SI, Automatisierungssystem) 2: SR 3.2 (1);
- SL-C(SI, Automatisierungssystem) 3: SR 3.2 (1) (2);
- SL-C(SI, Automatisierungssystem) 4: SR 3.2 (1) (2).

7.5 SR 3.3 – Verifikation der IT-Sicherheitsfunktionalität

7.5.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, die Verifikation des vorgesehenen Betriebes der IT-Sicherheitsfunktionen zu unterstützen und zu melden, falls Anomalien bei der Werksabnahme (FAT), bei Abnahme der installierten Anlage (SAT) und während einer geplanten Instandhaltung erkannt werden. Dies muss für alle IT-Sicherheitsfunktionen gelten, die für die Unterstützung der in dieser Norm festgelegten IT-Sicherheitsanforderungen benötigt werden.

7.5.2 Begründung und zusätzliche Hinweise

Der Produktlieferant oder der Systemintegrator sollte Anleitungen zur Prüfung der vorgesehenen IT-Sicherheitsmaßnahmen liefern. Betreiber müssen sich der möglichen Auswirkungen bewusst sein, die diese Prüfungen während des normalen Betriebs haben können. Details zur Durchführung dieser Prüfungen müssen unter sorgfältiger Berücksichtigung der geforderten Aufrechterhaltung des laufenden Betriebs festgelegt werden (beispielsweise Ablaufplanung, vorherige Ankündigung der Tests).

Beispiele zur Verifikation der IT-Sicherheitsfunktionen sind:

- Überprüfung der Antivirus-Maßnahmen durch Prüfungen des Dateisystems des Automatisierungssystems anhand der vom European Institute for Computer Antivirus Research e.V. (EICAR) bereitgestellten Testdateien. Die Antivirussoftware sollte diese entdecken, und es sollte ein geeignetes Vorgehen zur Behandlung dieses Vorfalls veranlasst werden.
- Überprüfung der Maßnahmen zur Identifizierung, Authentifizierung und Nutzungskontrolle durch Zugriffsversuche von einem nicht autorisierten Nutzerkonto (für gewisse Funktionalitäten könnte dies automatisiert durchgeführt werden).
- Überprüfung des IDS als eine IT-Sicherheitsmaßnahme, hierfür wird in dem IDS eine Regel vorgesehen, die bei einem irregulären, aber bekannt nicht bösartigen Verkehr Alarm auslöst. Die Prüfung kann nun ausgeführt werden, indem Verkehr herbeigeführt wird, der diese Regel auslöst und damit eine angemessene Anzeige durch das IDS und das Vorgehen zur Behandlung dieses Vorfalls herbeiführt.
- Bestätigung, dass die Ereignisprotokolle wie von den IT-Sicherheitsleitlinien und -vorgehensweisen vorgesehen geführt werden und ihre Aufzeichnung nicht durch eine interne oder externe Person oder Stelle außer Kraft gesetzt wurde.

7.5.3 Weitergehende Anforderungen

7.5.3.1 SR 3.3 RE 1 – Automatisierte Mechanismen zur Verifikation der IT-Sicherheitsfunktionalität

Das Automatisierungssystem muss die Fähigkeit bieten, automatisierte Mechanismen einzusetzen, die die Verwaltung der Verifikation der IT-Sicherheit bei der Werksabnahme, bei Abnahme der installierten Anlage und während einer geplanten Instandhaltung unterstützen.

7.5.3.2 SR 3.3 RE 2 – Verifikation der IT-Sicherheitsfunktionalität im laufenden Betrieb

Das Automatisierungssystem muss die Fähigkeit bieten, die Verifikation des bestimmungsgemäßen Betriebs der IT-Sicherheitsfunktionen im laufenden Betrieb zu unterstützen.

ANMERKUNG Es ist allgemeine gute Praxis, diese Anforderung sehr sorgfältig umzusetzen, da dies durchaus zu nachteiligen Folgen führen kann. Sie wird oft für sicherheitsbezogene Systeme als nicht geeignet angesehen.

7.5.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 3.3 – Verifikation der IT-Sicherheitsfunktionalität sind:

- SL-C(SI, Automatisierungssystem) 1: SR 3.3;
- SL-C(SI, Automatisierungssystem) 2: SR 3.3;
- SL-C(SI, Automatisierungssystem) 3: SR 3.3 (1);
- SL-C(SI, Automatisierungssystem) 4: SR 3.3 (1) (2).

7.6 SR 3.4 – Software- und Informationsintegrität

7.6.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, nicht autorisierte Änderungen an Software und Informationen bei deren Speicherung zu erkennen, aufzuzeichnen, zu melden und gegen diese zu schützen.

7.6.2 Begründung und zusätzliche Hinweise

Nicht autorisierte Änderungen sind Änderungen, für welche die Person oder Stelle, die diese durchzuführen versucht, nicht die erforderlichen Berechtigungen hat. Diese SR vervollständigt verwandte, bereits in den FR 1 und FR 2 festgelegte SR. FR 1 und FR 2 beinhalten die Durchsetzung der Rollen, Berechtigungen und Nutzermuster entsprechend des Entwurfs. Verfahren zur Integritätsverifikation werden eingesetzt, um Verfälschungen von Software und Informationen, welche nach Umgehung anderer Schutzmechanismen (wie Durchsetzung der Autorisierung) auftreten können, zu erkennen, aufzuzeichnen, zu melden und gegen solche zu schützen. Das Automatisierungssystem sollte formale oder empfohlene Integritätsmechanismen (wie kryptographische Hashfunktionen) einsetzen. Beispielsweise könnten solche Mechanismen zur Überwachung des aktuellen Konfigurationsstandes von Feldgeräte verwendet werden, um IT-Sicherheitsverstöße (einschließlich nicht autorisierte Änderungen) zu erkennen.

7.6.3 Weitergehende Anforderungen

7.6.3.1 SR 3.4 RE 1 – Automatisierte Hinweise auf IT-Sicherheitsverstöße

Das Automatisierungssystem muss die Fähigkeit bieten, automatisierte Werkzeuge einzusetzen, die Nachrichten über während der Integritätsüberprüfung erkannte Diskrepanzen einem konfigurierbaren Kreis von Empfängern übermitteln.

7.6.3.2 Leer

7.6.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 3.4 – Software- und Informationsintegrität sind:

- | | |
|-----------|---|
| AC | <ul style="list-style-type: none"> – SL-C(SI, Automatisierungssystem) 1: keine; – SL-C(SI, Automatisierungssystem) 2: SR 3.4; – SL-C(SI, Automatisierungssystem) 3: SR 3.4 (1); – SL-C(SI, Automatisierungssystem) 4: SR 3.4 (1). |
|-----------|---|

7.7 SR 3.5 – Eingabevalidierung

7.7.1 Anforderung

Das Automatisierungssystem muss die Syntax und den Inhalt jeder Eingabe, die als Eingabe für das Automatisierungssystem verwendet wird oder unmittelbare Auswirkungen auf dessen Aktionen hat, validieren.

7.7.2 Begründung und zusätzliche Hinweise

Regeln für die Überprüfung der gültigen Syntax von Eingaben in ein Automatisierungssystem, wie beispielsweise Sollwerten, sollten in Kraft sein, um sicherzustellen, dass diese Informationen nicht verfälscht wurden und der Spezifikation entsprechen. Eingaben an weiterverarbeitende Programme sollten vorgeprüft werden, um zu vermeiden, dass deren Inhalt unabsichtlich als Befehle interpretiert wird. Es wird darauf hingewiesen, dass dies eine IT-Sicherheitsanforderungen (SR) ist, somit betrifft sie keine menschlichen Fehlhandlungen wie beispielsweise die Angabe einer legitimen ganzzahligen Variablen, die außerhalb des erwarteten Bereichs liegt.

Zu den in der industriellen Praxis allgemein anerkannten Gepflogenheiten der Validierung von Eingabedaten gehören außerhalb des erwarteten Bereichs liegende Werte eines definierten Feldtyps, ungültige Zeichen in Datenfeldern, fehlende oder unvollständige Daten und Pufferüberläufe. Weitere Beispiele von ungültigen Eingaben, die zu Problemen mit der Systemsicherheit führen, sind Angriffe mit SQL-Injectionen, Cross-Site-

Scripting oder ungültige Pakete (wie sie gewöhnlich durch Protokoll-Fuzzer erzeugt werden). Hierbei möglicherweise zu beachtende Anleitungen könnten neben anderen der „Open Web Application Security Project (OWASP) Code Review Guide“ [31] sein.

7.7.3 Weitergehende Anforderungen

Keine.

7.7.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 3.5 – Eingabevalidierung sind:

- SL-C(SI, Automatisierungssystem) 1: SR 3.5;
- SL-C(SI, Automatisierungssystem) 2: SR 3.5;
- SL-C(SI, Automatisierungssystem) 3: SR 3.5;
- SL-C(SI, Automatisierungssystem) 4: SR 3.5.

7.8 SR 3.6 – Vorbestimmte Zustände der Ausgänge

7.8.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, Ausgänge auf einen vorbestimmten Zustand zu setzen, falls in Folge eines Angriffs kein normaler Betrieb mehr aufrechterhalten werden kann.

7.8.2 Begründung und zusätzliche Hinweise

Das vorbestimmte Verhalten der Ausgänge eines Automatisierungssystems als Folge von Angriffen gegen dieses ist eine wichtige Eigenschaft zur Sicherstellung der Integrität des normalen Betriebs. Idealerweise fährt das Automatisierungssystem trotz eines Angriffs mit dem normalen Betrieb fort; wenn es diesen jedoch nicht länger aufrechterhalten kann, müssen seine Ausgänge auf einen vorbestimmten Zustand zurückfallen. Der geeignete vorbestimmte Zustand des Automatisierungssystems, ist von der Anwendung abhängig und könnte eine der folgenden, vom Nutzer zu konfigurierenden Optionen sein:

- spannungsfrei – die Ausgänge fallen in einen spannungsfreien Zustand;
- halten – die Ausgaben nehmen den letzten bekannten guten Wert an;
- fixiert – die Ausgaben nehmen einen festen Wert an, der zuvor vom Betreiber oder einer Anwendung festgelegt wurde.

7.8.3 Weitergehende Anforderungen

Keine.

7.8.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 3.6 – Vorbestimmte Zustände der Ausgänge sind:

- SR-C(SI, Automatisierungssystem) 1: SR 3.6;
- SR-C(SI, Automatisierungssystem) 2: SR 3.6;
- SR-C(SI, Automatisierungssystem) 3: SR 3.6;
- SR-C(SI, Automatisierungssystem) 4: SR 3.6.

7.9 SR 3.7 – Fehlerbehandlung

7.9.1 Anforderung

Das Automatisierungssystem muss Fehler erkennen und die Fehlzustände so behandeln, dass eine wirk-same Abhilfe stattfinden kann. Dies muss in einer Art und Weise geschehen, die keine Informationen, die von Gegnern für Angriffe auf das IACS verwendet werden können, liefert, außer die Offenlegung dieser Informationen ist für die rechtzeitige Behebung der Probleme unumgänglich.

7.9.2 Begründung und zusätzliche Hinweise

Die Struktur und der Inhalt von Fehlermeldungen sollten vom Produktlieferanten und Systemintegrator sorgfältig bedacht werden. Vom Automatisierungssystem erzeugte Fehlermeldungen sollten zeitnahe und nützliche Informationen liefern, ohne möglicherweise gefährliche Informationen offenzulegen, die von Gegnern zum Angriff auf das IACS verwendet werden können. Da es zunächst unklar sein kann, ob ein bestimmter Fehlzustand auf einen IT-Sicherheitsvorfall zurückzuführen ist, sollten während der Klärung des Vorfalls alle Fehlermeldungen leicht zugänglich sein. Eine Offenlegung dieser Informationen sollte durch die Notwendigkeit einer rechtzeitigen Klärung der Fehlzustände gerechtfertigt sein. Hierbei zu beachtende Anleitungen könnten neben anderen der „OWASP Code Review Guide“ [31] sein.

7.9.3 Weitergehende Anforderungen

Keine.

7.9.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 3.7 – Fehlerbehandlung sind:

- SL-C(SI, Automatisierungssystem) 1: keine;
- SL-C(SI, Automatisierungssystem) 2: SR 3.7;
- SL-C(SI, Automatisierungssystem) 3: SR 3.7;
- SL-C(SI, Automatisierungssystem) 4: SR 3.7.

7.10 SR 3.8 – Sitzungsintegrität

7.10.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, die Integrität von Sitzungen zu schützen. Es muss die Nutzung ungültiger Sitzungsbezeichner verweigern.

7.10.2 Begründung und zusätzliche Hinweise

Diese Maßnahme richtet sich auf den Schutz der Kommunikation in der Ebene der Sitzungen und nicht auf die Übertragung der Pakete. Mit dieser Maßnahme wird beabsichtigt an jedem Ende der Kommunikations-sitzung eine Vertrauensbasis in die Aufrechterhaltung der Identität der anderen Stelle und die Gültigkeit der übertragenen Informationen zu schaffen. Diese Maßnahme richtet sich beispielsweise gegen Man-in-the-middle-Angriffe einschließlich Sitzungsübernahme, Einspeisung falscher Informationen in eine Sitzung oder Replay-Angriffe. Der Einsatz von Mechanismen zur Bewahrung der Sitzungsintegrität kann zu einem erheblichen Verwaltungsaufwand führen und sollte daher im Lichte der Anforderungen an eine Echtzeit-Kommunikation bedacht werden.

7.10.3 Weitergehende Anforderungen

7.10.3.1 SR 3.8 RE 1 – Annullierung der Sitzungsbezeichner nach Sitzungsbeendigung

Das Automatisierungssystem muss die Fähigkeit bieten, die Gültigkeit von Sitzungsbezeichner nach der Abmeldung durch den Nutzer oder nach einer andersgearteten Sitzungsbeendigung (einschließlich Browser-Sitzungen) aufzuheben.

7.10.3.2 SR 3.8 RE 2 – Erzeugung eines eindeutigen Sitzungsbezeichners

Das Automatisierungssystem muss die Fähigkeit bieten, eine eindeutige Sitzungsbezeichner für jede Sitzung zu erzeugen und alle unerwarteten Sitzungsbezeichner als ungültig zu behandeln.

7.10.3.3 SR 3.8 RE 3 – Zufälligkeit der Sitzungsbezeichner

Das Automatisierungssystem muss die Fähigkeit bieten, eindeutige Sitzungsbezeichner anhand allgemein anerkannter Verfahren zur Erzeugung von Zufallszahlen zu erzeugen.

ANMERKUNG Für die Übernahme von Sitzungen und andere Man-in-the-Middle-Angriffe oder für die Einspeisung falscher Informationen machen sich Angreifer häufig leicht zu erratende Sitzungsbezeichner (Schlüssel oder andere gemeinsame Geheimnisse) zu Nutze oder verwenden Sitzungsbezeichner, die nach Sitzungsbeendigung nicht richtig ungültig gemacht wurden. Daher muss die Gültigkeit eines Sitzungsauthentifizierers eng an die Lebensdauer einer Sitzung geknüpft sein. Die Einbeziehung von Zufälligkeit in die Erzeugung eindeutiger Sitzungsbezeichner hilft, sich gegen Brute-Force-Angriffe zum Erraten zukünftiger Sitzungskennungen zu schützen.

7.10.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 3.8 – Sitzungsintegrität sind:

- SL-C(SI, Automatisierungssystem) 1: keine;
- SL-C(SI, Automatisierungssystem) 2: SR 3.8;
- SL-C(SI, Automatisierungssystem) 3: SR 3.8 (1) (2);
- SL-C(SI, Automatisierungssystem) 4: SR 3.8 (1) (2) (3).

7.11 SR 3.9 – Schutz von Prüfinformationen

7.11.1 Anforderung

Das Automatisierungssystem muss Prüfinformationen und Prüfwerkzeuge (soweit vorhanden) vor nicht autorisiertem Zugriff, Änderung und Löschung schützen.

7.11.2 Begründung und zusätzliche Hinweise

Zu den Prüfinformationen zählen alle Informationen (beispielsweise Ereignisdatensätze, Prüf-Voreinstellungen und Prüfaufzeichnungen), die für eine erfolgreiche Prüfung der Aktivität eines Automatisierungssystems benötigt werden. Diese sind wichtig für Fehlerkorrektur, Wiederherstellung nach IT-Sicherheitsverstößen, Untersuchungen und damit zusammenhängenden Bemühungen. Modifikation und Löschung können unter anderem durch Speicherung auf nur einmal beschreibbaren Speichermedien verhindert werden.

7.11.3 Weitergehende Anforderungen

7.11.3.1 SR 3.9 RE 1 – Ereignisdatensätze auf nur einmal beschreibbaren Speichermedien

Das Automatisierungssystem muss die Fähigkeit bieten, Ereignisdatensätze auf aufgrund ihrer Hardware nur einmal beschreibbaren Speichermedien anzulegen.

7.11.3.2 Leer

7.11.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 3.9 – Schutz von Prüfinformationen sind:

- SL-C(SI, Automatisierungssystem) 1: keine;
- SL-C(SI, Automatisierungssystem) 2: SR 3.9;
- SL-C(SI, Automatisierungssystem) 3: SR 3.9;
- SL-C(SI, Automatisierungssystem) 4: SR 3.9 (1).

8 Grundlegende Anforderung FR 4 – Vertraulichkeit der Daten

8.1 Zweck und Beschreibungen des SL-C(DC)

Die Vertraulichkeit von Daten in Kommunikationskanälen und Datenbeständen sicherstellen, um deren nicht autorisierte Offenlegung zu verhindern.

- SL 1 – Die nicht autorisierte Offenlegung von Informationen durch Abhören oder zufälliges Aufdecken verhindern.

- SL 2 – Die nicht autorisierte Offenlegung von Informationen an eine danach aktiv mit einfachen Mitteln bei geringem Aufwand, allgemeinen Fertigkeiten und geringer Motivation suchende Person oder Stelle verhindern.
- SL 3 – Die nicht autorisierte Offenlegung von Informationen an eine danach aktiv mit raffinierten Mitteln und moderatem Aufwand, IACS-spezifische Fertigkeiten und mittlerer Motivation suchende Person oder Stelle verhindern.
- SL 4 – Die nicht autorisierte Offenlegung von Informationen an eine danach aktiv mit raffinierten Mitteln und erheblichem Aufwand, IACS-spezifische Fertigkeiten und hoher Motivation suchende Person oder Stelle verhindern.

8.2 Begründung

Einige vom Automatisierungssystem erzeugte Informationen, sowohl bei der Übertragung als auch bei der Speicherung, sind von vertraulicher oder sensibler Natur. Dies hat zur Folge, dass einige Kommunikationskanäle und Datenbestände Schutz gegen Abhören und nicht autorisierten Zugriff benötigen.

8.3 SR 4.1 – Vertraulichkeit von Informationen

8.3.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, die Vertraulichkeit von solchen Informationen zu schützen, für die ausdrücklich eine Leseberechtigung vorgesehen ist, sowohl bei der Übertragung als auch bei der Speicherung.

8.3.2 Begründung und zusätzliche Hinweise

Der Schutz von Informationen, bei sowohl der Übertragung als auch der Speicherung, kann durch physikalische Mittel, durch Abschottung, Verschlüsselung oder andere Techniken gewahrt werden. Dabei ist es unerlässlich, bei der Technikauswahl die möglichen Nebenwirkungen auf das Systemverhalten und die Fähigkeit, nach einem Systemausfall oder Angriff wiederhergestellt werden zu können, sorgfältig zu beachten.

Die Entscheidung, ob eine bestimmte Information geschützt werden sollte oder nicht, hängt vom Zusammenhang ab und kann nicht schon während der Produktentwicklung getroffen werden. Jedoch kann der Umstand, dass eine Organisation den Zugang zu einer Information durch das Einrichten ausdrücklicher Leseberechtigungen im Automatisierungssystem beschränkt, als ein Indikator dafür angesehen werden, dass diese Information von der Organisation als vertraulich eingestuft wird. Somit sollten alle Informationen, für die das Automatisierungssystem die Möglichkeit der Einrichtung ausdrücklicher Leseberechtigungen vorsieht, als potenziell vertraulich eingestuft werden, und das Automatisierungssystem sollte daher auch die Möglichkeit vorsehen, diese zu schützen.

Je nach Arbeitsgebiet von Organisationen und Industriebereichen können unterschiedlich starke Verschlüsselungsverfahren für verschiedene Informationskategorien benötigt werden, dies richtet sich sowohl nach der Empfindlichkeit dieser Informationen als auch nach den Industrienormen und behördlichen Vorschriften (siehe 8.5, SR 4.3 – Verwendung von Verschlüsselung). In manchen Situationen können Informationen über Netzkonfigurationen, die in Switches und Routern gespeichert sind und dort weiterverarbeitet werden, als vertraulich eingestuft werden.

Eine Kommunikation mit offen zugänglicher Datenübertragung kann gegen Abhören und Verfälschen verwundbar sein. Ist ein Automatisierungssystem von einem externen Kommunikationsdienstleister abhängig, so könnte es schwierig werden, die notwendigen Zusicherungen hinsichtlich der Umsetzung der erforderlichen IT-Sicherheitsmaßnahmen für vertrauliche Kommunikation zu erhalten. In solchen Fällen könnte es angebracht sein, Ausgleichsmaßnahmen vorzusehen oder aber das zusätzliche Risiko ausdrücklich zu akzeptieren.

Die verantwortlichen Personen oder Stellen sollten sich ebenfalls der Informationsvertraulichkeit bewusst sein, wenn tragbare und mobile Geräte eingesetzt werden (beispielsweise Laptops zum Programmieren und USB-Sticks).

Wie in 5.7, SR 1.5 – Verwaltung der Authentifizierer gefordert, sollten zur Authentifizierung verwendete Informationen, beispielsweise Passwörter, als vertraulich eingestuft werden und sollten daher nie offen übertragen werden.

8.3.3 Weitergehende Anforderungen

8.3.3.1 SR 4.1 RE 1 – Schutz der Vertraulichkeit bei der Speicherung oder Übertragung über nicht vertrauenswürdige Netze

Das Automatisierungssystem muss die Fähigkeit bieten, die Vertraulichkeit von Informationen im Ruhezustand zu schützen sowie von Fernzugriffssitzungen, die ein nicht vertrauenswürdiges Netz durchqueren.

ANMERKUNG Kryptographie ist ein verbreitetes Verfahren zur Sicherstellung der Informationsvertraulichkeit.

8.3.3.2 SR 4.1 RE 2 – Schutz der Vertraulichkeit über Zonengrenzen hinweg

Das Automatisierungssystem muss die Fähigkeit bieten, die Vertraulichkeit von Informationen, die eine Zonengrenze überqueren, zu schützen.

8.3.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 4.1 – Vertraulichkeit von Informationen sind:

- SL-C(DC, Automatisierungssystem) 1: SR 4.1;
- SL-C(DC, Automatisierungssystem) 2: SR 4.1 (1);
- SL-C(DC, Automatisierungssystem) 3: SR 4.1 (1);
- SL-C(DC, Automatisierungssystem) 4: SR 4.1 (1) (2).

8.4 SR 4.2 – Dauerhaftigkeit von Informationen

8.4.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, Komponenten, die außer Betrieb genommen und/oder stillgelegt werden sollen, von allen Informationen, für die eine ausdrückliche Leseberechtigung vorgesehen war, zu säubern.

8.4.2 Begründung und zusätzliche Hinweise

Das Herausnehmen einer Komponente des Automatisierungssystems aus dem aktiven Betrieb sollte keine Gelegenheit für eine unbeabsichtigte Freigabe von Informationen, für die eine ausdrückliche Leseberechtigung gefordert war, bieten. Ein Beispiel für solche Informationen sind Verbindungsschlüssel (in einigen Funkgeräten), die in nichtflüchtigen Speichern aufbewahrt sind, oder andere Verschlüsselungsinformationen, die nicht autorisierte oder bösartige Handlungen erleichtern würden.

Durch Handlungen eines Nutzers oder einer Rolle erzeugte Information (oder im Namen eines Nutzers oder einer Rolle ausgeführte Handlungen eines Softwareprozesses) sollten gegenüber einem anderen Nutzer oder einer anderen Rolle nicht auf eine unkontrollierte Art und Weise offengelegt werden. Die Beschränkung von Informationen über das Automatisierungssystem oder der Dauerhaftigkeit von Daten verhindert, dass Informationen, die in einer gemeinsam genutzten Ressource gespeichert sind, unbeabsichtigt offengelegt werden, nachdem diese Ressource wieder für das Automatisierungssystem freigegeben wurde.

8.4.3 Weitergehende Anforderungen

8.4.3.1 SR 4.2 RE 1 – Säuberung gemeinsam genutzter Speicher

Das Automatisierungssystem muss die Fähigkeit bieten, eine nicht autorisierte und unbeabsichtigte Informationsübertragung über flüchtige, gemeinsam genutzte Speichermittel zu verhindern.

DIN EN IEC 62443-3-3 (VDE 0802-3-3):2020-01 EN IEC 62443-3-3:2019 + AC:2019

ANMERKUNG Flüchtige Speichermittel sind solche, in denen üblicherweise keine zuvor gespeicherten Informationen verbleiben, nachdem sie an das Speichermanagement zurückgegeben wurden. Es kann jedoch Angriffe gegen RAM-Speicher geben, die möglicherweise Informationen über Schlüssel oder andere vertrauliche Daten extrahieren, bevor sie wirklich überschrieben werden. Daher ist es allgemein übliche Praxis, alle eindeutigen Daten und Verbindungen zu einzelnen Daten in einem flüchtigen, gemeinsam genutzten Speicher zu löschen, wenn dieser zur Verwendung durch einen anderen Nutzer freigegeben und an das Automatisierungssystem zurückgegeben wird, damit diese Daten für den neuen Nutzer nicht sichtbar und auch nicht zugänglich sind.

8.4.3.2 Leer

8.4.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 4.2 – Dauerhaftigkeit von Informationen sind:

- SL-C(DC, Automatisierungssystem) 1: keine;
- SL-C(DC, Automatisierungssystem) 2: SR 4.2;
- SL-C(DC, Automatisierungssystem) 3: SR 4.2 (1);
- SL-C(DC, Automatisierungssystem) 4: SR 4.2 (1).

8.5 SR 4.3 – Verwendung von Verschlüsselung

8.5.1 Anforderung

Falls eine Verschlüsselung gefordert ist, muss das Automatisierungssystem kryptographische Algorithmen, Schlüsselgrößen und Mechanismen der Schlüsselerstellung und deren Verwaltung entsprechend den in der Informationstechnik allgemein anerkannten IT-Sicherheitsgepflogenheiten und Empfehlungen verwenden.

8.5.2 Begründung und zusätzliche Hinweise

Die Auswahl des Verschlüsselungsschutzes sollte dem Wert der zu schützenden Information, den Auswirkungen des Bruchs ihrer Vertraulichkeit, der Dauer ihrer Vertraulichkeit und den Einschränkungen von Seiten des Automatisierungssystems entsprechen. Dies kann Informationen bei der Speicherung oder bei der Übertragung oder beides betreffen. Es wird darauf hingewiesen, dass auch Sicherungskopien Information bei der Speicherung sind und daher bei der Beurteilung der erforderlichen Datenvertraulichkeit mit beachtet werden sollten. Der Lieferant des Automatisierungssystems sollte die Verfahren zur kryptographischen Schlüsselerstellung und zum Schlüsselmanagement dokumentieren. Das Automatisierungssystem sollte etablierte und geprüfte Verschlüsselungs- und Hashalgorithmen einsetzen, wie z. B. AES (en: advanced encryption standard) und SHA (en: secure hash algorithm) und Schlüsselgrößen entsprechend zugewiesener Standards und Normen verwenden. Zur Schlüsselerzeugung ist ein wirkungsvoller Zufallszahlengenerator erforderlich. IT-Sicherheitsleitlinien und -vorgehensweisen der Schlüsselverwaltung müssen periodische Schlüsseländerungen, Schlüsselzerstörung, Schlüsselverteilung und deren Sicherungskopien entsprechend zutreffender Normen vorsehen. Allgemein anerkannte Verfahren und Empfehlungen befinden sich in Schriftstücken wie z. B. NIST SP800-57 [25]. Implementierungsanforderungen befinden sich beispielsweise in ISO/IEC 19790 [12].

Zur Erfüllung vieler anderer in dieser Norm festgelegten Anforderungen kann diese SR, zusammen mit 5.10, SR 1.8 – PKI-Zertifikate, nützlich sein.

8.5.3 Weitergehende Anforderungen

Keine.

8.5.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 4.3 – Verwendung von Verschlüsselung sind:

- SL-C(DC, Automatisierungssystem) 1: SR 4.3;
- SL-C(DC, Automatisierungssystem) 2: SR 4.3;
- SL-C(DC, Automatisierungssystem) 3: SR 4.3;

- SL-C(DC, Automatisierungssystem) 4: SR 4.3.

9 Grundlegende Anforderung FR 5 – Eingeschränkter Datenfluss

9.1 Zweck und Beschreibungen des SL-C(RDF)

Das Automatisierungssystem in Zonen und Conduits aufteilen, um einen unnötigen Datenfluss zu verhindern.

- SL 1 – Verhindere die gelegentliche oder zufällige Umgehung der Aufteilung in Zonen und Conduits.
- SL 2 – Verhindere die absichtliche Umgehung der Aufteilung in Zonen und Conduits durch Personen oder Stellen, die mit einfachen Mitteln, geringen Ressourcen, allgemeinen Fertigkeiten und geringer Motivation vorgehen.
- SL 3 – Verhindere die absichtliche Umgehung der Aufteilung in Zonen und Conduits durch Personen oder Stellen, die mit raffinierten Mitteln, mittleren Ressourcen, IACS-spezifische Fertigkeiten und mittlerer Motivation vorgehen.
- SL 4 – Verhindere die absichtliche Umgehung der Aufteilung in Zonen und Conduits durch Personen oder Stellen, die mit raffinierten Mitteln, erheblichen Ressourcen, IACS-spezifische Fertigkeiten und hoher Motivation vorgehen.

9.2 Begründung

Anhand einer Risikoeinschätzung müssen die Betreiber die notwendigen Einschränkungen des Informationsflusses bestimmen und damit folglich auch die Einrichtung der zur Übermittlung dieser Informationen benutzten Conduits festlegen. Hieraus abgeleitete Empfehlungen und Leitlinien sollten Mechanismen enthalten, die von der Trennung der Automatisierungssysteme von kommerziellen oder öffentlichen Netzen bis zur Verwendung unidirektionaler Gateways, Firewalls mit stateful-packet-Inspection und DMZs reichen, um so den Informationsfluss lenken zu können.

9.3 SR 5.1 – Netzaufteilung

9.3.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, automatisierungstechnische Netze von nicht-automatisierungstechnischen Netzen logisch abzuteilen und kritische automatisierungstechnische Netze von anderen automatisierungstechnischen Netzen logisch abzuteilen.

9.3.2 Begründung und zusätzliche Hinweise

Netzaufteilung wird von Organisationen für verschiedene Zwecke, auch zur IT-Sicherheit, eingesetzt. Hauptgründe hierfür sind das Verringern der Angriffsfläche oder des Eindringens des Netzverkehrs in ein Automatisierungssystem sowie das Verringern der Ausbreitung des Netzverkehrs oder des abgehenden Netzverkehrs aus einem Automatisierungssystem. Dadurch werden das Reaktionsverhalten des Systems und die Zuverlässigkeit verbessert sowie die IT-Sicherheit erhöht. Es erlaubt weiterhin, dass Netzbereiche des Automatisierungssystems einschließlich sicherheitsbezogener und kritischer Systeme von anderen Systemen abgeteilt werden, um eine weitere Stufe des Schutzes zu erreichen.

Der Zugriff aus dem Automatisierungssystem heraus auf das Internet sollte eindeutig anhand betrieblicher Anforderungen des Automatisierungssystems gerechtfertigt werden.

Netzaufteilung und das dadurch erreichte Schutzniveau hängen in starkem Maße von der gesamten Netzarchitektur ab, die ein Betreiber in seiner Anlage einsetzt und die von Systemintegratoren innerhalb des Automatisierungssystems verwendet wird. Eine logische und an der Funktionalität ausgerichtete Netzaufteilung bietet eine gewisse Schutzwirkung, kann jedoch trotzdem zu einem Schwachpunkt der Verfügbarkeit führen, wenn eine Infrastrukturkomponente kompromittiert wurde. Eine physikalische Aufteilung von Netzen bietet, indem es den genannten Schwachpunkt beseitigt, eine weitere Stufe des Schutzes, führt jedoch zu einer komplexeren und teureren Auslegung. Diese Abwägungen müssen bei der Projektierung durchgeführt werden (siehe IEC 62443-2-1).

Als Reaktion auf einen IT-Sicherheitsvorfall kann es notwendig werden, die Verbindungen zwischen verschiedenen Netzbereichen zu trennen. In solch einem Fall sollten wesentliche Dienste in solch einer Weise aufrechterhalten bleiben, dass die Geräte weiterhin ordnungsgemäß arbeiten oder ordnungsgemäß abgeschaltet werden können. Hierzu kann es erforderlich werden, einige Server im Automatisierungssystemnetz zu duplizieren, damit die normalen Netzmerkmale, z. B. das Dynamic-Host-Configuration-Protocol (DHCP), der Domain-Name-Service (DNS) oder lokale Zertifizierungsstellen (CA) weiter zur Verfügung stehen. Dies könnte aber auch bedeuten, dass gewisse kritische und sicherheitsbezogene Systeme von Anfang an so ausgelegt werden, dass sie von anderen Netzen vollständig isoliert sind.

9.3.3 Weitergehende Anforderungen

9.3.3.1 SR 5.1 RE 1 – Physikalische Netzaufteilung

Das Automatisierungssystem muss die Fähigkeit bieten, automatisierungstechnische Netze von nicht automatisierungstechnischen Netzen physikalisch abzutrennen und kritische automatisierungstechnische Netze von anderen automatisierungstechnischen Netzen physikalisch abzutrennen.

9.3.3.2 SR 5.1 RE 2 – Unabhängigkeit von nicht automatisierungstechnischen Netzen

Das Automatisierungssystem muss die Fähigkeit bieten, ohne eine Verbindung zu nicht automatisierungstechnischen Netzen Netzdienste bereitzustellen in automatisierungstechnischen Netzen, seien diese von kritischer oder anderer Natur.

9.3.3.3 SR 5.1 RE 3 – Logische und physikalische Isolierung kritischer Netze

Das Automatisierungssystem muss die Fähigkeit bieten, kritische von nicht kritischen automatisierungstechnischen Netzen logisch und physikalisch zu isolieren.

9.3.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 5.1 – Netzaufteilung sind:

- SL-C(RDF, Automatisierungssystem) 1: SR 5.1;
- SL-C(RDF, Automatisierungssystem) 2: SR 5.1 (1);
- SL-C(RDF, Automatisierungssystem) 3: SR 5.1 (1) (2);
- SL-C(RDF, Automatisierungssystem) 4: SR 5.1 (1) (2) (3).

9.4 SR 5.2 – Schutz der Zonengrenze

9.4.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, die Kommunikation an Zonengrenzen zu überwachen und zu kontrollieren, um die im risikobasierten Zonen- und Conduits-Modell festgelegten Abtrennungen durchsetzen zu können.

9.4.2 Begründung und zusätzliche Hinweise

Verbindungen zu externen Netzen oder anderen Automatisierungssystemen sollten über gemanagte Schnittstellen erfolgen, die aus zum Schutz der Zonengrenze geeigneten Geräten bestehen (beispielsweise Proxies, Gateways, Router, Firewall, unidirektionale Gateways, Guards und verschlüsselte Tunnel), die in einer effektiven Architektur aufgebaut sind (beispielsweise schützen Firewalls Anwendungsgateways, die sich innerhalb einer DMZ befinden). Der Schutz der Zonengrenzen des Automatisierungssystems an irgendeinem anderen Standort sollte dasselbe Schutzniveau bieten wie an dem primären Ort.

Als Teil des Defense-in-Depth-Konzepts sollten in größerem Maße gefährdete Automatisierungssysteme in separate Zonen aufgeteilt werden, hierzu können Conduits eingesetzt werden, die entsprechend IT-Sicherheitsleitlinien und -vorgehensweisen und einer Risikoeinschätzung den Netzzugang beschränken oder verbieten. Die Einteilung nach SL-T(System) leitet zur Auswahl von Kandidaten für eine Zonenunterteilung an (siehe IEC 62443-3-2 [8]).

9.4.3 Weitergehende Anforderungen

9.4.3.1 SR 5.2 RE 1 – Standardmäßig verweigern, zulassen von Ausnahmen (Deny by default, allow by exception)

Das Automatisierungssystem muss die Fähigkeit bieten, Netzverkehr von vornherein abzulehnen und ihn nur in Ausnahmefällen zuzulassen.

9.4.3.2 SR 5.2 RE 2 – Inselmodus

Das Automatisierungssystem muss die Fähigkeit bieten, jede Kommunikation durch die Grenzen des Automatisierungssystems hindurch zu verhindern (wird auch mit Inselmodus bezeichnet).

ANMERKUNG Beispiele für den Einsatz dieser Fähigkeit sind Fälle, in denen ein IT-Sicherheitsverstoß oder Regelverstoß im Automatisierungssystem beobachtet wurde oder bei denen ein Angriff auf Unternehmensebene stattfindet (siehe auch 4.2, „Unterstützung wesentlicher Funktionen“).

9.4.3.3 SR 5.2 RE 3 – Im Fehlerzustand geschlossen (Fail close)

Das Automatisierungssystem muss die Fähigkeit bieten, jede Kommunikation durch die Grenzen des Automatisierungssystems hindurch zu verhindern, falls es zu einem Ausfall des Grenzschutzmechanismus gekommen ist (diese Maßnahme wird auch mit „im Fehlerzustand geschlossen (fail close)“ bezeichnet). Diese Funktionalität muss so entworfen werden, dass sie nicht den Betrieb eines sicherheitstechnischen Systems (SIS) oder einer anderen sicherheitsbezogenen Funktion stören kann.

ANMERKUNG Beispiele für den Einsatz dieser Fähigkeit sind Szenarien, in denen ein Hardwareausfall oder ein Stromausfall dazu führen, dass ein dem Schutz der Zonengrenze dienendes Gerät in einer eingeschränkten Betriebsart arbeitet oder dass es ganz ausfällt (siehe auch 4.2, „Unterstützung wesentlicher Funktionen“).

9.4.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 5.2 – Schutz der Zonengrenze sind:

- SL-C(RDF, Automatisierungssystem) 1: SR 5.2;
- SL-C(RDF, Automatisierungssystem) 2: SR 5.2 (1);
- SL-C(RDF, Automatisierungssystem) 3: SR 5.2 (1) (2) (3);
- SL-C(RDF, Automatisierungssystem) 4: SR 5.2 (1) (2) (3).

9.5 SR 5.3 – Beschränkung der Mensch-zu-Mensch-Kommunikation

9.5.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, zu verhindern, dass Mensch-zu-Mensch-Nachrichten von Nutzern oder Systemen außerhalb des Automatisierungssystems empfangen werden.

9.5.2 Begründung und zusätzliche Hinweise

Zu den Diensten der Mensch-zu-Mensch-Kommunikation gehören unter anderem folgende: E-Mail-Systeme, soziale Medien (wie Twitter, Facebook, Fotogalerien) oder sonstige Nachrichtendienste, die die Übertragung ausführbarer Dateien erlauben. Solche Systeme dienen üblicherweise privaten Zwecken, die nichts mit dem Betrieb des Automatisierungssystems zu tun haben, daher übersteigen die mit einem solchen System verbundenen Risiken normalerweise jeden wahrgenommenen Nutzen.

Solche allgemeinen Nachrichtendienste sind häufig genutzte Angriffsvektoren zur Einschleusung von Schadsoftware in ein Automatisierungssystem, zur Weiterleitung von Information, zu deren Lesen eine Berechtigung erforderlich ist, an außerhalb des Automatisierungssystems gelegene Orte und zur Erzeugung einer stark erhöhten Netzbelastung, durch die wiederum IT-Sicherheitsprobleme erzeugt oder Angriffe auf das Automatisierungssystem gestartet werden können. Mit der Anwendung eines breiten Bereichs anderer Systemanforderung können geeignete Ausgleichsmaßnahmen zur Erfüllung dieser Anforderung ergriffen werden,

dieses sind beispielsweise Nutzungsbeschränkungen und Einschränkungen des Datenflusses für persönliche Nachrichten, so wie an anderer Stelle dieser Norm beschrieben.

Das Automatisierungssystem darf die Fähigkeit bieten, solche Zweiwege-Nachrichtendienste zu nutzen, jedoch ausschließlich zwischen Servern und/oder Arbeitsplatzrechnern innerhalb des Automatisierungssystems. Man beachte, dass diese SR auch die Anforderungen im Zusammenhang mit 8.3, SR 4.1 – Vertraulichkeit von Informationen unterstützen muss.

Das Automatisierungssystem darf auch den E-Mail-Verkehr oder andere Lösungen zum Nachrichtenaustausch einschränken, die der Kommunikation zwischen internen und externen Computern dienen und die abgehende Nachrichten verwenden. Solche Intern-zu-extern-Kommunikationen dürfen auf den Zweck begrenzt werden, Alarmmeldungen oder andere computergenerierte Meldungen an außerhalb des Automatisierungssystems gelegene Nutzer oder Systeme zu versenden. Um die Weitergabe von Information zu verhindern, für die ausdrücklich Leseberechtigung gefordert wird, sollten zur Übertragung von Alarmen oder Statusmeldungen vorkonfigurierte Nachrichten (etwa mit der Möglichkeit, begrenzten Text einzufügen) eingesetzt werden. Nutzern darf es nicht möglich sein, diesen ausschließlich abgehenden Nachrichten zum Zeitpunkt ihrer Erzeugung Files oder andere Informationen anzuhängen.

9.5.3 Weitergehende Anforderungen

9.5.3.1 SR 5.3 RE 1 – Verbot jeglicher allgemeiner Mensch-zu-Mensch-Kommunikation

Das Automatisierungssystem muss die Fähigkeit bieten, sowohl den Empfang als auch den Versand von Mensch-zu-Mensch-Nachrichten zu verhindern.

9.5.3.2 Leer

9.5.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 5.3 – Beschränkung der Verwendung allgemeiner Nachrichtendienste sind:

- SL-C(RDF, Automatisierungssystem) 1: SR 5.3;
- SL-C(RDF, Automatisierungssystem) 2: SR 5.3;
- SL-C(RDF, Automatisierungssystem) 3: SR 5.3 (1);
- SL-C(RDF, Automatisierungssystem) 4: SR 5.3 (1).

9.6 SR 5.4 – Aufteilung von Anwendungen

9.6.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, Daten, Anwendungen und Dienste auf Basis der Kritikalität aufzuteilen, um die Einführung eines Zonenmodells zu erleichtern.

9.6.2 Begründung und zusätzliche Hinweise

Die Aufteilung darf auf physikalische oder logische Weise mit Hilfe unterschiedlicher Computer, CPUs unterschiedlicher Instanzen des Betriebssystems, verschiedener Netzwerkadressen, Kombinationen dieser Methoden oder anderer passender Methoden erfolgen. Beispiele solcher Anwendungen und Dienste, die für bestimmte Bereiche vorgesehen werden können, umfassen unter anderem Notfall- oder sicherheitsbezogene Systeme, Regelungen, Bedienplätze und Engineering-Arbeitsplatzrechner.

9.6.3 Weitergehende Anforderungen

Keine.

9.6.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 5.4 – Aufteilung von Anwendungen sind:

- SL-C(RDF, Automatisierungssystem) 1: SR 5.4;

- SL-C(RDF, Automatisierungssystem) 2: SR 5.4;
- SL-C(RDF, Automatisierungssystem) 3: SR 5.4;
- SL-C(RDF, Automatisierungssystem) 4: SR 5.4.

10 Grundlegende Anforderung FR 6 – Rechtzeitige Reaktion auf Ereignisse

10.1 Zweck und Beschreibungen des SL-C(TRE)

Auf Verstöße gegen die IT-Sicherheit durch Benachrichtigen der richtigen Stelle, Beibringen von erforderlichen Beweisen der Verletzung und Veranlassen rechtzeitiger Maßnahmen reagieren, sobald Vorfälle entdeckt worden sind.

- SL 1 – Überwache den Betrieb des IACS und reagiere auf Vorfälle, sobald diese entdeckt worden sind, durch die Erfassung und Weitergabe forensischer Beweise auf Nachfrage.
- SL 2 – Überwache den Betrieb des IACS und reagiere auf Vorfälle, sobald diese entdeckt worden sind, durch aktive Erfassung und periodisches Berichten forensischer Beweise.
- SL 3 – Überwache den Betrieb des IACS und reagiere auf Vorfälle, sobald diese entdeckt worden sind, durch aktive Erfassung und Weiterleiten forensischer Beweise an die richtige Stelle.
- SL 4 – Überwache den Betrieb des IACS und reagiere auf Vorfälle, sobald diese entdeckt worden sind, durch aktive Erfassung und Weiterleiten forensischer Beweise an die richtige Stelle, in nahezu Echtzeit.

10.2 Begründung

Anhand einer Risikoeinschätzung sollten die Betreiber IT-Sicherheitsleitlinien und -vorgehensweisen sowie eindeutige Kommunikations- und Eingriffswege, die zur Reaktion auf Verstöße gegen die IT-Sicherheit benötigt werden, festlegen. Daraus abgeleitete vorschriftenartige Empfehlungen und Leitlinien sollten Mechanismen zur Erfassung, Weiterleitung, Aufbewahrung und automatischen Korrelation forensischer Beweise einschließen, um zeitnahe Maßnahmen sicherzustellen. Der Einsatz von Überwachungswerkzeugen und -techniken sollte die Leistung des Automatisierungssystems nicht nachteilig beeinflussen.

10.3 SR 6.1 – Zugriffsmöglichkeit auf Ereignisprotokolle

10.3.1 Anforderung

Das Automatisierungssystem muss autorisierten menschlichen Nutzern und/oder Werkzeugen die Fähigkeit zur Verfügung stellen, auf Ereignisprotokolle lesend zuzugreifen.

10.3.2 Begründung und zusätzliche Hinweise

Das Automatisierungssystem erzeugt Ereignisdatensätze über Ereignisse im System (siehe 6.10, SR 2.8 – Prüfbare Ereignisse und deren Aufzeichnung). Der Zugriff auf diese Ereignisprotokolle ist zum Filtern, Feststellen und Beseitigen redundanter Informationen, zur Durchsicht und zur Berichterstattung für Ermittlungen im Nachgang zu IT-Sicherheitsvorfällen erforderlich. Durch diesen Zugriff sollten die ursprünglichen Aufzeichnungen nicht verändert werden. Im Allgemeinen sollten die Auswahl der Aufzeichnungen und die Berichterstellung auf einem separaten Informationssystem durchgeführt werden. Manueller Zugang zu den Prüfaufzeichnungen (wie Bildschirmanzeigen oder Papiausdrucke) ist zur Erfüllung der Grundforderung ausreichend, für höhere SL jedoch nicht. Zur Weitergabe der Ereignisprotokolle an Analysewerkzeuge wie SIEM wird meist ein programmierter Zugriff verwendet. Siehe hierzu die SR in den Abschnitten 5, 6 und 9 hinsichtlich der Erzeugung, des Schutzes und des Zugriffs auf Ereignisprotokolle.

10.3.3 Weitergehende Anforderungen

10.3.3.1 SR 6.1 RE 1 – Programmgesteuerter Zugriff auf Ereignisprotokolle

Das Automatisierungssystem muss mittels einer API einen programmierten Zugriff auf Ereignisprotokolle zur Verfügung stellen.

10.3.3.2 Leer

10.3.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 6.1 – Zugriffsmöglichkeit auf Ereignisprotokolle sind:

- SL-C(TRE, Automatisierungssystem) 1: SR 6.1;
- SL-C(TRE, Automatisierungssystem) 2: SR 6.1;
- SL-C(TRE, Automatisierungssystem) 3: SR 6.1 (1);
- SL-C(TRE, Automatisierungssystem) 4: SR 6.1 (1).

10.4 SR 6.2 – Kontinuierliche Überwachung

10.4.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, unter Verwendung der in der Informationstechnik allgemein anerkannten IT-Sicherheitsgepflogenheiten und Empfehlungen die Leistung aller IT-Sicherheitsmechanismen dauernd zu überwachen, um so IT-Sicherheitsverstöße rechtzeitig zu entdecken, einzuordnen und zu berichten.

ANMERKUNG Reaktionszeiten sind eine lokale Angelegenheit und liegen außerhalb des Anwendungsbereichs dieser Norm.

10.4.2 Begründung und zusätzliche Hinweise

Die Fähigkeit zur Überwachung des Automatisierungssystems kann durch eine Vielzahl von Werkzeugen und Techniken erreicht werden (beispielsweise IDS, IPS, Schutzmechanismen gegen Schadcode und Netzüberwachungsmechanismen). In dem Maße, wie die Angriffe immer raffinierter werden, müssen auch diese Überwachungswerkzeuge und Techniken immer raffinierter werden, zum Beispiel durch verhaltensabhängige IDS/IPS.

Überwachungsgeräte sollten innerhalb des Automatisierungssystems an strategischen Stellen aufgebaut werden (beispielsweise an der Grenze einer IT-Sicherheitszone und nahe bei Server-Farmen, auf denen kritische Anwendungen laufen), um dort wichtige Informationen zu erfassen. Überwachungsgeräte können auch provisorisch an ausgewählten Orten innerhalb des Automatisierungssystems aufgebaut werden, um dort besondere Tätigkeiten zu verfolgen.

Zur Überwachung gehören auch geeignete Berichtsverfahren, die eine rechtzeitige Reaktion auf Vorfälle ermöglichen. Um Berichte begrenzt und den Umfang der weitergemeldeten Informationen für die Empfänger verarbeitbar zu halten, werden häufig Verfahren wie SIEM eingesetzt, um einzelne Ereignisse in Berichten zusammenzufassen, in denen die Einzelereignisse in einen weiterreichenden Zusammenhang gestellt werden.

Zusätzlich können diese Mechanismen dazu verwendet werden, die Auswirkungen von Änderungen der IT-Sicherheit auf das Automatisierungssystem zu verfolgen (siehe 6.10, SR 2.8 – Prüfbare Ereignisse und deren Aufzeichnung). Vorinstallierte forensische Werkzeuge können die Analyse von Ereignissen erleichtern.

10.4.3 Weitergehende Anforderungen

Keine.

10.4.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 6.2 – Kontinuierliche Überwachung sind:

- SL-C(TRE, Automatisierungssystem) 1: keine;
- SL-C(TRE, Automatisierungssystem) 2: SR 6.2;
- SL-C(TRE, Automatisierungssystem) 3: SR 6.2;
- SL-C(TRE, Automatisierungssystem) 4: SR 6.2.

11 Grundlegende Anforderung FR 7 – Ressourcenverfügbarkeit

11.1 Zweck und Beschreibungen des SL-C(RA)

Die Verfügbarkeit des Automatisierungssystems sicherstellen, um der Verschlechterung oder Ablehnung wesentlicher Dienste entgegenzuwirken.

- SL 1 – Stelle sicher, dass das Automatisierungssystem unter normalen Produktionsbedingungen zuverlässig arbeitet und DoS-Situationen verhindert, die durch gelegentliche oder zufällige Handlungen einer Person oder Stelle verursacht werden.
- SL 2 – Stelle sicher, dass das Automatisierungssystem unter normalen und außergewöhnlichen Produktionsbedingungen zuverlässig arbeitet und DoS-Situationen durch Personen oder Stellen verhindert, die mit einfachen Mitteln, geringen Ressourcen, allgemeinen Fertigkeiten und geringer Motivation vorgehen.
- Security-Level SL 3 – Stelle sicher, dass das Automatisierungssystem unter normalen, außergewöhnlichen und extremen Produktionsbedingungen zuverlässig arbeitet und DoS-Situationen durch Personen oder Stellen verhindert, die mit raffinierten Mitteln, mittleren Ressourcen, IACS-spezifische Fertigkeiten und mittlerer Motivation vorgehen.
- Security-Level SL 4 – Stelle sicher, dass das Automatisierungssystem unter normalen, außergewöhnlichen und extremen Produktionsbedingungen zuverlässig arbeitet und DoS-Situationen durch Personen oder Stellen verhindert, die mit raffinierten Mitteln, erhebliche Ressourcen, IACS-spezifische Fertigkeiten und hoher Motivation vorgehen.

11.2 Begründung

Das Ziel dieser Reihe von SR ist es, sicherzustellen, dass das Automatisierungssystem gegen verschiedene Arten von DoS-Ereignissen widerstandsfähig ist. Dies schließt die teilweise oder vollständige Nichtverfügbarkeit von Systemfunktionen auf verschiedenen Ebenen ein. Insbesondere sollten IT-Sicherheitsvorfälle im Automatisierungssystem keine sicherheitstechnischen Systeme (SIS) oder anderen sicherheitsbezogenen Funktionen beeinträchtigen.

11.3 SR 7.1 – Schutz gegen DoS-Ereignisse

11.3.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, während eines DoS-Ereignisses in einer eingeschränkten Betriebsart weiterzuarbeiten.

11.3.2 Begründung und zusätzliche Hinweise

Es existieren verschiedene Techniken zur Begrenzung oder in manchen Fällen sogar zur Beseitigung der Auswirkungen einer DoS-Situation. Beispielsweise können Geräte zum Schutz der Zonengrenzen gewisse Arten von Datenpaketen herausfiltern, um dadurch Geräte in einem internen, vertrauenswürdigen Netz davor zu schützen, von DoS-Ereignissen direkt betroffen zu werden, oder sie können den Informationsfluss so beschränken, dass er nur nach auswärts geht. Wie bereits in [Abschnitt 4](#) angemerkt, sollte ein auf das Automatisierungssystem gerichtetes DoS-Ereignis keine sicherheitsbezogenen Systeme beeinträchtigen.

11.3.3 Weitergehende Anforderungen

11.3.3.1 SR 7.1 RE 1 – Netzbelastung steuern

Das Automatisierungssystem muss die Fähigkeit bieten, die Kommunikationsauslastung so zu verwalten (etwa durch eine Beschränkung der Übertragungsrate), dass die Auswirkungen eines DoS-Ereignisses mit Datenüberflutung gemindert werden.

11.3.3.2 SR 7.1 RE 2 – DoS-Auswirkungen auf andere Systeme oder Netze begrenzen

Das Automatisierungssystem muss die Fähigkeit bieten, die Möglichkeiten aller Nutzer (menschliche Nutzer, Softwareprozesse und Geräte) zu beschränken, DoS-Ereignisse auszulösen, durch die andere Automatisierungssysteme oder Netze betroffen werden.

11.3.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 7.1 – Schutz gegen DoS-Ereignisse sind:

- SL-C(RA, Automatisierungssystem) 1: SR 7.1;
- SL-C(RA, Automatisierungssystem) 2: SR 7.1 (1);
- SL-C(RA, Automatisierungssystem) 3: SR 7.1 (1) (2);
- SL-C(RA, Automatisierungssystem) 4: SR 7.1 (1) (2).

11.4 SR 7.2 – Ressourcenmanagement

11.4.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, die Verwendung von Ressourcen durch IT-Sicherheitsfunktionen zu begrenzen, um eine Ressourcenüberlastung zu verhindern.

11.4.2 Begründung und zusätzliche Hinweise

Ressourcenmanagement (beispielsweise mittels Netzaufteilung oder Prioritätsvorgaben) hindert einen Softwareprozess niedrigerer Priorität daran, die Ausführung eines Softwareprozesses höherer Priorität zu verzögern oder das Automatisierungssystem bei der Bedienung eines solchen zu stören. So könnte beispielsweise das Auslösen von Netzwerk-Scans, das Aufspielen von Sicherheitspatches oder Antivirusprüfungen in einem Betriebssystem schwerwiegende Störungen des normalen Betriebs bewirken. Beschränkungen des Datenverkehrs sollten als Abhilfemaßnahme erwogen werden.

11.4.3 Weitergehende Anforderungen

Keine.

11.4.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 7.2 – Ressourcenmanagement sind:

- SL-C(RA, Automatisierungssystem) 1: SR 7.2;
- SL-C(RA, Automatisierungssystem) 2: SR 7.2;
- SL-C(RA, Automatisierungssystem) 3: SR 7.2;
- SL-C(RA, Automatisierungssystem) 4: SR 7.2.

11.5 SR 7.3 – Datensicherung im Automatisierungssystem (Backup)

11.5.1 Anforderung

Das Automatisierungssystem muss ohne Beeinträchtigung des laufenden Betriebs der Anlage die Sicherung kritischer Dateien und Verzeichnisse auf Benutzer- und Systemebene (einschließlich Systemstatusinformationen) unterstützen.

11.5.2 Begründung und zusätzliche Hinweise

Die Verfügbarkeit aktueller Datensicherungen ist für die Wiederherstellung nach einem Ausfall des Automatisierungssystems oder nach dessen fehlerhafter Konfiguration unerlässlich. Durch eine Automatisierung dieser Funktion wird sichergestellt, dass alle benötigten Dateien erfasst werden und die Arbeitsbelastung des Bedieners reduziert wird. Obwohl üblicherweise für die Wiederherstellung eines Automatisierungssystems nicht gefordert, sollten für forensische Tätigkeiten nach einem Vorfall benötigte Informationen (beispielsweise Ereignisprotokolle) ausdrücklich in die Datensicherung mit aufgenommen werden (siehe [10.4](#), SR 6.2 – Kontinuierliche Überwachung). Falls die zusammengestellten Sicherungskopien vertrauliche Angaben enthalten, sollten Verschlüsselungsmaßnahmen erwogen werden (siehe [8.5](#), SR 4.3 – Verwendung von Verschlüsselung).

11.5.3 Weitergehende Anforderungen

11.5.3.1 RE 1 – Verifikation der Datensicherung

Das Automatisierungssystem muss die Fähigkeit bieten, die Zuverlässigkeit von Sicherungsmechanismen zu überprüfen.

11.5.3.2 SR 7.3 RE 2 – Automatisierung der Datensicherung

Das Automatisierungssystem muss die Fähigkeit bieten, die Datensicherungsfunktion mit einstellbarer Wiederholungsrate zu automatisieren.

11.5.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 7.3 – Datensicherung im Automatisierungssystem sind:

- SL-C(RA, Automatisierungssystem) 1: SR 7.3;
- SL-C(RA, Automatisierungssystem) 2: SR 7.3 (1);
- SL-C(RA, Automatisierungssystem) 3: SR 7.3 (1) (2);
- SL-C(RA, Automatisierungssystem) 4: SR 7.3 (1) (2).

11.6 SR 7.4 – Wiederherstellung des Automatisierungssystems

11.6.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, sich nach einer Unterbrechung oder einem Ausfall entsprechend eines bekannten, sicheren Zustands wiederherzustellen.

11.6.2 Begründung und zusätzliche Hinweise

Die Wiederherstellung des Automatisierungssystems entsprechend eines bekannten, sicheren Zustands bedeutet, dass alle Systemparameter (entweder voreingestellte oder konfigurierbare) auf sichere Werte gesetzt werden, Sicherheitspatches wieder eingespielt werden, das System im Sinne der IT-Sicherheit wieder richtig konfiguriert wird, Systemdokumentation und Betriebsprozeduren verfügbar sind, Anwendungs- und Systemsoftware wieder installiert und im Sinne der IT-Sicherheit richtig konfiguriert sind, die letzte Datensicherung wieder geladen und das System voll durchgetestet und funktionsfähig ist.

11.6.3 Weitergehende Anforderungen

Keine.

11.6.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 7.4 –Wiederherstellung des Automatisierungssystems sind:

- SL-C(RA, Automatisierungssystem) 1: SR 7.4;
- SL-C(RA, Automatisierungssystem) 2: SR 7.4;
- SL-C(RA, Automatisierungssystem) 3: SR 7.4;
- SL-C(RA, Automatisierungssystem) 4: SR 7.4.

11.7 SR 7.5 – Notstromversorgung

11.7.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, auf eine Notstromversorgung umzuschalten oder von dieser wieder zurückzuschalten, ohne den gerade bestehenden IT-Sicherheitszustand zu beeinträchtigen oder eine gerade bestehende eingeschränkte Betriebsart, die dokumentiert ist.

11.7.2 Begründung und zusätzliche Hinweise

Es kann Fälle geben, in denen Ausgleichsmaßnahmen, wie z. B. Zugangskontrollen an Türen, durch einen Ausfall der Stromversorgung betroffen werden, in diesen Fällen sollte die Notstromversorgung auch solche angegliederten Systeme mit versorgen. Sollte dies nicht möglich sein, könnten in solch einer Notsituation andere Ausgleichsmaßnahmen erforderlich werden.

11.7.3 Weitergehende Anforderungen

Keine.

11.7.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 7.5 – Notstromversorgung sind:

- SL-C(RA, Automatisierungssystem) 1: SR 7.5;
- SL-C(RA, Automatisierungssystem) 2: SR 7.5;
- SL-C(RA, Automatisierungssystem) 3: SR 7.5;
- SL-C(RA, Automatisierungssystem) 4: SR 7.5.

11.8 SR 7.6 – Netz- und IT-Sicherheitseinstellungen

11.8.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, entsprechend den empfohlenen Netz- und IT-Sicherheitseinstellungen, so wie sie in den vom Lieferanten zur Verfügung gestellten Anleitungen beschrieben sind, eingestellt zu werden. Das Automatisierungssystem muss eine Schnittstelle zu den momentan angewendeten Netzwerk- und IT-Sicherheitseinstellungen bereithalten.

11.8.2 Begründung und zusätzliche Hinweise

Diese Einstellungen sind die einstellbaren Parameter der Automatisierungssystemkomponenten. Um Abweichungen von den genehmigten oder empfohlenen Einstellungen erkennen und korrigieren zu können, muss das Automatisierungssystem das Überwachen und die Steuerung der Änderungen entsprechend den IT-Sicherheitsleitlinien und -vorgehensweisen unterstützen. Für weitergehende IT-Sicherheit darf eine automatisierte Prüfung durchgeführt werden, welche die momentanen Einstellungen mittels eines Software-agenten automatisch erfasst und mit den vorgegebenen vergleicht.

11.8.3 Weitergehende Anforderungen

11.8.3.1 SR 7.6 RE 1 – Maschinenlesbare Berichte über die momentanen IT-Sicherheitseinstellungen

Das Automatisierungssystem muss die Fähigkeit bieten, Berichte, die die momentan angewendeten IT-Sicherheitseinstellungen in einem maschinenlesbaren Format aufführen, zu erzeugen.

11.8.3.2 Leer

11.8.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 7.6 – Netzwerk- und IT-Sicherheitseinstellungen sind:

- SL-C(RA, Automatisierungssystem) 1: SR 7.6;
- SL-C(RA, Automatisierungssystem) 2: SR 7.6;
- SL-C(RA, Automatisierungssystem) 3: SR 7.6 (1);
- SL-C(RA, Automatisierungssystem) 4: SR 7.6 (1).

11.9 SR 7.7 – Geringste Funktionalität

11.9.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, gezielt die Verwendung unnötiger Funktionen, Ports, Protokolle und/oder Dienste zu verbieten und/oder zu beschränken.

11.9.2 Begründung und zusätzliche Hinweise

Automatisierungssysteme können eine große Vielfalt von Funktionen und Dienste zur Verfügung stellen. Einige sind möglicherweise für die Ausführung wesentlicher Funktionen nicht erforderlich. Daher sollten per Voreinstellung über eine Grundkonfiguration hinausgehende Funktionen gesperrt werden. Außerdem ist es gelegentlich zweckmäßig, mehrere Dienste von einer einzigen Komponente des Automatisierungssystems aus bereitzustellen; dadurch erhöht sich jedoch das Risiko, die von einer beliebigen anderen Komponente bereitgestellten Dienste einzuschränken. Viele der von handelsüblichen Geräten häufig bereitgestellten Funktionen und Dienste können Kandidaten für eine Beseitigung sein, beispielsweise E-Mail, IP-Telefonie (VoIP), Instant Messaging (IM), FTP, HTTP und gemeinsame Benutzung von Dateien (Filesharing).

11.9.3 Weitergehende Anforderungen

Keine.

11.9.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 7.7 – Geringste Funktionalität sind:

- SL-C(RA, Automatisierungssystem) 1: SR 7.7;
- SL-C(RA, Automatisierungssystem) 2: SR 7.7;
- SL-C(RA, Automatisierungssystem) 3: SR 7.7;
- SL-C(RA, Automatisierungssystem) 4: SR 7.7.

11.10 SR 7.8 – Verzeichnis der Komponenten eines Automatisierungssystems

11.10.1 Anforderung

Das Automatisierungssystem muss die Fähigkeit bieten, eine laufende Liste aller installierten Komponenten mit ihren jeweiligen Merkmalen zu erstellen.

11.10.2 Begründung und zusätzliche Hinweise

Ein Verzeichnis der Komponenten eines Automatisierungssystems (Inventarliste) darf, ohne darauf beschränkt zu sein, die Bezeichner (ID) der Komponente, ihre Fähigkeit und den Ausgabestand beinhalten. Dieses Verzeichnis sollte mit dem betrachteten System übereinstimmen. Es sollte ein formaler Konfigurationsverwaltungsprozess eingerichtet werden, der Änderungen im Komponenteninventar überwacht (siehe IEC 62443-2-1).

11.10.3 Weitergehende Anforderungen

Keine.

11.10.4 Security-Level

Die Anforderungen für die vier SL bezüglich der SR 7.8 – Verzeichnis der Komponenten eines Automatisierungssystems sind:

- SL-C(RA, Automatisierungssystem) 1: keine;
- SL-C(RA, Automatisierungssystem) 2: SR 7.8;
- SL-C(RA, Automatisierungssystem) 3: SR 7.8;
- SL-C(RA, Automatisierungssystem) 4: SR 7.8.

Anhang A (informativ)

Diskussion des SL-Vektors

ANMERKUNG 1 Dieser Anhang beruht auf dem Dokument „Security Assurance Levels: A Vector Approach to Describing Security Requirements“ [28]. Der Inhalt dieses Anhangs wurde gegenüber dem Dokument geändert, um auf Änderungen in der Normenreihe IEC 62443 und eingegangene Stellungnahmen zu reagieren.

ANMERKUNG 2 Die in diesem Anhang enthaltenen Beschreibungen und Erklärungen werden in IEC 62443-1-1 und IEC 62443-3-2 aufgenommen werden. Zum Zeitpunkt der Veröffentlichung der vorliegenden Norm befanden sich diese Dokumente in Bearbeitung oder Überarbeitung und enthielten noch keine Angaben zum SL-Vektor. Dieser Anhang soll dem Leser beim Verständnis des SL-Vektor-Konzepts behilflich sein. Die enthaltenen Beschreibungen und Erklärungen sind informativ und werden durch alle normativen Inhalte in den genannten anderen Normen ersetzt.

A.1 Überblick

In sicherheitsbezogenen Systemen wird seit fast zwei Jahrzehnten das Konzept des Sicherheits-Integritäts-levels^{N4} (SIL) verwendet. Dies erlaubt es, die Sicherheitsintegritätsbeurteilung einer Komponente oder den Sicherheits-Integritätslevel eines installierten Systems durch eine einzige Zahl darzustellen; damit wird, ausgehend von der Ausfallwahrscheinlichkeit dieser Komponente oder dieses Systems, ein zur Sicherstellung der Gesundheit und Sicherheit von Menschen oder der Umwelt notwendiger Schutzfaktor definiert. Der Prozess der Bestimmung des erforderlichen Schutzfaktors für ein sicherheitsbezogenes System ist, obwohl komplex, durchführbar, da die Ausfallwahrscheinlichkeit einer Komponente oder eines Systems aufgrund zufälliger Hardwareausfälle quantitativ gemessen werden kann. Das Gesamtrisiko kann, ausgehend von den Folgen, die solche Ausfälle auf Gesundheit, Sicherheit und Umwelt haben können, errechnet werden.

Systeme der IT-Sicherheit haben dagegen einen sehr viel breiteren Bereich der Anwendung, der Auswirkungen und der Umstände, die zu einem Ereignis führen können. Sie sind zwar auch dazu da Gesundheit, Sicherheit und Umwelt schützen, aber ebenso den industriellen Prozess selbst, unternehmensinterne Informationen, öffentliches Vertrauen und die nationale Sicherheit sowie andere Dinge, in Situationen, in denen zufällige Hardwareausfälle nicht die eigentliche Ausfallursache sind. In manchen Fällen könnte es ein wohlmeinender Angestellter sein, der einen Fehler begeht, und in anderen Fällen ein hinterhältiger Angreifer, der darauf aus ist, einen Vorfall unter Verwischung seiner Spuren herbeizuführen. Die große Komplexität von Systemen der IT-Sicherheit macht es viel schwieriger, den Schutzfaktor mit einer einzigen Zahl auszudrücken.

A.2 Security-Level

A.2.1 Definition

Der nachfolgende Auszug aus IEC/TS 62443-1-1:2009, 5.11.1 erklärt sehr gut, was Security-Level (SL) sind und wie man sie verwenden kann.

Security-Level eröffnen einen qualitativen Ansatz zur Beschreibung der IT-Sicherheit in einer Zone. Als qualitative Methode sind Security-Level so definiert, dass man sie zum Vergleichen und Verwalten von IT-Sicherheitszonen innerhalb einer Organisation anwenden kann. Indem mehr Daten verfügbar und mathematische Darstellungen von Risiken, Bedrohungen und IT-Sicherheitsvorfällen entwickelt werden, wird dieser Ansatz zu einem quantitativen Herangehen zur Auswahl und Verifikation von Security-Level (SL) werden. Er wird sowohl für Betreiber als auch für Anbieter von IACS und IT-Sicherheitsprodukten anwendbar sein. Er verwendet IACS-Geräte und Gegenmaßnahmen, die innerhalb einer Zone

^{N4} Nationale Fußnote: Siehe beispielsweise DIN EN 61508-4 (VDE 0803-4).

verwendet werden, um die Sicherheit von Zonen in verschiedenen Organisationen über Industriebereiche hinweg zu identifizieren und zu vergleichen.

In der ersten Phase der Entwicklung stehen in der Normenreihe IEC 62443 qualitative SL im Vordergrund, die durch Adjektive wie „niedrig“, „mittel“ und „hoch“ beschrieben werden. Es ist dann erforderlich, dass ein Betreiber eigene Definitionen dazu erarbeitet, was solche Klassifizierungen für seine eigene Anwendung bedeuten. Das langfristige Ziel der Normenreihe IEC 62443 ist es, so viele SL und IT-Sicherheitsanforderungen wie möglich in quantitative Beschreibungen, Anforderungen und Metriken zu überführen, um wiederholbare Anwendungen der Norm über verschiedenen Unternehmen und Industriebereiche hinweg zu erreichen. Die Erreichung dieses Ziels wird Zeit benötigen, da mehr Erfahrung bei der Anwendung dieser Normen und Daten zu industriellen IT-Sicherheitssystemen gesammelt werden müssen, um den quantitativen Ansatz zu rechtfertigen.

Bei der Abbildung der Anforderungen auf verschiedenen Security-Leveln benötigen die Normenentwickler einen gewissen Orientierungsrahmen, der beschreibt, was die einzelnen Security-Level bedeuten und wie diese sich voneinander unterscheiden. Das Ziel dieses Anhangs ist es, solch einen Orientierungsrahmen vorzuschlagen.

A.2.2 SL-Arten

Security-Level (SL) sind in drei verschiedene Arten unterteilt: zu erreichender, erreichter und erreichbarer Wert. Diese drei Arten stehen im Zusammenhang mit verschiedenen Aspekten des IT-Sicherheitslebenszyklus.

- **Target SL (SL-T)** (zu erreichender SL) sind die gewünschten Security-Level eines gegebenen Systems. Diese wird üblicherweise durch eine Risikobewertung eines Systems ermittelt und die Feststellung, dass es eine bestimmte Stufe der IT-Sicherheit für seinen ordnungsgemäßen Betrieb benötigt.
- **Achieved SL (SL-A)** (erreichter SL) sind die aktuell erreichten Security-Level eines gegebenen Systems. Nachdem ein Systementwurf verfügbar oder ein System aufgebaut worden ist, werden diese gemessen. Sie dienen der Feststellung, dass ein IT-Sicherheitssystem die in den SL-T niedergelegten Ziele erfüllt.
- **Capability SL (SL-C)** (erreichbarer SL) sind die Security-Level, welche die Komponenten oder Systeme bei richtiger Konfiguration liefern können. Diese Stufen geben an, dass eine bestimmte Komponente oder ein bestimmtes System bei richtiger Konfiguration und Integration fähig ist, die SL-T von sich aus ohne zusätzliche Ausgleichsmaßnahmen zu erreichen.

Diese SL sind zur Verwendung in den verschiedenen Phasen des IT-Sicherheitslebenszyklus nach der Normenreihe IEC 62443 vorgesehen. Beginnend mit der Zielvorgabe (Target) für ein gegebenes System wird eine Organisation einen Systementwurf mit den zur Erreichung des gewünschten Ergebnisses erforderlichen Fähigkeiten erstellen. Anders ausgedrückt wird das Entwicklungsteam zunächst die für ein gegebenes System erforderlichen SL-T erarbeiten. Daran anschließend wird es das System so entwerfen, dass die Ziele erreicht werden; meist in einem iterativen Vorgang, bei dem nach jedem Schritt die erreichten SL des vorgeschlagenen Entwurfs gemessen und mit den SL-T verglichen werden. Im Rahmen dieses Entwicklungsprozesses werden die Entwickler geeignete Komponenten und Systeme mit den zum Erreichen der Anforderungen des SL-T benötigten Fähigkeiten auswählen oder – sollten solchermaßen benötigte Komponenten und Systeme nicht erhältlich sein – die verfügbaren durch Ausgleichsmaßnahmen ergänzen. Nach Inbetriebnahme des Systems würde der aktuelle SL als SL-A gemessen und mit dem SL-T verglichen werden.

A.2.3 Anwendung der Security-Level

Beim Entwurf eines neuen oder der Überarbeitung der IT-Sicherheit eines existierenden Systems besteht der erste Schritt darin, das System in verschiedene Zonen aufzubrechen und Conduits zur Verbindung dieser Zonen untereinander zu bestimmen. Nähere Angaben, wie dieses erreicht werden kann, sind in IEC 62443-3-2 enthalten. Nachdem für ein System ein Zonenmodell aufgestellt worden ist, wird jeder Zone und jedem Conduit auf der Basis einer Analyse der Auswirkungen ein SL-T zugewiesen, der somit die in dieser Zone oder in diesem Conduit gewünschte IT-Sicherheit beschreibt. Für diese anfängliche Analyse der Zonen und Conduits ist es nicht notwendig, dass der Systementwurf im Detail abgeschlossen ist. Es reicht aus, die Funktionalität zu beschreiben, die von den Schutzobjekten in einer Zone bereitgestellt werden sollte, und die Verbindung zwischen den Zonen, um die Sicherheitsziele zu erreichen.

DIN EN IEC 62443-3-3 (VDE 0802-3-3):2020-01 **EN IEC 62443-3-3:2019 + AC:2019**

Die [Bilder A.1](#) und [A.2](#) zeigen Übersichtsbeispiele für die Aufteilung eines Systems in untereinander durch Conduits verbundene Zonen. [Bild A.1](#) ist eine graphische Darstellung eines Automatisierungssystems einer Chlorgas-Ladestation für Lkw. Die zugehörige Anwendungsbeschreibung wird in IEC/TR 62443-1-4 enthalten sein. Das Bild zeigt fünf Zonen: die Betriebs- und Überwachungseinrichtungen (BPCS, en: basic process control system,), das sicherheitstechnische System (SIS), die Leitwarte, die in der Anlage befindliche demilitarisierte Zone (DMZ) und das interne Datennetz des Unternehmens mit dem ERP- oder Warenwirtschaftssystem. Die BPCS und die SIS verwenden speicherprogrammierbare Steuerungen zum Bearbeiten unterschiedlicher Aufgaben in der Ladestation, SIS verwenden FS-PLC, die für den Einsatz in sicherheitsbezogenen Systemen qualifiziert sind. Die beiden SPS sind über eine nicht routbare serielle oder Ethernet-Leitung miteinander verbunden, am Zonenübergang ist eine Schutzeinrichtung zwischengeschaltet. Jede SPS ist mit einem lokalen Switch verbunden, an dem ein Arbeitsplatzrechner als Programmiergerät und ein Gerät zum Bedienen und Beobachten als Bedienplatz angeschlossen sind. Die BPCS- und SIS-Zonen verfügen über je ein Instandhaltungssystem, mit denen die Mess- und Stellgeräte überprüft werden können. Die Leitwarte mit mehreren Arbeitsplatzrechnern und das BPCS sind beide mit der demilitarisierten Zone (DMZ) der Anlage verbunden. Eine Anlagen-DMZ kann, wie im Bild gezeigt, eine Vielzahl unterschiedlicher Komponenten und Systeme enthalten, beispielsweise Arbeitsplatzrechner für die Datenarchivierung oder die Instandhaltung. Im Bild ist die Anlagen-DMZ mit dem internen Datennetz des Unternehmens verbunden, welches auch das unternehmensinterne WLAN und den Web-Server bereitstellt. Um die zur Verbesserung der IT-Sicherheit möglicherweise erforderlichen Ausgleichsmaßnahmen anzudeuten, sind im Bild mehrere Bereichsrechner und Schutzeinrichtungen an Zonenübergängen gezeigt.

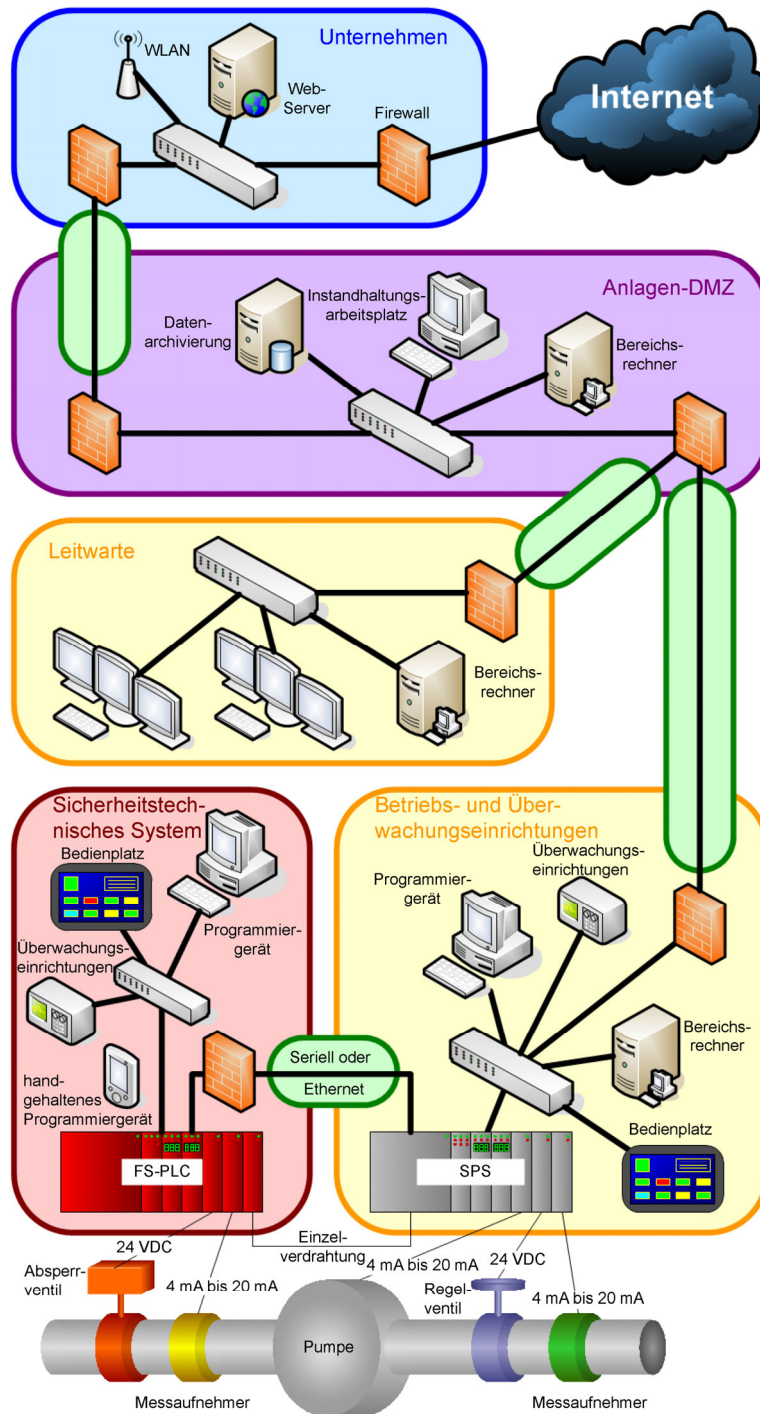


Bild A.1 – Beispiel aus der verfahrenstechnischen Industrie mit Zonen und Conduits

Bild A.2 zeigt eine graphische Darstellung einer Fertigungsanlage. Sie besteht aus vier definierten Zonen: dem Unternehmenskommunikationsnetz, der Industrie-/Unternehmens-DMZ und zwei industriellen Kommunikationsnetzen. Zur Infrastruktur des Unternehmensnetzes gehören ein WLAN sowie eine Verbindung zum Internet. Um den Netzverkehr isolieren zu können, setzen viele Unternehmen eine DMZ zwischen wichtigen Teilen ihres Systems ein. In dem gezeigten Beispiel wird jedes industrielle Kommunikationsnetz relativ unabhängig voneinander betrieben und verfügt hierfür über eine eigene SPS, Feldgeräte und Mensch-Maschine-Schnittstellen.

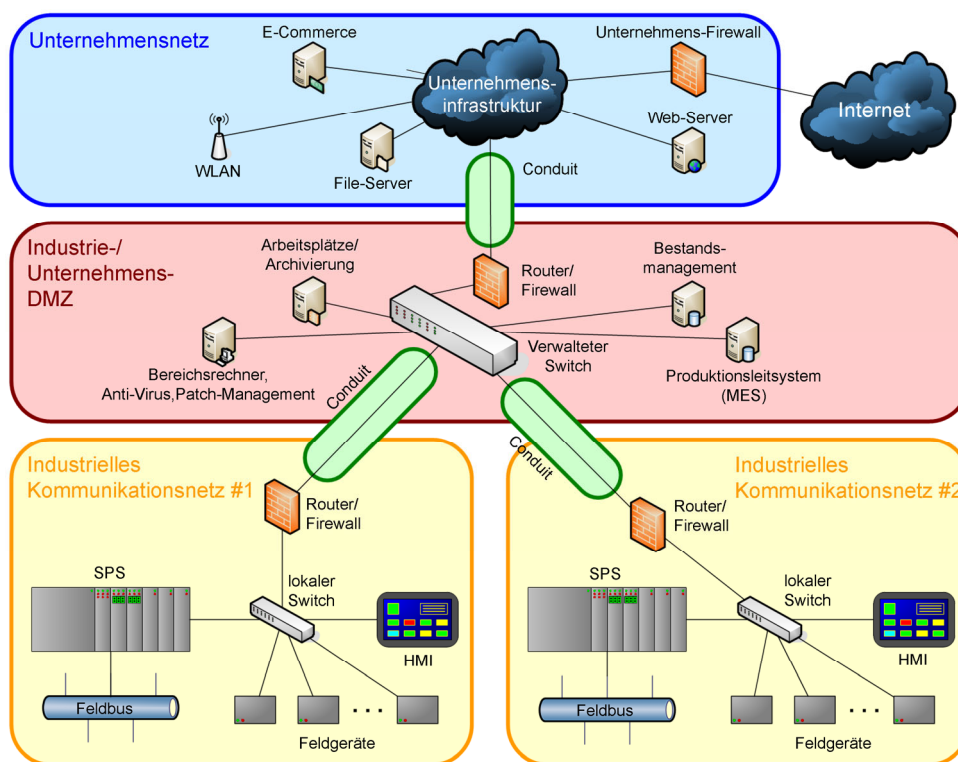


Bild A.2 – Beispiel aus der Fertigungsindustrie mit Zonen und Conduits

Nachdem die SL-Ts festgelegt worden sind, kann das System entwickelt (Green Field) oder überarbeitet (Brown Field) werden, um diese zu erreichen. Der Entwurf verläuft dabei üblicherweise schrittweise, indem der Systementwurf mehrmals gegen die Zielwerte geprüft wird. Mehrere Teile der Normenreihe IEC 62443 enthalten Anleitungen zu den verschiedenen Aspekten der programmatischen und technischen Anforderungen, die in den Entwurf einfließen. IEC 62443-2-1 leitet zu den programmatischen Aspekten des Entwurfsprozesses an, in IEC 62443-3-3 (diese Norm) und IEC 62443-4-2 [10] werden technische IT-Sicherheitsanforderungen auf Komponenten- und Systemebene festgelegt und diese zu verschiedenen SL-C in Beziehung gesetzt.

Im Verlauf des Entwicklungsprozesses eines Systems ist es notwendig, die Fähigkeiten zur IT-Sicherheit der verschiedenen Komponenten und Subsysteme zu bewerten. Produktlieferanten werden diese Merkmale als SL-C für ihre Komponenten oder Systeme beizubringen haben, indem sie die Merkmale und Fähigkeiten mit den in der Normenreihe IEC 62443 für die verschiedenen SL-C definierten Anforderung vergleichen. Diese SL-C können verwendet werden, um festzustellen, ob eine bestimmte Komponente oder ein System fähig ist, die SL-C für das System zu erreichen. Der Produktlieferant oder der Systemintegrator wird ebenfalls zur Konfiguration der Produkte oder Systeme anzuleiten haben, damit die angegebenen SL-C erreicht werden.

Es ist wahrscheinlich, dass es in einem Systementwurf einige Komponenten oder Systeme geben wird, welche die SL-T nicht vollständig erreichen können. Wenn die SL-C einer Komponente oder eines Systems niedriger als die gewünschte SL-T ist, müssen Ausgleichsmaßnahmen in Betracht gezogen werden, um diese zu erreichen. Zu ihnen gehört beispielsweise, den Entwurf der Komponente oder des Systems so zu ändern, dass die betreffenden Fähigkeiten verbessert werden, eine andere Komponente oder ein anderes System zur Erreichung des SL-T zu wählen oder weitere Komponenten und Systeme zu diesem Zweck hinzuzufügen. Nach jedem Iterationsschritt im Entwurfsprozess sollten die vom aktuellen Systementwurf erreichten SL erneut daraufhin bewertet werden, wie sie im Vergleich zur SL-T des Systems stehen.

Nachdem der Systementwurf abgenommen und ausgeführt worden ist, muss das System bewertet werden, damit eine Verschlechterung des SL des Systems verhindert oder hiergegen Abhilfe geschaffen werden kann. Es sollte während oder nach durchgeführten Änderungen sowie auf regelmäßiger Basis bewertet werden. IEC 62443-2-1 vermittelt Leitlinien zu den notwendigen Schritten der Durchführung eines IT-Sicherheitsprogramms und der Bewertung seiner Wirksamkeit. Nachdem die SL-A bestimmt worden sind, wird es notwendig sein zu bewerten, ob das System immer noch die ursprünglichen SL-T erfüllt (beispielsweise unter

Verwendung der Systemanforderungen nach IEC 62443-3-3). Sollte das System diese Anforderungen nicht erfüllen, kann es dafür vielfache Gründe geben, beispielsweise die mangelhafte Aufrechterhaltung des Programms oder die Notwendigkeit zum Neuentwurf von Teilen des Systems.

Im Wesentlichen werden die Fähigkeiten zur IT-Sicherheit des Automatisierungssystems unabhängig von einem bestimmten Anwendungszusammenhang bestimmt, jedoch werden sie in einem solchen verwendet, um die SL-T der jeweiligen Systemarchitektur, Zonen und Conduits zu erreichen (siehe Bild A.3).

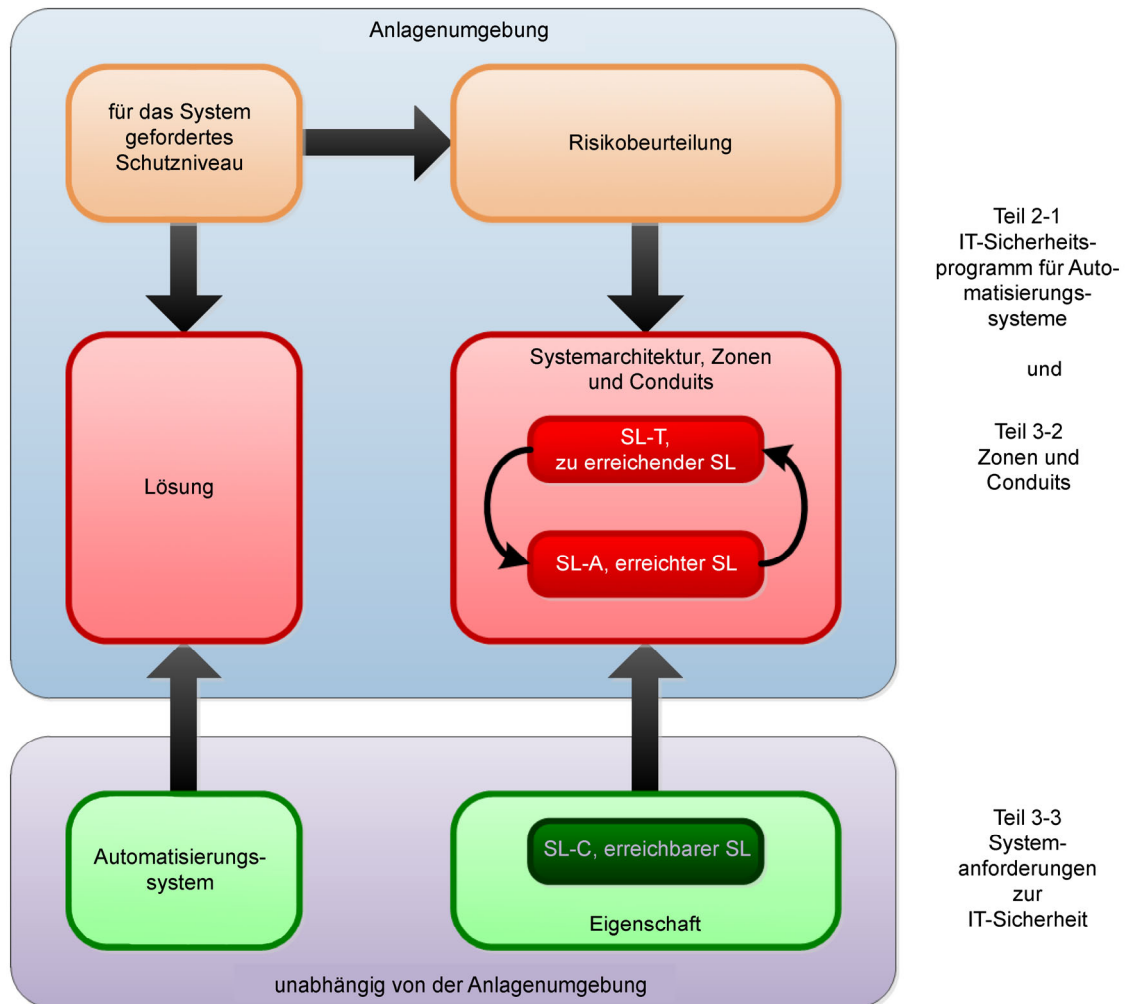


Bild A.3 – Schematische Darstellung der Wechselbeziehung der Verwendung verschiedener SL-Arten

A.3 SL-Vektor

A.3.1 Grundlegende Anforderungen

Die Security-Level (SL) beruhen nach IEC 62443-1-1 auf den sieben grundlegenden Anforderungen (FR) der IT-Sicherheit:

- 1) Identifizierung und Authentifizierung (IAC) (en: identification and authentication control),
- 2) Nutzungskontrolle (UC) (en: use control),
- 3) Systemintegrität (SI) (en: system integrity),
- 4) Vertraulichkeit der Daten (DC) (en: data confidentiality),
- 5) eingeschränkter Datenfluss (RDF) (en: restricted data flow),
- 6) rechtzeitige Reaktion auf Ereignisse (TRE) (en: timely response to events),

7) Verfügbarkeit der Ressourcen (RA, en: resource availability).

Anstatt die Security-Level (SL) zu einer einzigen Zahl zu verdichten, wird ein SL-Vektor verwendet, der die sieben grundlegenden Anforderungen (FR) anstelle eines einzigen Schutzfaktors verwendet. Dieser Vektor von SLs erlaubt definierbare Trennungen zwischen SL für die verschiedenen FR unter Verwendung von Sprache. Diese Sprache kann auf den zusätzlichen Auswirkungen, die mit den IT-Sicherheitssystemen oder mit verschiedenen Angriffen auf die durch die FR vorgegebenen Sicherheitsziele in Verbindung gebracht werden, beruhen. Sie kann praktische Erläuterungen enthalten, warum das eine System sicherer als das andere ist, ohne dass alles zu Auswirkungen auf Gesundheit, Sicherheit und Umwelt in Beziehung gesetzt werden muss.

A.3.2 SL-Festlegung

A.3.2.1 Überblick

In der Normenreihe IEC 62443 werden Security-Level (SL) in fünf verschiedene Stufen (0, 1, 2, 3 und 4) eingeteilt, mit jeder Stufe nimmt die IT-Sicherheit zu. Das aktuelle Modell der SL-Festlegung orientiert sich am Schutz gegen eine zunehmend komplexere Bedrohung und variiert etwas, je nach dem, auf welche SL-Art es angewendet wird. Für SL-C (erreichbares Security-Level) bedeutet dies, dass eine bestimmte Komponente oder ein bestimmtes System vom Betreiber oder Systemintegrator so konfiguriert werden kann, dass sie gegen eine zunehmend komplexere Bedrohungsart schützt. Für SL-T bedeutet dies, dass der Betreiber oder Systemintegrator durch eine Risikobewertung festgestellt hat, dass er diese bestimmte Zone, dieses System oder diese Komponente gegen dieses Bedrohungsausmaß schützen muss. Für SL-A bedeutet dies, dass der Betreiber, Systemintegrator oder Produktlieferant (oder eine Kombination dieser drei) die Zone, das System oder die Komponente so konfiguriert hat, dass die für diese SL festgelegten IT-Sicherheitsanforderungen erreicht werden.

Die Sprache, die für jeden SL verwendet wird, verwendet Adjektive wie gelegentlich, zufällig, einfach, raffiniert und erheblich. Sie ist absichtlich vage gehalten, um sie in allen Normen der Reihe IEC 62443 verwenden zu können. Jede einzelne Norm dieser Reihe wird die Anforderung an die SL, die für ihren bestimmten Zweck zutreffen, festlegen.

Obwohl die Anforderungen für jeden SL innerhalb der Normenreihe IEC 62443 unterschiedlich sein werden, benötigt man ein allgemeines Verständnis, gegen was jeder einzelne SL schützen soll. Die nachfolgenden Unterabschnitte sollen bei der Unterscheidung zwischen den einzelnen SL helfen.

A.3.2.2 SL 0: Keine besonderen Anforderungen oder Schutzmaßnahmen notwendig

SL 0 hat je nach Anwendungssituation unterschiedliche Bedeutungen. Bei der Bestimmung eines SL-C bedeutet er, dass die Komponente oder das System einige der „SL 1“-Anforderungen für diese bestimmte FR nicht erfüllt. Dies wird wahrscheinlich auf Komponenten oder Systeme zutreffen, die zu einer größeren Zone gehören und in der andere Komponenten oder Systeme Ausgleichsmaßnahmen übernehmen. Bei der Bestimmung eines SL-T für eine bestimmte Zone bedeutet er dagegen, dass der Betreiber durch eine Risikoanalyse festgestellt hat, dass weniger als die vollständigen SL 1-Anforderungen für diese bestimmte FR zu dieser Komponente oder diesem System nötig sind. Dies wird wahrscheinlicher auf einzelne Komponenten innerhalb eines Systems oder einer Zone zutreffen, die in keiner Weise zu den FR-spezifischen Anforderungen beitragen. Bei der Bestimmung eines SL-A bedeutet er, dass diese bestimmte Zone einige der SL 1-Anforderungen für diese bestimmte FR nicht erfüllt.

A.3.2.3 SL 1: Schutz gegen gelegentlichen oder zufälligen Missbrauch

Gelegentliche oder zufällige IT-Sicherheitsverstöße ergeben sich üblicherweise durch eine nachlässige Anwendung der IT-Sicherheitsleitlinien. Sie können durch wohlmeinende Angestellte genau so leicht wie durch eine Bedrohung von außen hervorgerufen werden. Viele dieser Verstöße haben etwas mit dem IT-Sicherheitsprogramm zu tun und können durch eine strikte Anwendung der IT-Sicherheitsleitlinien und -vorgehensweisen abgefangen werden.

Betrachtet man [Bild A.1](#), so wäre ein einfaches Beispiel ein Bediener, der in der Lage ist, am Programmiergerät einen Sollwert in der BPCS-Zone auf einen Wert außerhalb der von den Ingenieuren festgelegten Gren-

zen zu setzen. Das System hätte keine ordnungsgemäße Authentifizierung und Nutzungskontrolle durchgesetzt, die die Änderung durch den Bediener verhindert hätte. Ein weiteres Beispiel, ebenfalls nach [Bild A.1](#), wäre ein über das Conduit zwischen der BPCS-Zone und der DMZ-Zone im Klartext gesendetes Passwort, das es einem mit einer Störungsbeseitigung beauftragtem Techniker ermöglicht hätte, dieses mitzulesen. Das System hätte keine ordnungsgemäße Vertraulichkeit der Daten zum Schutz des Passworts durchgesetzt. Ein drittes Beispiel wäre, siehe hierzu [Bild A.2](#), ein Techniker, der auf die SPS im industriellen Kommunikationsnetz Nr. 1 zugreifen möchte, aber tatsächlich auf diejenige im industriellen Kommunikationsnetz Nr. 2 zugreift. Das System hätte keine ordnungsgemäße Einschränkung des Datenflusses erzwungen, die den Techniker daran gehindert hätte, auf das falsche System zuzugreifen.

A.3.2.4 SL 2: Schutz gegen einen absichtlichen Missbrauch mit einfachen Mitteln und geringem Aufwand, allgemeinen Fertigkeiten und geringer Motivation

Der Einsatz einfacher Mittel erfordert seitens eines Angreifers keine großen Kenntnisse. Der Angreifer benötigt keine detaillierten Kenntnisse über die IT-Sicherheit, das Fachgebiet oder das angegriffene System. Die Angriffsvektoren sind wohlbekannt und es kann automatisierte Werkzeuge geben, die dem Angreifer behilflich sind. Sie sind so ausgelegt, dass man mit ihnen einen weiten Bereich unterschiedlicher Systeme angreifen kann, sind also nicht auf ein bestimmtes System ausgerichtet. Ein Angreifer braucht somit über keine besondere Motivation oder Mittel verfügen.

In [Bild A.1](#) wäre ein Beispiel ein Virus, der den Rechner des Instandhaltungsarbeitsplatzes befällt und sich anschließend im Programmiergerät der Betriebs- und Überwachungseinrichtung ausbreitet, da beide das gleiche Betriebssystem verwenden. In [Bild A.2](#) wäre ein weiteres Beispiel ein Angreifer, der einen Web-Server im internen Unternehmensnetz durch einen aus dem Internet heruntergeladenen Exploit, der eine öffentlich bekannte Sicherheitslücke in dessen Betriebssystem ausnutzt, kompromittiert. Der Angreifer bedient sich des Web-Servers als Ausgangspunkt für seine Angriffe gegen andere Systeme, sowohl im Unternehmensnetz als auch im industriellen Kommunikationsnetz. Betrachtet man [Bild A.2](#), wäre ein drittes Beispiel ein Bediener, der über den im industriellen Kommunikationsnetz Nr. 1 aufgestellten Bedienplatz eine Webseite betrachtet, die einen Trojaner herunterlädt, der eine Öffnung in den Routern und Firewalls zum Internet herstellt.

A.3.2.5 SL 3: Schutz gegen einen absichtlichen Missbrauch mit raffinierten Mitteln und mittlerem Aufwand, IACS-spezifische Fertigkeiten und mittlerer Motivation

Der Einsatz raffinierter Mittel erfordert hervorragende Kenntnisse der IT-Sicherheit, des Fachgebietes, des Zielsystems oder einer Kombinationen davon. Ein Angreifer, der es auf ein SL 3-System abgesehen hat, wird wahrscheinlich auf das Zielsystem maßgeschneiderte Angriffsvektoren einsetzen. Er kann sich hierzu nicht besonders bekannte Exploits in Betriebssystemen, Sicherheitslücken in industriellen Protokollen, Informationen über das Ziel und andere Mittel, die gegenüber SL 1 und SL 2 größere Motivation, Fertigkeiten und Kenntnisse erfordern, zu Nutze machen.

Ein Beispiel für raffinierte Mittel sind Werkzeuge, die Passwörter oder Schlüssel mittels Hash-Tabellen brechen. Diese können aus dem Internet heruntergeladen werden, aber für ihren Einsatz sind Kenntnisse des Systems erforderlich (etwa die Hashwerte des zu ermittelnden Passwortes). Betrachtet man [Bild A.1](#), wäre ein weiteres Beispiel ein Angreifer, der sich Zugriff auf die FS-PLC im sicherheitstechnischen System durch das serielle Conduit verschafft, nachdem ihm der Zugriff auf die SPS in der Betriebs- und Überwachungseinrichtung mit Hilfe einer Sicherheitslücke im Ethernet-Controller gelungen ist. Ein drittes Beispiel wäre ein Angreifer in [Bild A.2](#), der sich über das WLAN und durch den Industrie/Unternehmens-DMZ-Firewall durchgeführten Brute-Force-Angriffs Zugang zum Rechner der Archivierung verschafft hat.

A.3.2.6 SL 4: Schutz gegen einen absichtlichen Missbrauch mit raffinierten Mitteln und erheblichem Aufwand, IACS-spezifische Fertigkeiten und hoher Motivation

SL 3 und SL 4 ähneln sich sehr, indem sie beide raffinierte Mittel zur Verletzung der IT-Sicherheit des Systems annehmen. Die Angreifer machen den Unterschied aus, sie sind noch motivierter und verfügen über mehr Ressourcen. Dazu können Hochleistungscomputer, sehr viele Computer oder sehr viel Zeit gehören.

Ein Beispiel für raffinierte Mittel und erhebliche Ressourcen wäre der Einsatz von Superrechnern oder Rechnerclustern zum Ausführen von Brute-Force-Angriffen zum Ermitteln von Passwörtern mittels großer Hash-Tabellen. Ein weiteres Beispiel wäre ein Botnet-Angriff auf das System, bei dem gleichzeitig verschiedene Angriffsvektoren eingesetzt werden. Ein drittes Beispiel wäre ein Verbrechersyndikat, das über

Motivation und Mittel verfügt und Wochen damit zubringt, das System zu analysieren und maßgeschneiderte Zero-Day-Exploits zu entwickeln.

A.3.3 SL-Vektorformat

Mit einem Vektor kann man die IT-Sicherheitsanforderungen einer Zone, eines Conduits, einer Komponente oder eines Systems besser beschreiben als mit einer einzelnen Zahl. Dieser Vektor darf für jede grundlegende Anforderung (FR) entweder eine SL-Anforderung oder den Nullwert (siehe [A.3.1](#)) enthalten.

FORMAT → SL-?([FR,]Bereich) = { IAC UC SI DC RDF TRE RA }

Dabei ist

SL-? = (Pflichtfeld) die SL-Art ist (siehe [A.2.2](#)). Die möglichen Formate sind:

- SL-T = Target SL (zu erzielende SL);
- SL-A = Achieved SL (erreichter SL);
- SL-C = Capabilities SL (erreichbarer SL).

[FR,] = (optionales) Feld, welches die grundlegende Anforderung (FR), zu welcher der SL-Wert gehört, angibt. Die FR werden als Abkürzung und nicht als Zahl angegeben, um die Lesbarkeit zu verbessern.

Bereich = (Pflichtfeld), in diesem gilt der Security-Level (SL). Bereiche können sich auf Zonen, Automatisierungssysteme, Subsysteme oder Komponenten beziehen. Einige Beispiele von in [Bild A.1](#) genannten Bereichen sind Zone des sicherheitstechnischen Systems, Zone der Betriebs- und Überwachungseinrichtungen, Zone des Bedienplatzes innerhalb der Betriebs- und Überwachungseinrichtungen, Bereichsrechner der Anlagen-DMZ, Conduit von der Anlagen-DMZ zur Leitwarte und das Conduit, das die serielle Verbindung vom sicherheitstechnischen System zu den Betriebs- und Überwachungseinrichtungen umfasst. In der vorliegenden Norm beziehen sich alle Anforderungen auf ein Automatisierungssystem, daher wird der Bereichs-Begriff anders verwendet, als es in anderen Normen der Reihe IEC 62443 der Fall sein wird.

BEISPIEL 1 → SL-T(Betriebs- und Überwachungseinrichtungen) = { 2 2 0 1 3 1 3 }

BEISPIEL 2 → SL-C(Programmiergerät im sicherheitstechnischen System) = { 3 3 2 3 0 0 1 }

BEISPIEL 3 → SL-C(RA, SPS im sicherheitstechnischen System) = 4

ANMERKUNG Das letzte Beispiel gibt lediglich die RA-Komponente eines siebendimensionalen SL-C an.

Anhang B (informativ)

Abbildung der Systemanforderungen (SR) und weitergehenden Anforderungen (RE) auf die Security-Level (SL) 1 bis 4 der grundlegenden Anforderungen (FR)

B.1 Überblick

Mit diesem Anhang ist beabsichtigt dem Leser eine Anleitung geben, wie die Security-Level (SL) 0 bis 4 bei den grundlegenden Anforderungen (FR), Systemanforderungen (SR) und weitergehenden Anforderungen (RE) unterschieden werden.

B.2 SL-Abbildungstabelle

Tabelle B.1 zeigt auf, welche SR und RE auf welche FR bei einem zu erreichenden Security-Level SL-C(xx, Automatisierungssystem) zutreffen. Für eine gegebene FR sind die zur Erreichung eines gegebenen SL-C notwendigen SR und RE durch ein Häkchen markiert. Damit zum Beispiel das System SL = 1 bei der grundlegenden Anforderung FR 5 erreicht, müssen die Anforderungen aller vier SR eingeschlossen werden (oder anders ausgedrückt SL-C(RDF, Automatisierungssystem) = 1). Hält ein System nicht alle dieser vier SR ein, so hat es einen SL-C(RDF, Automatisierungssystem) = 0. Um einen SL-C(RDF, Automatisierungssystem) = 2 zu erreichen, müsste ein System alle vier SR sowie RE(1) von SR 5.1 und RE(1) von SR 5.2 unterstützen. Ein anderes Beispiel: Für SL-C(TRE, Automatisierungssystem) = 1 wird lediglich SR 6.1 gefordert, für SL-C(TRE, Automatisierungssystem) = 2 ist jedoch die Einhaltung der beiden dort definierten SR erforderlich. In A.3.3 ist erläutert, wie ein vollständiger SL-Vektor bezeichnet werden würde.

Tabelle B.1 – Abbildung von SR und RE auf die FR für SL 1– 4 (1 von 5)

SR und RE		SL 1	SL 2	SL 3	SL 4
FR 1 – Identifizierung und Authentifizierung (IAC)					
SR 1.1 – Identifizierung und Authentifizierung von menschlichen Nutzern	5.3	✓	✓	✓	✓
SR 1.1 RE 1 – Eindeutige Identifizierung und Authentifizierung	5.3.3.1		✓	✓	✓
SR 1.1 RE 3 – Multifaktor-Authentifizierung über nicht vertrauenswürdige Netze	5.3.3.2			✓	✓
SR 1.1 RE 3 – Multifaktor-Authentifizierung über alle Netze	5.3.3.3				✓
SR 1.2 – Identifizierung und Authentifizierung von Softwareprozessen und Geräten	5.4		✓	✓	✓
SR 1.2 RE 1 – Eindeutige Identifizierung und Authentifizierung	5.4.3.1			✓	✓
SR 1.3 – Nutzerkontenverwaltung	5.5	✓	✓	✓	✓
SR 1.3 RE 1 – Einheitliche Nutzerkontenverwaltung	5.5.3.1			✓	✓
SR 1.4 – Verwaltung der Bezeichner	5.6	✓	✓	✓	✓
SR 1.5 – Verwaltung der Authentifizierer	5.7	✓	✓	✓	✓

Tabelle B.1 (2 von 5)

SR und RE		SL 1	SL 2	SL 3	SL 4
SR 1.5 RE 1 – Beglaubigung der Identität von Softwareprozessen durch Hardwaremaßnahmen	5.7.3.1			✓	✓
SR 1.6 – Management drahtloser Zugriffsverfahren	5.8	✓	✓	✓	✓
SR 1.6 RE 1 – Eindeutige Identifizierung und Authentifizierung	5.8.3.1		✓	✓	✓
SR 1.7 – Stärke der Authentifizierung durch Passwörter	5.9	✓	✓	✓	✓
SR 1.7 RE 1 – Erzeugung und Lebensdauerbeschränkungen von Passwörtern für menschliche Nutzer	5.9.3.1			✓	✓
SR 1.7 RE 2 – Lebensdauerbeschränkungen von Passwörtern für alle Nutzer	5.9.3.2				✓
SR 1.8 – PKI-Zertifikate	5.10		✓	✓	✓
SR 1.9 – Stärke der Authentifizierung durch öffentlichen Schlüssel	5.11		✓	✓	✓
SR 1.9 RE 1 – Beglaubigung öffentlicher Schlüssel durch Hardwaremaßnahmen	5.11.3.1			✓	✓
SR 1.10 – Rückmeldung vom Authentifizierer	5.12	✓	✓	✓	✓
SR 1.11 – Erfolgreiche Anmeldeversuche	5.13	✓	✓	✓	✓
SR 1.12 – Nutzungshinweis	5.14	✓	✓	✓	✓
1.13 – Zugriff über nicht vertrauenswürdige Netze	5.15	✓	✓	✓	✓
SR 1.13 RE 1 – Genehmigung ausdrücklicher Anmeldebegehren	5.15.3.1		✓	✓	✓
FR 2 – Nutzungskontrolle (UC)					
SR 2.1 – Durchsetzung der Autorisierung	6.3	✓	✓	✓	✓
SR 2.1 RE 1 – Durchsetzung der Autorisierung für alle Nutzer	6.3.3.1		✓	✓	✓
SR 2.1 RE 2 – Abbildung der Berechtigung auf Rollen	6.3.3.2		✓	✓	✓
SR 2.1 RE 3 – Eingriff des Aufsichtspersonals	6.3.3.3			✓	✓
SR 2.1 RE 4 – Doppelte Zustimmung	6.3.3.4				✓
SR 2.2 – Nutzungskontrolle von Funkverbindungen	6.4	✓	✓	✓	✓
SR 2.2 RE 1 – Nicht genehmigte drahtlose Geräte erkennen und anzeigen	6.4.3.1			✓	✓
SR 2.3 – Nutzungskontrolle von tragbaren und mobilen Geräten	6.5	✓	✓	✓	✓
SR 2.3 RE 1 – IT-Sicherheitsstatus tragbarer und mobiler Geräte durchsetzen	6.5.3.1			✓	✓
SR 2.4 – Plattformübergreifender Code	6.6	✓	✓	✓	✓
SR 2.4 RE 1 – Prüfung der Integrität eines plattformübergreifenden Codes	6.6.3.1			✓	✓
SR 2.5 – Sitzungssperrung	6.7	✓	✓	✓	✓

Tabelle B.1 (3 von 5)

SR und RE		SL 1	SL 2	SL 3	SL 4
SR 2.6 – Beendigung einer Fernzugriffssitzung	6.8		✓	✓	✓
SR 2.7 – Begrenzung der Anzahl gleichzeitiger Sitzungen	6.9			✓	✓
SR 2.8 – Prüfbare Ereignisse und deren Aufzeichnung	6.10	✓	✓	✓	✓
SR 2.8 RE 1 – Zentral verwaltete systemweite Ereignisaufzeichnung	6.10.3.1			✓	✓
SR 2.9 – Speicherkapazität für Aufzeichnungen	6.11	✓	✓	✓	✓
SR 2.9 RE 1 – Warnung, wenn die Kapazitätsgrenze zur Speicherung von Ereignisdatensätzen erreicht ist	6.11.3.1			✓	✓
SR 2.10 – Reaktion auf ausgefallene Ereignisdatenverarbeitung	6.12	✓	✓	✓	✓
SR 2.11 – Zeitstempel	6.13		✓	✓	✓
SR 2.11 RE 1 – Interne Systemtakte	6.13.3.1			✓	✓
SR 2.11 RE 2 – Schutz und Integrität der Zeitquelle	6.13.3.2				✓
SR 2.12 – Nichtabstreitbarkeit	6.14			✓	✓
SR 2.12 RE 1 – Nichtabstreitbarkeit für alle Nutzer	6.14.3.1				✓
FR 3 – Systemintegrität (SI)					
SR 3.1 – Kommunikationsintegrität	7.3	✓	✓	✓	✓
SR 3.1 RE 1 – Kryptographische Schutzmaßnahmen zur Bewahrung der Integrität	7.3.3.1			✓	✓
SR 3.2 – Schutz vor Schadcode	7.4	✓	✓	✓	✓
SR 3.2 RE 1 – Schutz vor Schadcode an Eingangs- und Ausgangspunkten	7.4.3.1		✓	✓	✓
SR 3.2 RE 2 – Zentrales Management und Meldewesen zum Schutz vor Schadcode	7.4.3.2			✓	✓
SR 3.3 – Verifikation der IT-Sicherheitsfunktionalität	7.5	✓	✓	✓	✓
SR 3.3 RE 1 – Automatisierte Mechanismen zur Verifikation der IT-Sicherheitsfunktionalität	7.5.3.1			✓	✓
SR 3.3 RE 2 – Verifikation der IT-Sicherheitsfunktionalität im laufenden Betrieb	7.5.3.2				✓
SR 3.4 – Software- und Informationsintegrität	7.6		✓	✓	✓
SR 3.4 RE 1 – Automatisierte Hinweise auf IT-Sicherheitsverstöße	7.6.3.1			✓	✓
SR 3.5 – Eingabevalidierung	7.7	✓	✓	✓	✓
SR 3.6 – Vorbestimmte Zustände der Ausgänge	7.8	✓	✓	✓	✓
SR 3.7 – Fehlerbehandlung	7.9		✓	✓	✓
SR 3.8 – Sitzungsintegrität	7.10		✓	✓	✓

AC

Tabelle B.1 (4 von 5)

SR und RE		SL 1	SL 2	SL 3	SL 4
SR 3.8 RE 1 – Annullierung der Sitzungsbezeichner nach Sitzungsbeendigung	7.10.3.1			✓	✓
SR 3.8 RE 2 – Erzeugung eines eindeutigen Sitzungsbezeichners	7.10.3.2			✓	✓
SR 3.8 RE 3 – Zufälligkeit der Sitzungsbezeichner	7.10.3.3				✓
SR 3.9 – Schutz von Prüfinformationen	7.11		✓	✓	✓
SR 3.9 RE 1 – Ereignisdatensätze auf nur einmal beschreibbaren Speichermedien	7.11.3.1				✓
FR 4 – Vertraulichkeit der Daten (DC)					
SR 4.1 – Vertraulichkeit von Informationen	8.3	✓	✓	✓	✓
SR 4.1 RE 1 – Schutz der Vertraulichkeit bei der Speicherung oder Übertragung über nicht vertrauenswürdige Netze	8.3.3.1		✓	✓	✓
SR 4.1 RE 2 – Schutz der Vertraulichkeit über Zonengrenzen hinweg	8.3.3.2				✓
SR 4.2 – Dauerhaftigkeit von Informationen	8.4		✓	✓	✓
SR 4.2 RE 1 – Säuberung gemeinsam genutzter Speicher	8.4.3.1			✓	✓
SR 4.3 – Verwendung von Verschlüsselung	8.5	✓	✓	✓	✓
FR 5 – Eingeschränkter Datenfluss (RDF)					
SR 5.1 – Netzaufteilung	9.3	✓	✓	✓	✓
SR 5.1 RE 1 – Physikalische Netzaufteilung	9.3.3.1		✓	✓	✓
SR 5.1 RE 2 – Unabhängigkeit von nicht-automatisierungstechnischen Netzen	9.3.3.2			✓	✓
SR 5.1 RE 3 – Logische und physikalische Isolierung kritischer Netze	9.3.3.3				✓
SR 5.2 – Schutz der Zonengrenze	9.4	✓	✓	✓	✓
SR 5.2 RE 1 – Standardmäßig verweigern, zulassen von Ausnahmen (Deny by default, allow by exception)	9.4.3.1		✓	✓	✓
SR 5.2 RE 2 – Inselmodus	9.4.3.2			✓	✓
SR 5.2 RE 3 – Im Fehlerzustand geschlossen (Fail close)	9.4.3.3			✓	✓
SR 5.3 – Beschränkung der Mensch-zu-Mensch-Kommunikation	9.5	✓	✓	✓	✓
SR 5.3 RE 1 – Verbot der Verwendung allgemeiner Nachrichtendienste	9.5.3.1			✓	✓
SR 5.4 – Partitionierung von Anwendungen	9.6	✓	✓	✓	✓
FR 6 – Rechtzeitige Reaktion auf Ereignisse (TRE)					
SR 6.1 – Zugriffsmöglichkeit auf Ereignisprotokolle	10.3	✓	✓	✓	✓

Tabelle B.1 (5 von 5)

SR und RE		SL 1	SL 2	SL 3	SL 4
SR 6.1 RE 1 – Programmgesteuerter Zugriff auf Ereignisprotokolle	10.3.3.1			✓	✓
SR 6.2 – Kontinuierliche Überwachung	10.4		✓	✓	✓
FR 7 – Ressourcenverfügbarkeit (RA)					
SR 7.1 – Schutz gegen DoS-Ereignisse	11.3	✓	✓	✓	✓
SR 7.1 RE 1 – Netzbelastung steuern	11.3.3.1		✓	✓	✓
SR 7.1 RE 2 – DoS-Auswirkungen auf andere Systeme oder Netze begrenzen	11.3.3.2			✓	✓
SR 7.2 – Ressourcenmanagement	11.4	✓	✓	✓	✓
SR 7.3 – Datensicherung im Automatisierungssystem	11.5	✓	✓	✓	✓
SR 7.3 RE 1 – Verifikation der Datensicherung	11.5.3.1		✓	✓	✓
SR 7.3 RE 2 – Automatisierung der Datensicherung	11.5.3.2			✓	✓
SR 7.4 – Wiederherstellung des Automatisierungssystems	11.6	✓	✓	✓	✓
SR 7.5 – Notstromversorgung	11.7	✓	✓	✓	✓
SR 7.6 – Netzwerk- und IT-Sicherheitseinstellungen	11.8	✓	✓	✓	✓
SR 7.6 RE 1 – Maschinen-lesbare Meldungen der momentanen IT-Sicherheitseinstellungen	11.8.3.1			✓	✓
SR 7.7 – Geringste Funktionalität	11.9	✓	✓	✓	✓
SR 7.8 – Verzeichnis der Komponenten eines Automatisierungssystems	11.10		✓	✓	✓

Literaturhinweise

ANMERKUNG 1 Diese Literaturhinweise enthalten Verweisungen auf Quellen, die bei der Ausarbeitung dieser Norm verwendet wurden, sowie Verweisungen auf Quellen, die den Leser zu einem besseren Verständnis der IT-Sicherheit als Ganzes und des Entwicklungsprozesses eines IT-Sicherheit-Managementsystems verhelfen können. Nicht alle Verweisungen in diesen Literaturhinweisen werden im Text der Norm erwähnt. Die Verweisungen wurden je nach Quelle in unterschiedliche Kategorien zusammengefasst.

Verweisungen auf andere Teile, sowohl veröffentlichte als auch in Bearbeitung befindliche der Normenreihe IEC 62443

ANMERKUNG 2 Nicht alle genannten Verweisungen beziehen sich auf veröffentlichte Dokumente; einige befinden sich noch in Bearbeitung. Sie sind hier der Vollständigkeit halber für die gegenwärtig zugelassenen Teile der Normenreihe IEC 62443 aufgeführt.

- [1] IEC/TR 62443-1-2, *Industrial communication networks – Network and system security – Part 1-2: Master glossary of terms and abbreviations*³
- [2] IEC/TS 62443-1-3, *Industrial communication networks – Network and system security – Part 1-3: System security compliance metrics*⁴
- [3] IEC/TR 62443-1-4, *Industrial communication networks – Network and system security – Part 1-4: IACS security lifecycle and use-case*⁵
- [4] IEC/TR 62443-2-2, *Industrial communication networks – Network and system security – Part 2-2: Implementation guidance for an IACS security management system*⁶
- [5] IEC/TR 62443-2-3, *Industrial communication networks – Network and system security – Part 2-3: Patch management in the IACS environment*⁷
- [6] IEC 62443-2-4, *Industrial communication networks – Network and system security – Part 2-4: Installation and maintenance requirements for IACS suppliers*⁸
- [7] IEC/TR 62443-3-1, *Industrial communication networks – Network and system security – Part 3-1: Security technologies for industrial automation and control systems*
- [8] IEC 62443-3-2, *Industrial communication networks – Network and system security – Part 3-2: Security levels for zones and conduits*⁹
- [9] IEC 62443-4-1, *Industrial communication networks – Network and system security – Part 4-1: Product development requirements*¹⁰

ANMERKUNG Harmonisiert als EN IEC 62443-2-4.

ANMERKUNG Harmonisiert als EN IEC 62443-4-1.

³ In Bearbeitung.

⁴ In Veröffentlichung.

⁵ In Bearbeitung.

⁶ In Bearbeitung.

⁷ In Bearbeitung.

⁸ In Veröffentlichung.

⁹ In Bearbeitung.

¹⁰ In Bearbeitung.

- [10] IEC 62443-4-2, *Industrial communication networks – Network and system security – Part 4-2: Technical security requirements for IACS components*¹¹

ANMERKUNG Harmonisiert als EN IEC 62443-4-2.

Weitere Verweisungen auf Normen

- [11] ISO/IEC Directives, Part 2:2011, *Rules for the structure and drafting of International Standards*
- [12] ISO/IEC 19790, *Information technology – Security techniques – Security requirements for cryptographic modules*
- [13] ISO/IEC 27002, *Information technology – Security techniques – Code of practice for information security management*
- ANMERKUNG Harmonisiert als EN ISO/IEC 27002.
- [14] NERC CIP-002, *Cyber Security – Critical Cyber Asset Identification*
- [15] NERC CIP-003, *Cyber Security – Security Management Controls*
- [16] NERC CIP-004, *Cyber Security – Personnel & Training*
- [17] NERC CIP-005, *Cyber Security – Electronic Security Perimeter(s)*
- [18] NERC CIP-006, *Cyber Security – Physical Security of Critical Cyber Assets*
- [19] NERC CIP-007, *Cyber Security – Systems Security Management*
- [20] NERC CIP-008, *Cyber Security – Incident Reporting and Response Planning*
- [21] NERC CIP-009, *Cyber Security – Recovery Plans for Critical Cyber Assets*
- [22] NIST FIPS 199, *Standards for Security Categorization of Federal Information and Information Systems*
- [23] NIST SP800-52, *Guidelines for the Selection and Use of Transport Layer Security (TLS) Implementations*
- [24] NIST SP800-53 Rev. 3, *Recommended Security Controls for Federal Information Systems and Organizations*
- [25] NIST SP800-57, *Recommendation for Key Management*
- [26] NIST SP800-82, *Guide to Industrial Control Systems (ICS) Security*
- [27] NIST SP800-92, *Guide to Computer Security Log Management*

Weitere Dokumente und Fundstellen

- [28] Gilsinn, J.D., Schierholz, R., *Security Assurance Levels: A Vector Approach to Describing Security Requirements*, NIST Publication 906330, October 20, 2010
- [29] IETF RFC 3647, Internet X.509 Public Key Infrastructure, Certificate Policy and Certification Practices Framework
- [30] Digital Bond Bandolier project, siehe <http://www.digitalbond.com/tools/bandolier/>
- [31] Open Web Application Security Project (OWASP), siehe <http://www.owasp.org/>

¹¹ In Bearbeitung.